AI how-to sheets

CNIL how to comply

Introduction

What is the scope of the AI how-to sheets?

07 juin 2024

The CNIL wishes to provide concrete clarifications and recommendations for the development of artificial intelligence (AI) systems and the creation of datasets used for their training, when they involve personal data. The CNIL defines the scope of the different how-to sheets.

This content is a courtesy translation of the original publication in French. In the event of any inconsistencies between the French version and this English translation, please note that the French version shall prevail.

Item detail:

The following sheets **concern only the development phase of AI systems, not their deployment,**where this involves the processing of personal data. They are limited to the processing of data subject to the General Data Protection Regulation (GDPR).

They aim at accompanying a large number of professionals with both legal and technical profiles (such as data protection officers, legal officers, legal professionals, AI practitioners, etc.).

Please note: These how-to sheets, adopted following a public consultation, provide a framework to help professionals with their compliance. They recall the obligations imposed by GDPR and make recommendations to comply with them. These recommendations are not binding: data controllers may deviate from it, under their responsibility and provided that they can justify their choices. Some recommendations are also made as good practices and allow one to go beyond GDPR obligations.

The presence of personal data

The how-to sheets relate to dataset creation activities and their use in the development of AI systems where all or part of that data is personal data. In practice, three cases may be encountered:

- **It is certain that no personal data is present in the dataset**: the how-to sheets are not applicable (although some recommendations may be relevant as good practices).

- **It is certain that personal data are present:** the how-to sheets apply. This is the case for AI systems developed from videos or images of people, voice recordings, structured personal data, etc. It should be noted that the European texts lay down the rule that 'mixed' datasets are governed by the GDPR, if both types of data are inextricably linked.

- **Personal data may be present**: this is a frequent case for which the collection of personal data is not expressly desired. For example:
    - residual presence of persons or license plates in images;
    - occurrences of surnames, first names, addresses, etc. in textual data such as comments or prompts, etc.

      In the latter case, the how-to sheets apply. However, verification operations may be carried out as a result of the collection in order to delete the remaining personal data. This can be achieved:

    - **by manual verification**, e.g. when annotating the data;
    - **by automatic verification**, e.g. by using techniques for detecting persons/faces in images, by nameentity recognition methods (NER), etc.

In such cases, provided that the original personal data has been anonymized, and for processing operations subsequent to such deletion, the data loses its personal character and the application of the how-to sheets is

no longer mandatory. Issues related to the risks associated with the use of the system will be the subject of how-to sheets published at a later date.

The AI systems concerned

The CNIL's how-to sheets concern the development of systems implementing artificial intelligence techniques involving the processing of personal data. These are referred to as 'AI systems'.

The definition of AI systems covered by these how-to sheets is aligned with the definition of the EU AI Act just adopted (see box below): a*n AI system is a machine-based system designed to operate with varying levels of autonomy and that may exhibit adaptiveness after deployment and that, for explicit or implicit objectives, infers, from the input it receives, how to generate outputs such as predictions, content, recommendations, or decisions that can influence physical or virtual environments.*

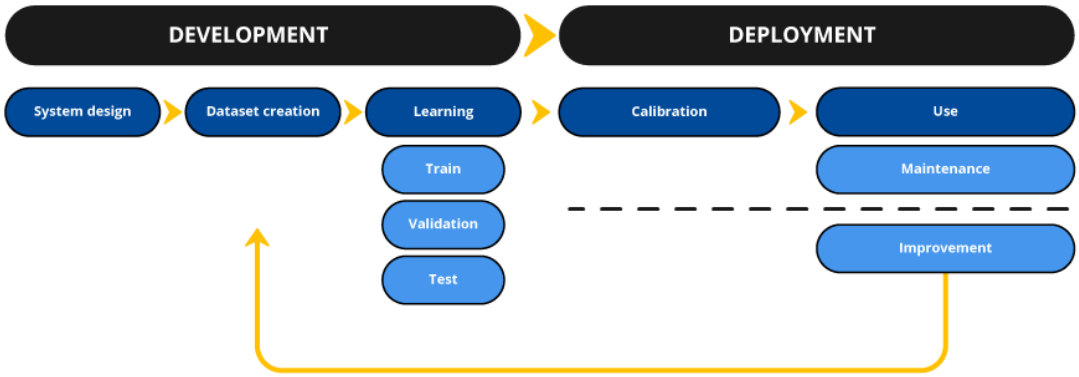
In practice, the AI systems concerned include systems based on machine learning (supervised, unsupervised, by reinforcement) and systems based on logic and knowledge (knowledge-based, inference and deduction engines, symbolic reasoning, expert systems, etc.), as well as hybrid approaches.

The how-to sheets concern those systems whether operational use in the deployment phase is defined at the development stage, or whether they are general purpose AI systems (GPAI), for example relying on "foundation" models, because of their ability to be reused and adapted for different applications and use cases.

They also cover all AI systems as defined above, whether training is done "once and for all" or continuously. In the case of continuous learning, the data collected when the system is deployed is reused for the system's iterative improvement.

Finally, the how-to sheets also concern the process of training existing AI models (fine-tuning / transfer learning), regardless of their integration into a system itself, where they involve personal data.

The phases of the treatment concerned

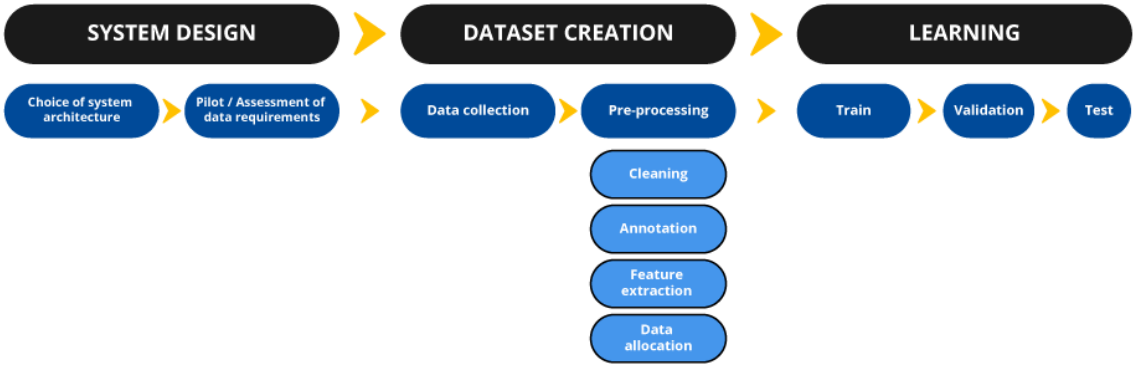


As illustrated in the previous diagram, the establishment of an AI system based on machine learning requires, in principle, the succession of two distinct phases:

- **the development phase**: it consists of designing, developing and training an AI system.
- **the deployment phase**: it consists of putting into use the AI system developed in the first phase.

The development phase includes all stages from the development of the AI system to its deployment (production phase), namely:

- **the design of the system**: choice of the architecture, including the learning method(s) and, where appropriate, the selection of pre-trained models, identification of the necessary data and first tests, pilots;
- **the establishment of the database**: collection and pre-processing (cleaning, annotation, feature extraction, data allocation);
- **learning**: model training, possible fine tuning, adjustment and validation of hyperparameters, performance tests;
- **and sometimes integration**: when the final product expected at the end of the development phase is a system and not a model (for instance a general purpose AI system), inserting the trained model into the information system, connecting to other software components, developing a user interface, writing a user documentation, etc.



In many cases, the development of an AI system will be based on fine-tuning or transfer learning. The CNIL considers that this phase constitutes a second phase of development, distinct from that which produced the original model.

In the case of continuous learning, data is collected during the deployment and development phases (through the use in production of the system), for future improvement. Continuous training is therefore included in this development phase via a feedback loop.

It should be noted that in addition to these two phases, there is a phase of shutdown of the AI system or deletion of personal data that it contained. These sheets do not specify the operations to be carried out during this phase, which are also covered by the regulations on the protection of personal data.

Applicable texts

Regulations on the protection of personal data

The how-to sheets concern, in particular, use cases relating to the phase of development of an AI system (scientific research, research and development, personalisation of a commercial product, improvement of the public service provided to the user, etc.) for which the GDPR is applicable.

Reminder on the scope of the GDPR

The GDPR applies to any organisation:

- public and private, regardless of size (company, administration, community, association, etc.);
- who processes personal data, on its behalf or not;
- established in the territory of the European Union where the processing is carried out in the course of the activities of one of its establishments in the territory of the Union, irrespective of whether or not the processing takes place in the Union;
- or who, not established in the territory of the European Union, directly targets natural persons in the European Union or monitors their behaviour.

Examples:

- **Application of the GDPR to the re-use of datasets created outside the EU**: the GDPR is applicable to the re-use of datasets by a controller or processor established in the European Union where the processing is carried out in the context of the activities of one of its establishments in the territory of the Union, even if those databases have been set up outside the EU and contain the personal data of persons outside the EU. In this case, the controller is therefore obliged to comply with the applicable data protection regulations.

- **Application of the GDPR to the reuse of models trained outside the EU:** the GDPR applies to the use of models created outside the European Union by a controller or processor established within the European Union where they contain personal data and the processing is carried out in the context of the activities of one of its establishments in the territory of the Union.

Data processing in the development phase of the AI system subject to the scope of the Law enforcement directive as well as those relevant to State security and national defense are therefore excluded from the scope of these how-to sheets. However, the recommendations provided can serve as inspiration.

Other applicable regulations

If these how-to sheets are intended to clarify how the development of AI systems can comply with personal data protection obligations, other regulations, which are not addressed directly, may apply. This is, for example, the case of rules on intellectual property law or the regulation on data governance (DGA), which regulates data intermediation services or data altruism.

Others are not yet applicable. This is particularly the case with the proposal for a European AI regulation which aims to frame the development and deployment of AI systems within the European Union.

Finally, sector-specific regulations apply to AI systems developed or deployed for certain applications subject to specific regulation (health, finance, critical systems, etc.). It is up to each controller to determine the applicable regulations and to turn to the relevant regulators.

Interplay between the how-to sheets and the EU AI Act

The European AI Act distinguishes several categories of systems according to their level of risk with regard to product safety and fundamental rights: prohibited systems, high-risk systems, systems requiring transparency guarantees and minimum risk systems. It thus provides for different degrees of obligations based mainly on AI system providers.

CNIL's how-to sheets have been drawn up with a view to an intelligible interplay with these future obligations (e.g. in terms of qualification of actors and risk assessment).

It should be noted, however, that these how-to sheets apply, under constant law, to any processing of data subject to the GDPR in the context of the development of an AI model or system, regardless of the entry into application of the European rules on artificial intelligence. The CNIL also recalls that the AI Act is not intended to replace data protection obligations but to complement them.

The elaboration of more precise rules on the articulation between these different requirements is the subject of European work (within the European data protection board) in which the CNIL actively participates and which will lead to subsequent publications.

1. Determining the applicable legal regime

07 juin 2024

When it contains personal data, the creation of training datasets, as well as the development phase, must comply with the relevant regulations. The CNIL helps you determine the legal regime applicable to data processing in the development phase.

This content is a courtesy translation of the original publication in French. In the event of any inconsistencies between the French version and this English translation, please note that the French version shall prevail.

The principle

The development and deployment phases of an AI system constitute separate processing of personal data, subject to personal data protection regulations. There are different legal regimes depending on the processing:

- **the regime resulting from the General Data Protection Regulation (GDPR)** which is intended to apply to all processing of personal data, both in the public and private sectors, with the exception of processing that fall under the following two specific schemes;

- **the specific regime for the law enforcement sectors** (Title III of the French Data Protection Act);

- **the regime concerning the national defence or the security of the State** governed by the provisions of the French Data Protection Act.

The purpose of this how-to sheet is to define the cases where the data processing in the development phase is subject to the same legal regime as the data processing in the deployment phase, and the cases where they are subject to separate regimes.

As a reminder: the principles and recommendations formulated in the following how-to sheets concern only processing that fall within the scope of the GDPR.

Find out more:

- The scope of CNIL's AI how-to sheets;
- The scope of the Law enforcement Directive.

In practice

In order to determine the regime for data processing in the development phase, two cases must be distinguished.

Case 1: the operational use of the AI system in the deployment phase is defined from the development phase

In the event that the operational use of the AI system in the deployment phase is identified as early as development phase and if the processing operations implemented during the development phase pursue exclusively the same purpose as those in the deployment phase, it may be considered that they are generally covered by the same legal regime (see Conseil d'Etat, 22 July 2022, N° 451653).

This will in particular be the case where the choice of the development of a specific AI system is one of the means identified to achieve the purpose set for the system to be deployed.

It should be noted that the 'law enforcement' regime (Title III of the French Data Protection Act) may apply to processing in the development phase if the following conditions are met:

- the operational use of the AI system is identified from the development stage, so that the processing operations implemented during the development phase have the same purpose only as those in the deployment phase;

- the use of the AI system exclusively pursues the purposes of preventing, detecting, investigating and prosecuting criminal offences

or executing criminal penalties, including the protection against and the prevention of threats to public security;

- the controller in development is a 'competent authority'.

Case 2: the operational use of the AI system in the deployment phase is not clearly defined in the development phase (general purpose AI system)

The development phase and deployment phase of the AI system can be decorrelated.

It is not always possible to clearly identify the purpose of the processing in the deployment phase from the development phase. Some AI systems (*general purpose AI systems*) are developed without a specific operational use and then eventually operated in a second stage.

The legal regime of the development phase is therefore not systematically the same as the one determined in the deployment phase.

In this case, it is generally considered, depending on a case-by-case analysis, that processing in the development phase is subject to the GDPR.

Example: an organisation wishes to develop a voice recognition model capable of identifying a speaker and his/her language in order to commercialise it for different operational uses in the production phase (e.g. tools for identifying people by voice assistants or voice translation applications on a mobile device, etc.).

In this case, the creation of the training dataset falls within the scope of the GDPR.

This does not rule out, depending on the operational use of the AI system, that the processing during the deployment phase may be subject to the 'law enforcement' regime, if it is carried out by a competent authority for the purposes of the prevention, detection, investigation and prosecution of criminal offences or the execution of criminal penalties.

Example: a company develops an image classification system to detect the crossing of an area. It then commercialises it to several entities:

- in the first case, it sells it to a company that uses it for statistical purposes to measure the influx of people entering a mall. In this case, processing in the development and deployment phase will be subject to the GDPR.

- in the second case, it sells it to a national police service that uses it to detect persons crossing prohibited areas for prosecution. In this case, the processing in the development phase will be subject to the GDPR, but processing in the deployment phase will be subject to the 'law enforcement' regime.

2. Defining a purpose

07 June 2024

The creation of a training dataset containing personal data is a processing of personal data which, pursuant to the GDPR, must have a purpose that is 'specified, explicit and legitimate'. The CNIL helps you define the purpose taking into account the specificities of AI systems development

This content is a courtesy translation of the original publication in French. In the event of any inconsistencies between the French version and this English translation, please note that the French version shall prevail.

The principle

The purpose of the processing is the aim of the use of personal data. This objective must be specified, i.e. defined as soon as the project starts. It must also be explicit, that is to say, known and understandable. Finally, it must be legitimate, i.e. compatible with the tasks of the organisation.

The data must not be further processed in a manner incompatible with this initial purpose: the principle of purpose limitation restricts how the controller may use or reuse these data in the future.

The requirement of a specified, explicit and legitimate purpose is particularly important, as it determines the application of other principles of the GDPR, including:

- **the principle of transparency:** the purpose of the processing must be brought to the attention of the data subjects so that they are able to know the reason for the collection of the data concerning them and to understand the use that will be made of it;

- **the principle of data minimisation:** the data selected must be adequate, relevant and limited to what is necessary for the purposes for which they are processed;
- **the principle of storage limitation:** the data may only be kept for a limited period, defined according to the purpose for which it was collected.

How to define the purpose of the processing when the operational use is identified from the development stage?

This case concerns AI systems that are developed for a specific operational use in the deployment phase. This excludes AI systems that are developed without an operational use being defined in the development phase (see next section).

When an AI system is developed for a single operational use, it is considered that the purpose in the development phase is directly related to the one pursued by the processing in the deployment phase. It follows that if the purpose in the deployment phase is itself specified, explicit and legitimate, the purpose in the development phase will also be determined.

In this case, these are still separate processing operations whose compliance with the obligations of the GDPR must be analysed separately (in particular in terms of identifying the legal basis, informing individuals, minimising the collected data, defining retention periods, etc.).

Example: an organisation wishes to set up a dataset consisting of photos of trains in service – that is, with people on board – in order to train an algorithm to measure the influx and attendance of trains at the stations. The purpose in the development phase may be considered to be specified, explicit and legitimate in relation to the identified operational use.

In some cases, an AI system can be developed for several operational uses defined from the development phase. In this case, the development of such an AI system may pursue several purposes corresponding to the operational uses identified (a data processing can indeed simultaneously pursue several purposes if they are all specified, explicit and legitimate).

How to define the purpose of processing for the development of general purpose AI systems?

This case **concerns AI systems whose operational use in the deployment phase is not clearly identified in the development phase**. This is the case for general purpose AI systems and foundation models that can be used for a wide variety of applications and for which it may be difficult to define a sufficiently specified and explicit purpose at the development stage.

Examples:

- An organisation may set up a dataset for training an image classification model (persons, vehicles, food, etc.) and make it publicly accessible, without any specific operational use being foreseen during the development of the model.

  This model can be freely reused in accordance with the associated license (possibly adapted, e.g. using transfer learning techniques), and the rules governing image right and intellectual property, by third-party organisations for the development of computer vision systems. The purposes of the AI system can be varied: detection of people by enhanced camera systems for measuring attendance on station platforms or detection of defects on images taken as part of product quality controls.

- An organisation creates a dataset for training a language model to identify the language register of a text. This model can be used for various tasks: writing and summarizing articles, letters, speeches, learning French, etc.

The purpose of the processing during the development stage may be considered to be specified, explicit and legitimate only if it is sufficiently specific, i.e. **where it refers cumulatively to:**

- **the 'type' of system developed**, such as, for example, the development of a large language model (LLM), a computer vision system or a generative AI system for images, videos or sounds. The types of systems must be presented in a sufficiently clear and intelligible way for the data subjects, taking into account their technical complexities and rapid developments in this area.

- **technically feasible functionalities and capabilities,** which means that the controller must draw up a list of capabilities that he or she can reasonably foresee at the development stage.

These criteria allow to take into account the fact that the controller cannot define at the development stage of an AI system all its future applications, while ensuring that the purpose limitation principle is respected.

Examples of purposes considered to be explicit and specified:

- Development of a large language model (LLM) able to answer questions, generate text according to context (emails, letters, reports, including computer code), perform translations, summaries and corrections of text, perform text classification, analysis of feelings, etc.;

- Development of a voice recognition model capable of identifying a speaker, his or her language, age, gender, etc.;

- Development of a computer vision model capable of detecting different objects such as vehicles (cars, trucks, scooters, etc.), pedestrians, street furniture (dumpsters, public benches, bicycle shelters, etc.), road signs, tricolor lights, road signs, etc.

  Conversely, the purpose would not be considered as specified enough if it only referred to the type of AI system, without mentioning the technically feasible functionalities and capabilities.

Examples of purposes that are not considered explicit and specified:

- Development of a generative AI model (possible capabilities are not defined);

- Development and improvement of an AI system (neither the type of model nor the possible capabilities are defined);

- Development of a model to identify a person's age (the type is not defined).

Warning: the general purpose AI system development manager should remind system users of their obligation to define as precisely as possible the purpose for which the deployment is intended and to ensure compliance. This compliance will depend in particular on considering the specific risks related to this purpose. Some of these risks should be anticipated from the development stage: the CNIL recommends taking into account the risks associated with known or reasonably possible deployments at the development stage, even if the user of the system would be another

controller. When appropriate, the license given to third-party users should allow the data subjects to know the extent of those risks.

Good practice

Transparency of processing is of particular importance for general purpose AI systems. Thus, in addition to complying with the obligations referred to above, the CNIL recommends, as a good practice, that:

- **The purpose refer to the foreseeable capacities most at risk**
  The controller is invited to identify, upstream, the foreseeable capabilities of the AI system that present the most risks in the deployment phase. This would be, for example, the case of AI systems identified as "high risk" under the EU AI Act, .

  These risks may also be taken into account for the realisation of the DPIA (see how-to sheet 5 - Carrying out an impact assessment if necessary).
- **The purpose refer to functionalities excluded by design**
  The description of the system's capabilities may include the choices made with regards to the design of the system, leading to limiting its functionality, such as:
  - the ability of an LLM to treat only short texts, such as publications on social networks;
  - the calculation time required for a computer vision system to perform its detections, which could be too long to perform real-time detection;
  - the list of classes provided for a classification algorithm that would thus exclude the detection of other categories (feelings, objects, etc.).

These limitations could be specified in particular at the end of the testing and validation stages of the development phase, which allows the controller to specify the functional scope of the AI system.

- **The purpose specify, as far as possible, the conditions of use of the AI system**
  The controller may specify the conditions of use of the AI system. These may include, for example, known use cases of the solution or the modalities of use (open source distribution of the model, marketing, SaaS availability, etc.).

  The controller could also provide examples of operational use cases or

purposes of the AI system (e.g. traffic regulation for a computer vision system capable of detecting and quantifying vehicle flows).

How to define the purposes of the development of an AI system for scientific research ?

The controller **must always define the purpose** of the research and the data processing. However, in the field of scientific research, **it may be accepted that the degree of precision of that objective is less precise or that the research purposes are not specified in their entirety**, given the difficulties which researchers may have in identifying it entirely from the beginning of their work. It will then be possible to provide information to clarify the objective as the project progresses.

Possible derogations

Data processing carried out for the purpose of scientific research benefits from derogations and adjustments to certain data protection obligations (e.g. in relation to individuals' rights or retention periods).

- For more information: Scientific research (excluding health)

Reminder: what is 'scientific research' within the meaning of the GDPR?

The notion of "scientific research" is to be understood broadly in the GDPR. In summary, the aim of the research is to produce new knowledge in all areas in which the scientific method is applicable.

In order to assist controllers in determining whether they can benefit from the provisions on scientific research, the CNIL proposes a set of criteria to assist the controller in determining whether the processing which pursues a research purpose falls within the scope of scientific research:

- In some cases, it will be possible to **assume that the creation of training datasets for AI pursues a scientific research purpose due to the nature of the organisation** (e.g. a university or a public research centre) **or the type of funding** (e.g. funding from the French National Research Agency).

- Otherwise, in particular for non-publicly funded private scientific research, the **following criteria (based on the OECD Frascati Manual and its definition of R & D) should be examined together**. As these criteria are cumulative, the controller will in principle have to demonstrate that they are all fulfilled in order for the processing to be considered scientific research within the meaning of the GDPR. Otherwise, a case-by-case analysis is necessary to qualify the processing.
    - **Novelty:** the processing should be aimed at obtaining new results (a novelty may also result from a project that leads to the identification of potential discrepancies with the intended result). The purpose of the research can help in the qualification of scientific research. In this respect, the publication of articles in a peer-reviewed journal or the grant of a patent makes it possible to qualify the novelty criterion.

    - **Creativity:** this criterion is based on original and non-obvious notions and hypotheses – the contribution of the work to scientific knowledge or the state of the art. The development of collective knowledge that not only benefits the moral entity that supports the research project is a strong indication to qualify it as a scientific one.

    - **Uncertainty:** the processing must be uncertain as to the final outcome.

    - **Systematicity:** the processing must be part of planning and budgeting and implement a scientific methodology. Adhesion to relevant industry standards of methodology and ethics is a strong indicator to qualify research as a scientific one.

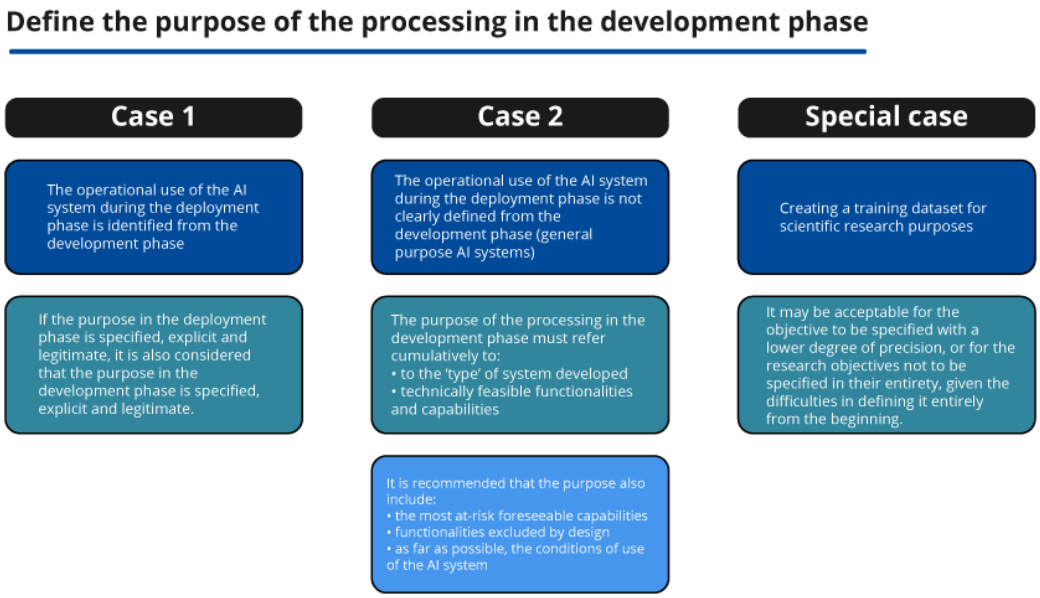
      This is, for example, the case of specific methodological requirements for processing carried out for the purposes of research, study or evaluation in the field of health, which result in particular from Articles 72 et seq. of the French Data Protection Act.

    - **Transferability/reproducibility**: the processing should lead to results that can be replicated or transferred to a wider field. For example, the publication of the study carried out and the presentation of the research methodology adopted is a strong indication to highlight the willingness of the project leader(s) to share the results of the research.

Example:

The development of an AI system for proof of concept to demonstrate the robustness of machine learning requiring less training data could be considered as pursuing scientific research purposes, which would be part of a documented scientific approach for publication.

Find out more:
The re-use of publicly available data for scientific (non-health) research purposes, extracted from the guide [in French].



Text transcript

Case 1 : The operational use of the AI system during the deployment phase is identified from the development phase.

If the purpose in the deployment phase is specified, explicit and legitimate, it is also considered that the purpose in the development phase is specified, explicit and legitimate.

Case 2 : The operational use of the AI system during the deployment phase is not clearly defined from the development phase (general purpose AI systems).

The purpose of the processing in the development phase must refer cumulatively to :

- *the 'type' of system developed*
- *technically feasible functionalities and capabilities*

It is recommended that the purpose also include :

- *the most at-risk foreseeable capabilities*
- *functionalities excluded by design*
- *as far as possible, the conditions of use of the AI system*

Case 3 : Creating a training dataset for scientific research purposes

It may be acceptable for the objective to be specified with a lower degree of precision, or for the research objectives not to be specified in their entirety, given the difficulties in defining it entirely from the beginning.

3. Determining the legal qualification of AI system providers

07 June 2024

AI system providers who intend to create training datasets with personal data must determine their qualification under the GDPR: they may be qualified as controllers, joint controllers or processors.

This content is a courtesy translation of the original publication in French. In the event of any inconsistencies between the French version and this English translation, please note that the French version shall prevail.

Several operators may intervene in the development of an AI system, with varying degrees of involvement in the processing of personal data. In particular, there are:

- AI system providers developing or delegating the development of a system and placing it on the market or putting it into service under their own name or brand, against payment or for free.
- importers, distributors, and users of these systems (i.e. those deploying AI systems).

The qualification of the operators involved in each processing, within the meaning of the GDPR, must be analysed on a case-by-case basis.

The controller

The principle

The controller is the natural or legal person who determines the purposes and means of the processing, i.e. who decides on the “why” and “how” of the use of personal data.

The essential means of processing are those which are closely related to the purpose and scope of the processing, such as the type of personal data collected, the hardware and software used for the processing as well as their security, the duration of the processing, the categories of recipients and the categories of data subjects.

In practice

Some clues may help to conduct the analysis on a case-by-case basis to determine who is responsible for the processing.

A provider who is **at the initiative** of the development of an AI system and who **creates the training dataset based** on data that it has selected on its own account, may be qualified as **a controller.**

The same applies to a supplier who entrusts the creation of such a base to a service provider through sufficiently detailed documented instructions (see the role of processor below).

It should be noted that in some cases a provider will have recourse to a third-party who has already created a dataset as the controller (on its own initiative). It will then be necessary to identify the processing for which the provider is responsible, such as the re-use on its own account of a dataset already constituted.

Examples of controllers:

1. A video streaming platform wants to develop a recommendation AI system. For this purpose, it reuses a dataset of its customers that was originally collected for the purpose of providing the service.
   The streaming platform that creates the training dataset is responsible for this new processing since it has decided on the purpose (train a recommendation AI system) and the essential means of processing (i.e. the dataset it has already collected for another purpose).
2. The provider of a conversational agent who trains its large language model (LLM) from publicly available data on the Internet is controller of the reuse of publicly available personal data on the Internet.
   Indeed, the provider decides both the purpose (proposing a conversational agent) and the essential means of processing (selecting the data to be re-used).

3. A provider develops an AI system based on a pre-trained model with personal data. The provider intends to retrain or adjust the model (through fine-tuning or transfer learning) with a dataset that it set up, at its initiative. In such a case, that provider will have to be classified as a controller, provided that it pursues a purpose of its own and for which it determines itself the essential means.

Reuse of data collected by another organisation

When the provider trains its AI system with data collected by another entity, it is necessary to distinguish:

- **the data diffuser:** the natural or legal person, public or private, who uploads online personal data or a dataset that contains personal data;
- **the re-user of the data:** the natural or legal person, public or private, who processes such data or datasets with the intention of using them on its own account.

The diffuser and the re-user of the data are, in principle, responsible for separate processing, since each determines the objectives and the essential means of its own processing.

The data diffuser is, in principle, responsible for the public dissemination, while the provider of the AI system that re-uses the data is responsible the usage of the data it has. The diffuser is not, in principle, responsible for the re-use of its data. It may, however, lay down conditions for the use of the data disseminated to limit its reuse or provide for certain provisions.

Example: An administration makes real estate data publicly available and freely reusable (open data). A company wants to reuse this data to create a training dataset in order to develop an AI system able to predict certain real estate developments in a given area. The diffuser and the re-user are then responsible for separate processing, provided that these two processings are independent.

Find out more: Sheet 1 of the guide on the opening and reuse of publicly accessible data.

Joint controllers

The principle

When two or more controllers jointly determine the purposes and means of processing, they are joint controllers.

This qualification may be difficult in the presence of several stakeholders having an influence on the determination of the purposes and means of the processing. In particular, stakeholders need to determine whether they process the data for their own and distinct purposes or for a common purpose.

In practice

When the training dataset of an AI system is **fed by more than one controller** for a **jointly defined purpose,** the controllers may be qualified as **joint controllers.**

Examples:

Case 1: academic hospitals developing an AI system for the analysis of medical images choose to use the same federated learning protocol. The latter allows them to exploit data for which they are initially separate controllers, in order to benefit from the mutualization.
Together, they determine the purpose (training a medical imaging AI system) and the means of this processing (through the choice of the protocol and the determination of the data they exploit): they are therefore jointly responsible for this training processing.

Case 2: a consortium consisting of a municipality, a company providing automated image processing software and a company providing video devices is conducting an experiment to install enhanced cameras to record and analyse the flow and behaviour of vehicles using a traffic lane within the municipality. The contract between the city and the two companies provides for the use of the software by the municipality in real-time conditions and the possibility for companies to improve the automated image processing software by the data collected in real time. This improvement of the automated processing software benefits both the municipality and the companies providing automated image processing software and video devices.

The municipality and the two companies would thus be jointly responsible for the processing of the training dataset of the automated image processing software, provided that they jointly decide on the purpose and essential means of the processing and the companies do not act solely on behalf of the municipality. Indeed, it is possible to consider that they jointly decide on the essential means of processing (by choosing to feed the AI system training dataset with real-time data collected by enhanced cameras and data already collected by the company providing the automated image processing software) and the purpose of the processing (experimentally train an AI system that detects particular vehicle behaviour and improves

the automated image processing software).

Conversely, if one of the companies intends to reuse the data for its own purpose, which it would be the only one to benefit from (e.g. in a research and development framework), then it could be considered that it is responsible for a separate processing.

In case of joint control, the parties must ensure the lawfulness of the processing (i.e. its compliance with the law), including by defining in a transparent manner their respective obligations under an agreement. The form of this agreement is not specified by the GDPR. The agreement must reflect the roles of each of the stakeholders, with joint controllers having to clearly specify "who does what" to ensure the protection of the data processed.

Please note: regardless of the terms of the agreement, the data subject may exercise his or her rights vis-à-vis each of the joint controllers.

The use of a processor

The principle

The processor is the natural or legal person who processes data on behalf of the controller, in the context of a service or provision.

In practice

The qualification of the AI system provider must be assessed on a case-by-case basis.

An AI system provider may be a processor when it develops an AI system on behalf of one of its customers as part of a service. The customer is the data controller as soon as they determine the purpose and means of the processing.

In other cases, the AI system provider may be the controller of the systems it designs to market them.

An AI system provider may use a provider to collect and process the data according to its documented instructions (e.g. to collect publicly available data on the Internet, reuse a specific dataset made available online, etc.). **The latter then qualifies as a processor**. It is essential for the

provider of the AI system, as the controller, to ensure that its processor complies with the GDPR and limits the processing of data to its instructions, in particular by concluding a data processing agreement.

Moreover, the fact of using the same dataset for several customers, in the context of separate services, is generally a decisive indication that the provider is responsible for a separate processing, at least for the establishment of the database.

Example: A provider has been entrusted with the creation of a training dataset by an AI system provider who has indicated precisely how it should be developed (in particular with regard to data sources and categories, with quality and documentation requirements). This service provider is likely to act as a processor.

Conversely, a service provider which, on its own initiative, would have created a dataset which it operates by developing AI systems adapted to the needs of each of its customers will likely be responsible for the processing of this dataset, regardless of its role in the specific processing carried out for those customers (which it could implement as a processor, for example on the basis of data provided by the customers themselves).

Ensuring the lawfulness of the data processing - Defining a legal basis

07 June 2024

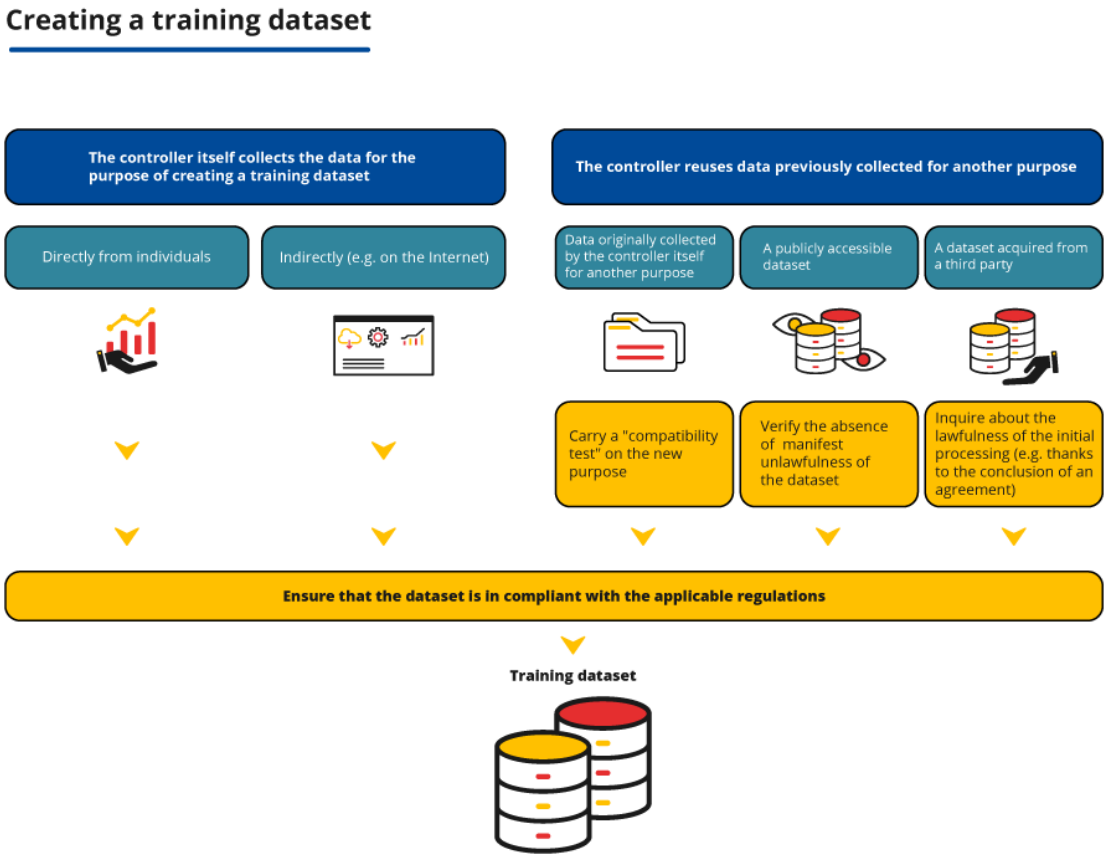
An organisation that wishes to build a training dataset containing personal data and then use it to develop an AI system must ensure that the processing is lawful. The CNIL helps you determine your obligations based on your responsibility and the means of collecting or reusing the data.

This content is a courtesy translation of the original publication in French. In the event of any inconsistencies between the French version and this English translation, please note that the French version shall prevail.

The controller must in all cases define a legal basis and carry out, depending on the method of collection or re-use of the data, certain additional verifications.

There are several ways to build a training dataset, which can be used cumulatively:

- data is collected directly from individuals;
- data is collected from open sources on the Internet for this purpose;
- data was initially collected for another purpose by the controller itself (e.g. in the context of providing a service to its users) or by another controller. **This involves taking additional precautions.**



Define a legal basis

The principle

Like any personal data processing, the creation and use of a training dataset containing personal data can only be implemented if it corresponds to one of the “legal bases” provided for in the GDPR.

The legal basis is what gives an organisation the right to process personal data. The choice of the legal basis is therefore an essential first step to ensure compliance of the processing. Depending on the legal basis, the obligations of the organisation and the rights of individuals may vary.

The most relevant legal bases for training an algorithm are detailed below.

In practice

The determination of the legal basis must be carried out in a manner appropriate to the situation and the type of treatment. In order to establish a dataset for the training of an AI system, **the following legal bases may be envisaged in particular:**

The legal basis for consent

To be valid, the consent of the data subjects must meet four cumulative criteria: **it must be freely given, specific, informed and unambiguous**. The controller must be able to demonstrate the validity of the use of this legal basis by ensuring that each of these conditions, specifically defined by the GDPR, is met.

Example: an organisation wishes to film or photograph volunteers to create a dataset of images to train a system to detect certain specific gestures. It may base the processing on the basis of their consent.

When creating a dataset for, an organisation must ensure the **validity of the consent** collected.

Beyond the obligations of transparency, a certain amount of information must be provided to the data subjects before they consent, in order to enable them to make informed decisions and to allow them to withdraw their consent.

Consent must relate to a specific purpose (see how-to sheet 2 on the definition of the purpose).

The freedom of consent implies, in principle, the possibility for data subjects to give their consent in a granular way, where there are different purposes.

Example: the consent of individuals to the use of their image, collected at a company event for communication purposes, does not mean that they consent to a re-use of the data for building a training dataset or improving an AI system. In this case, two separate consents must be collected (e.g. via two check boxes).

The freedom of consent may also be impacted in the case of an imbalance of power in the relationship between the data subject and the controller, especially if the controller is a public authority or an employer.

Example: a company wants to use the data of its employees to develop an AI system. Their consent can only be validly collected in exceptional situations, where they are able to refuse to give their consent without fear or incurring

negative consequences. As controller, the company must ensure, in any event, that the communications intended to present the device to employees are neither incentive nor binding. It must inform the volunteers of the possibility of no longer participating in the collection of their data at any time, without any consequence.

It does not seem possible to obtain valid consent in some cases. This is often the case when the controller collects data accessible online or reuses an dataset available online, especially given the lack of contact with the data subjects and the difficulty in identifying them. In these cases, the controller must rely on a more appropriate legal basis.

There may also be difficulties related to the right to withdraw consent, for example due to technical obstacles to the identification of data subjects. If it is not possible for the controller to guarantee the possibility of exercising this right, it is recommended to rely on another legal basis.

The legal basis for the legitimate interest

The controller may rely on its legitimate interest provided that it complies with the following conditions:

- **the legitimacy of the interest pursued by the controller.** For example, the interest of an organisation in developing a model for the commercialisation of an AI system or in order to contribute to the improvement of scientific knowledge, for example by publishing the tools developed (code, model, experimentation protocol, etc.) and research results.

- **the necessity of the data processing.** For example, processing for the purpose of creating up a training dataset containing images of people may be considered necessary for the interests of an organisation wishing to develop a pose estimation system, where anonymous or synthetic data are not sufficient.

- **the absence of a disproportionate impact on data subjects' interests and rights and freedoms,** taking into account their reasonable expectations. Balancing of the rights and interests at hand depends on the specific characteristics of the processing and in particular on the safeguards implemented to ensure the best possible balance between those interests and to limit the impact of the processing on the data subjects.

More often than not, creating a training dataset whose use is lawful can be considered legitimate. However, an analysis is necessary to determine whether the use of personal data for this purpose does not disproportionately infringe the privacy of the data subjects, even when the data is not nominative. To guarantee that its processing is proportionate, the controller may implement measures such as: pseudonymisation of the data, ensuring the absence of sensitive data, defining selection criteria to limit the collection to the relevant and necessary data, etc.

Examples: A company wants to develop an AI system that can predict a person's psychological profile from online data that may relate to them. Its commercial interest in developing such a system is likely to be insufficient in the light of the interests, rights and freedoms of data subjects: another legal basis will have to be sought or the project abandoned.

An organisation creates a training dataset by collecting comments made public and freely accessible by online users on forums, blogs and websites. The purpose of this processing is to design an AI system to assess and predict the appreciation of works of art by the general public. In this case, its interest in developing and possibly marketing an AI system may be considered legitimate. The collection of feedback on the works may be considered necessary for the development of the model, especially given the amount of training data required . It should be noted that the legal basis of legitimate interest gives data subjects the right to object to the processing of their data (for reasons relating to their particular situation).

The legal basis of the task carried out in the public interest

The possibility of relying on the legal basis of the "task carried out in the public interest" implies:

- that the task of processing is provided for in a normative text applicable to the controller;
- that the use of the data makes it possible to carry out this task specifically, in a relevant and appropriate manner.

Examples: Researchers from a public research laboratory on the French language wish to analyse the evolution of the use of the language online. To do so, they create a dataset based on comments published online on different social networks (anonymised at short notice) in order to train a model that automatically detects and analyses the occurrence of certain

expressions or spelling forms.

To the extent that the controller is a public laboratory, in this case the researchers may base the data processing on the task carried out in the public interest. This legal basis can be used, in general, for data processing carried out by public or private research laboratories entrusted with a task of public interest, when the processing is necessary for their research activity.

The Pôle d'Expertise de la Régulation Numérique (PEReN) is authorised to reuse, under certain conditions, publicly accessible data from certain platforms in order to carry out experiments aimed in particular at designing technical tools for the regulation of online platform operators, in accordance with Article 36 of Law No 2021-1382 of 25 October 2021 and Decree No 2022-603 of 21 April 2022.

For more information:

- Use case sheet 4 of the guide on the re-use of publicly accessible data (open data)
- What legal basis for research processing?

The legal basis of the contract

The legal basis of the contract could be used for the creation of a training dataset for an AI system provided that a valid contract is concluded between the controller and the data subject and that the processing is objectively necessary for its performance.

Contracts concluded for this purpose must comply with other applicable rules, such as labour law or intellectual property.

Examples: A text editor software company offers an automated and personalised mail generation service, to which the user contractually subscribes, and for which the editor collects the data of the users of this service. The data processing for this personalisation service may be considered, subject to its specific characteristics, necessary for the performance of the contract.

Conversely, the operator of an online social network registered in its general terms and conditions of use that it intends to reuse the data of its users (provided by them, observed or inferred by the operator) to develop and improve new products, services and functionalities useful for its users. It cannot base the processing on the legal basis of the contract since such

processing is not objectively necessary in order to offer them its online social network service (ECJ, 4 July 2023, Meta Platforms Inc. and a. c/Bundeskartellamt, C-252/21).

Sensitive data: prohibited processing, with exceptions

Sensitive data is a particular category of personal data defined in Article 9 of the GDPR. Sensitive data includes, for instance, data revealing the alleged racial or ethnic origin of the data subjects, or biometric data for the purpose of uniquely identifying a natural person, such as a facial template.

The GDPR prohibits the processing of such data, except in the cases listed in Article 9.2. of the GDPR. These exceptions include in particular:

- processing operations for which data subjects gave their explicit consent (active, explicit and preferably written, freely given, specific and informed);

- processing of personal data which is manifestly made public by the data subject;

  In its Guidelines on targeting users of social networks, the EDPB provides a list of factors to be taken into account in determining whether the data is manifestly made public: the default setting of the social media platform, the nature of the platform, the accessibility of the page concerned, the visibility of the information about its public nature, whether the data subject has published the data himself or whether it has been published by a third party or deduced.

  It is important to check whether the data subject wished, explicitly and by a clear positive act, on the basis of an informed setting, to make his or her personal data accessible to the general public or, on the contrary, to a more or less limited number of selected persons (ECJ, 4 July 2023, Meta Platforms, C -252/21).
- processing necessary for reasons of substantial public interest, on the basis of EU or Member State law;

- processing operations necessary for the purpose of scientific research on the basis of European Union or Member State law.

Particular attention should be paid to the collection of sensitive data when using web scraping tools that involve the processing of large volumes of data. The controller has to implement measures to automatically exclude the collection of irrelevant sensitive data, in particular by applying filters to

exclude the collection of certain categories of data or to exclude certain sites that gather sensitive data by nature. If, despite the measures taken, the organisation processes incidentally and residually sensitive data that it had not sought to collect, it is not considered illegal. In particular, the Court of Justice of the European Union held that that prohibition applies to the operator of a search engine "in the context of its responsibilities, powers and possibilities" (ECJ, Grand Chamber, 24 September 2019, GC and Others, C-136/17). On the other hand, if the organisation comes to know that it is processing sensitive data, it has to proceed, as far as possible, to its immediate and automated deletion.

Please note:

- A how-to sheet on bias management will be published at a later date. It will clarify the possibility of processing sensitive data for the purpose of detecting and correcting bias in the training dataset.

- The CNIL is currently conducting work on the issue of AI in health, which will be published later.

The basis of the legal obligation

This legal basis may seem relevant in some cases for data processing carried out in the deployment phase, since an AI system can sometimes be used by the controller to comply with a legal obligation (provided that it requires the processing of personal data). It is however more difficult to rely on this basis for its development.

Indeed, in order to rely on this legal basis, the processing must be necessary to meet a specific legal obligation to which the controller is subject. The text on which it is based must at least define the purpose of the processing and may frame it more precisely (in particular through the types of data to be processed, the limitation of the purposes or other conditions to be respected). The more precise the legal obligation, the easier it is to justify why it requires the processing of personal data.

However, since legal obligations are generally not specific enough to provide for the development of AI systems, it will most often be necessary to rely on another legal basis to develop such systems.

Examples: In the insurance sector, actuarial studies are based on mathematical, probabilistic and statistical models similar to AI systems, the objective of which is to identify, qualify and quantify risks (and associated

amounts) related to insurance contracts.

Since the general solvency obligations of insurance institutions are not sufficiently precise, it is not possible to consider that the development of such systems is necessary for their compliance. The legitimate interest then appears to be the most relevant legal basis.

4. Ensuring the lawfulness of the data processing - In case of re-use of data, carrying out the necessary additional tests and verifications

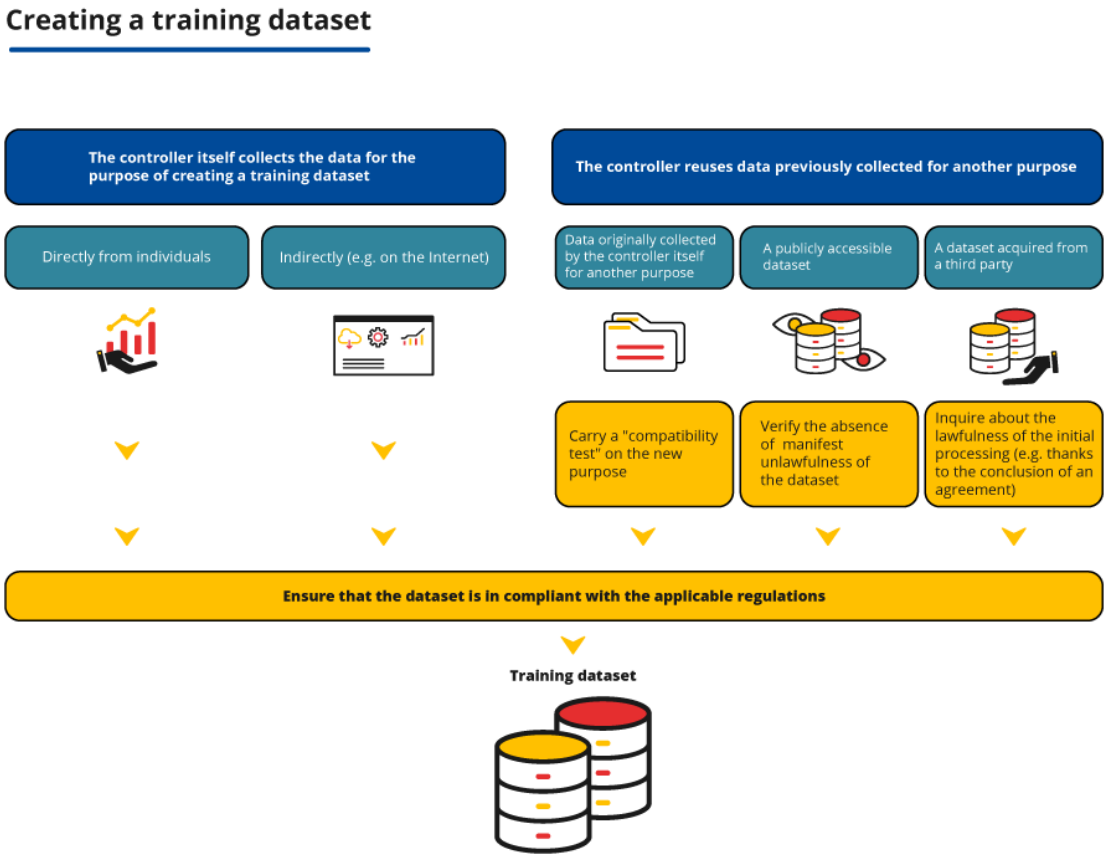
07 June 2024

If it re-uses data previously collected, the data controller is required to carry out certain additional verifications to ensure that that the processing is lawful. The CNIL helps you determine your obligations, depending on the means of collecting the data and its source.

This content is a courtesy translation of the original publication in French. In the event of any inconsistencies between the French version and this English translation, please note that the French version shall prevail.

The principle

In some cases, depending on the methods of collection and the source of the data used for the creation of the training dataset, the controller is required to carry out certain verifications to ensure that the processing of data is lawful. These verifications must be carried out in addition to the identification of the legal basis for the processing.



In practice

The provider reuses the data it originally collected for another purpose

A data controller may wish to reuse the data it has collected for an initial purpose (e.g. in the context of providing a service to individuals) in order to create a training dataset.

In that case, **it must determine whether that further processing is compatible with the purpose for which the data were originally collected**, where the processing is not based on the data subject's consent or on Union or Member State law.

The obligation to carry out this "compatibility test" applies to the further processing of data (within the meaning of Article 6.4 GDPR), i.e.:

- which have not been foreseen or brought to the attention of data subjects when collecting the data;

- which are carried out by the same controller who decides to re-use data for a purpose distinct from the purpose for which it was collected, including when it comes to publishing it on the Internet or sharing it with third parties for re-use for another purpose.

Please note: no compatibility test is required for the intended purposes and brought to the attention of the data subjects as soon as they are collected in accordance with the principle of transparency, including where some of them may appear secondary or accessory. For example, the sharing of data by a controller with its processor for the improvement of the performance of its algorithm does not require a compatibility test, if this purpose was intended and brought to the attention of the data subject (subject to its compliance with the conditions of legality for this purpose of improving the algorithm).

In order to carry out this "compatibility test", it must take into account in particular:

- the existence of a link between the initial purpose and the purpose of the intended further processing;

- the context in which the personal data was collected, in particular the reasonable expectations of the data subjects, depending on the relationship between the data subjects and the controller;

- the type and nature of the data, in particular according to its sensitivity (biometric data, geolocation data, concerning minors, etc.);

- the possible consequences of the envisaged further processing for the data subjects;

- the existence of appropriate safeguards (such as encryption or pseudonymisation).

Examples: The provider of a text editor launches a generative AI feature to complete certain sentences or paragraphs. Some time after the deployment of this feature, it wishes to re-use the manual corrections made by users to the content of the texts thus generated, in order to offer each user a personalised version of their recommendation service (for example to better understand and anticipate the way they write) on the basis of their respective data.

A video streaming platform is now considering reusing the history and playlists it has saved as part of the provision of the service to offer each user a personalised version of their referral service (e.g. to better anticipate and understand their preferences) based on their respective data.

In both cases, the new purpose may be considered compatible with the original purpose of the provision of the service, provided that the guarantees implemented are sufficient (e.g. through the possibility of objecting such re-use without having to provide any grounds) on the basis of their respective data.

Where the reuse of the data pursues statistical or scientific research purposes, the processing is presumed to be compatible with the original purpose if it complies with the GDPR and if it is not used to make decisions regarding the data subjects. The compatibility test is therefore not necessary.

In order to pursue a statistical purpose within the meaning of the GDPR, the processing must only aim at the production of aggregated data for themselves: the sole purpose of the processing must be the calculation of the data, their display or publication, their possible sharing or communication (and not taking subsequent decisions, individual or collective). The statistical results thus obtained must constitute aggregated and anonymous data within the meaning of the data protection regulations. The use of statistical techniques of machine learning is not enough to consider that they are processing "for statistical purposes", since the purpose of processing is not to produce aggregated data for themselves. The use of these techniques is more of a mean to train the model.

The notion of "scientific research" is broadly understood in the GDPR. In summary, the aim of the research is to produce new knowledge in all areas in which the scientific method is applicable. Any processing of data for scientific research purposes must be subject to appropriate safeguards for the rights and freedoms of the data subject, such as anonymisation or pseudonymisation (referred to in Article 89 GDPR).

Learn more:

- Scientific research (excluding health) [In French]

Please note: even when the further processing is compatible, a valid legal basis must always be identified and the data subjects informed, in particular in order to be able to exercise their rights.

Focus: under what conditions can a dataset originally constituted for scientific research purposes be reused?

The GDPR facilitates the reuse of data for scientific research purposes: this reuse is considered compatible with the original purpose of the processing and certain derogations (in particular to the rights of individuals) are possible.

On the other hand, where a controller has processed data for scientific research purposes and intends to reuse them for other purposes (on its own

behalf or to transmit it to a third party), it must comply with certain conditions.

- **The reuse of a dataset will be possible:**
  - **if the data have been previously anonymised, or**
  - **if the reuse is compatible with the purpose for which the controller collected the data** (according to the "compatibility test" detailed above) **and the new processing is implemented in compliance with the GDPR** (information to individuals about this new purpose, identification of a legal basis, etc.). The derogations allowed by the GDPR for scientific research will no longer be mobilised.

    In the event of transmission of the data to third parties, the compatibility of further reuse with the research purpose may be guaranteed in particular by a license.

The provider reuses a publicly accessible dataset

Datasets containing personal data may be freely made available on the Internet outside the legal framework for open data. Most often, it corresponds to data that were already publicly accessible and that constitute a dataset or corpus disseminated on the website of a university or a platform dedicated to sharing datasets, to facilitate their re-use.

Checking the lawfulness of making the dataset available online is primarily the responsibility of the controller who put the dataset online (where appropriate, by ensuring that it is a compatible further processing if it had not initially collected the data for that purpose). However, in order to be able to rely on a valid legal basis under the GDPR, the controller who reuses the data must ensure that they are not reusing a dataset whose creation was manifestly unlawful (e.g. from a data leak).

The re-user may not re-use an established or uploaded dataset for which they cannot ignore that they do not comply with the GDPR (Article 5.1.a GDPR) or other rules, such as those prohibiting breaches of the security of information systems or infringements of intellectual property rights.

In addition, the person who downloads or reuses a manifestly illegal dataset may be guilty of the offence of concealment (Article 321-1 of the French Criminal Code).

The possibility of reusing freely a dataset made available on the Internet is not necessarily subject to in-depth verifications on compliance with all GDPR rules or other applicable legal rules (copyright, data covered by business secrecy, etc.), which are primarily under the responsibility of the organisation that uploads the data. However, an organisation cannot reuse a dataset that would be manifestly unlawful.

This obvious illegality must be assessed on a case-by-case basis. As such, the CNIL recommends that re-users ensure that:

- **The description of the dataset mentions their source.**

Example: a dataset whose description would explain that it was made from publications on a professional social network referred to by name.

Conversely, if a dataset containing video surveillance images does not specify its sources, such a dataset should not be reused until further details have been obtained to remove doubts as to the conformity of its constitution and dissemination;

- The creation or dissemination of the dataset **is not manifestly the result of a crime or an offence nor has been the subject of a public conviction or sanction** by a competent authority which involved the deletion or prohibition of further use of the data;

Examples: a company wishes to create a training dataset to develop a recommendation AI system for its consumers. If it acquires for this purpose a dataset on the dark web from, for example, an infringement of an automated processing system punishable by law (within the meaning of Article 323-1 of the French Criminal Code), it cannot ignore its criminal origin. In this case, the illegality of the dataset would then be obvious.

The same applies to a company wishing to reuse a dataset for which a court decision has found an infringement of an intellectual property right such as that of dataset producers (within the meaning of Article L. 342-1 of the French Intellectual Property Code);

- there is no clear **doubt that the dataset is lawful (in particular that the initial processing is not manifestly lacking a legal basis** when the data are so intrusive that they cannot be processed without the consent of the individuals), ensuring in particular that the conditions for collecting the data are documented enough;

Examples: on a hosting platform for ML practitioners, a company identifies a dataset containing the home-to-work journeys of thousands of people. Its description explains that it is accurate geolocation data, not anonymous,

without detailing the source. In that case, the company cannot ignore that there is a serious doubt as to the lawfulness of the dissemination of such a dataset without the consent of the data subjects.

Conversely, it would be possible to create a dataset from another dataset whose description leaves no clear doubt as to its lawfulness. For example, a pseudonymised dataset, initially made public by data subjects on an identified website and that does not contain sensitive data.

The same applies to the reuse of an aggregated dataset that the diffuser would present as anonymous. For example, an organisation that wishes to create a training dataset to develop an AI system able to predict the socio-economic impact of population ageing could reuse anonymous aggregated datasets containing demographic information (number of active persons, age of persons, fertility rate or elderly dependency rate).

- the dataset does **not contain sensitive data** (e.g. health data or political opinions) or **infringement data** (as defined in Articles 9 and 10 GDPR) or, if it contains such data, it is recommended to carry out additional verifications to ensure that such processing is lawful (mainly for sensitive data to ensure explicit consent of data subjects, or that the data have been clearly made public by the data subjects as specified below and for data relating to infringements that such use is made possible by the French Data Protection Act).

Example: on an online forum, a researcher discovers a non-anonymous dataset that would contain, according to his description, the healthcare information of a hundred patients with a particular pathology and who would come from French hospitals. In this case, the researcher should seriously doubt whether the dissemination of this dataset is lawful in view of the supervision of health data provided for by the GDPR and the French Data Protection Act.

Such prior verifications could be included in the Data Protection Impact Assessment (DPIA).

Certain failures committed by the controller to create and disseminate a dataset do not systematically and irreparably impact the lawfulness of the processing carried out by the re-user. Thus, **a re-user may use a dataset with minor illegalities**, provided that the reuse meets the requirements of the GDPR.

Example: the provision of incomplete information when creating or disseminating the dataset, or a lack of adequate documentation of the compliance of these processing operations (which it is necessary to verify with the diffuser or publisher of the dataset).

The provider reuses a dataset acquired from a third party (data brokers, etc.)

Some providers wish to create a training dataset from datasets owned by third parties.

For the third party who shares personal data, this means ensuring the lawfulness of this transmission

- **Case 1: the data was collected specifically to be shared to create a training dataset**

The third party **will have to ensure that the processing of data transmission complies with the GDPR** (definition of an explicit and legitimate purpose, identification of a valid legal basis, information to data subjects and management of the exercise of their rights, etc.) for which they assume responsibility.

- **Case 2: the third party did not initially collect the data for this purpose**

Where the third party initially collected the data for other purposes (e.g. in the context of the provision of a service to data subjects), it **is for the third party to ensure that the transmission of such data is for a purpose compatible with the purpose(s) which justified its collection.** It will therefore have to carry out a "compatibility test".

Note that the initial owner of a dataset sometimes authorises its use under a license agreement that provides for its terms and conditions (in particular under intellectual property law). This license agreement can, for example, regulate this compatibility by limiting possible reuse.

For the re-user, this usually involves a series of verifications of the initial controller's processing

The controller **must ensure that they do not re-use a dataset whose creation or transmission was manifestly unlawful** (for example, in the absence of an indication as to its source, in case of blatant doubt as to its lawfulness, in particular in the case of the processing of sensitive data, etc.). This results from the general principle of lawfulness of processing in Article 5.1(a) GDPR, in addition to the risk of being guilty of the offence of concealment (Article 321-1 of the French Criminal Code). This implies for the controller to carry out at least the same verifications as those set out in the section above.

The re-user of a dataset transmitted by a third party will be all the less likely to ignore that the dataset was created or shared in breach of the GDPR or of more general rules (such as those prohibiting breaches of the security of information systems or infringements of intellectual property rights) since its relationship with that third party allows it to remove any doubts that it may have.

An agreement between the initial data holder and the re-user is thus recommended in order to enable the latter to ensure the lawfulness of its own processing, even if it is not explicitly required by the GDPR.

In this regard, the CNIL recommends providing a number of indications in the contract such as:

- the source, the context of the data collection, the legal basis for the processing and the data protection impact assessment (see in particular how-to sheet 5 on the implementation of a DPIA) if necessary, in order to avoid the risks of having an unlawful dataset;

- the information provided to the data subjects (especially with regards to the purpose and the recipients);

- any guarantees as to the lawfulness of this data sharing by the original data holder (e.g.: the compatibility of the purpose, the lawfulness of sharing, etc.).

The CNIL provides a description sheet of the dataset that can be used for this purpose.

Please note: if the re-user wishes to base his processing on consent obtained by a third party, they must be able to prove that valid consent has indeed been obtained from the data subjects. The obligation to provide proof of consent cannot be fulfilled by the mere presence of a contractual clause requiring one of the parties to obtain valid consent on behalf of the other party. Such a clause does not allow the organisation to guarantee, in all circumstances, the existence of

valid consent (see the CNIL's deliberation no. SAN-2023-009 of 15 June 2023). The contract may, on the other hand, be used to frame:

- the mechanisms put in place to demonstrate the collection of valid consent;
- the provision of evidence to the organisation wishing to rely on the consent of data subjects;
- where applicable, the conditions under which such evidence must be retained, in particular in order to maintain its probative value.

Example: the provider of a generative AI image system approaches a data broker to create a training dataset including photographs.

To this end, they enter into a contract that guarantees the provider the lawfulness of the data shared and regulates the provision of crucial indications for the compliance of its processing (e.g. evidence of the context of the collection of data in order to assess its legitimate interest, guarantees in relation to other regulations such as governing the assignment of intellectual property rights, etc.).

In addition to these prior verifications, and regardless of the method of collection used, **re-users must ensure that their own processing are fully compliant.**

It should be noted that this obligation also applies when they reuse datasets whose creation and dissemination do not fall within the scope of French or European law. For more information on the territorial scope of the GDPR, see the how-to sheet "What is the scope of the AI how-to sheets".

In particular, the re-user must ensure compliance with the requirements regarding the persons whose data is present in the dataset thus obtained. They must inform them of the processing that they wish to implement, and allow them to exercise their rights.

Please note: a dedicated sheet on the reuse of personal data will be published later. It will complement the elements introduced in this sheet, in particular with practical case studies.

5. Carrying out an data protection impact assessment if necessary

07 juin 2024

Creating a dataset for the training of an AI system can create a high risk to people's rights and freedoms. In this case, a data protection impact assessment is mandatory. The CNIL explains how and in which cases it should be realised.

This content is a courtesy translation of the original publication in French. In the event of any inconsistencies between the French version and this English translation, please note that the French version shall prevail.

The Data Protection Impact Assessment (PDIA) is an approach that allows to map and assess the risks of a personal data processing and to establish an action plan to reduce them to an acceptable level. This approach, facilitated by the tools provided by the CNIL, is particularly useful to control the risks associated with a processing before it is implemented, but also to ensure their follow-up over time.

In particular, a DPIA makes it possible to carry out:

- an identification and assessment of the risks for individuals whose data could be collected, by means of an analysis of their likelihood and severity;

- an analysis of the measures enabling individuals to exercise their rights;
- an assessment of people's control over their data;
- an assessment of the transparency of the data processing for individuals (consent, information, etc.).

The DPIA must be carried out prior to the implementation of the processing and should be changed iteratively as the characteristics of the processing and risk assessment evolve.

The realisation of a DPIA for the development of AI systems

Identifying when a DPIA is needed

The development of AI systems requires, in some cases, the realisation of a DPIA if the envisaged processing is likely to create a high risk to the rights and freedoms of natural persons (Article 35 GDPR).

In its guidelines on the DPIA, the European Data Protection Board (EDPB) has identified nine criteria to assist data controllers, i.e. the AI system providers, in determining whether a DPIA is required. Any processing of personal data fulfilling at least two criteria on this list should be presumed to be subject to the obligation to carry out a DPIA. Some of these criteria are particularly relevant for processing taking place during the development phase:

- the collection of sensitive data or highly personal data (e.g. categories of data that can be considered to increase the risk of harm to the rights and freedoms of individuals, such as location data or financial data);
- the large-scale collection of personal data;
- the collection of data from vulnerable persons, such as minors;
- the crossing or combination of data sets;
- innovative uses or application of new technological or organisational solutions.

In all cases, it is necessary to consider the existence of risks for persons as a result of the establishment of a training dataset and its use: if there are significant risks, in particular due to data misuse, data breach, or where the processing may give rise to discrimination, a DPIA must be carried out even if two of those criteria are not met; conversely, a DPIA does not have to be carried out if several criteria are met but the controller can establish with sufficient certainty that the processing of the personal data in question does not expose individuals to high risks.

On the basis of these criteria, the CNIL has published a list of personal data processing for which the realisation of a DPIA is mandatory (for more information, see the CNIL's website). Of these, several may rely on artificial intelligence systems, such as those involving profiling or automated decision-making: in this case, a DPIA is always required.

Is the use of an artificial intelligence system an "innovative use"?

Innovative use is one of the 9 criteria that can lead to the realisation of a DPIA: it is assessed in the light of the state of technological knowledge and not only of the context of the processing (a processing can be very "innovative" for a given organism, because of the technological novelty it brings to it, without, however, being an innovative use in general). The use of artificial intelligence systems **is not systematically a matter of innovative use or the application of new technological or organisational solutions.** All processing using an AI system will therefore not meet this criterion. In order to determine whether the technique used falls within such uses, it is necessary to distinguish between two categories of systems:

- Systems that use AI techniques that have been experimentally validated for several years and tested in real-life conditions. These systems are not part of the innovative use or application of new technological or organisational solutions.

Example: certain regression or clustering techniques or model architectures such as random forests, in cases where the risks associated with their use are known;

- Systems that use new techniques, such as deep learning, and whose risks are just beginning to be identified today, but are still poorly understood or mastered. These systems are part of innovative use.

Example: generative AI systems trained on large amounts of data whose behaviour cannot be anticipated in all situations.

By way of illustration, a research project aimed at developing automatic language processing tools for clinical applications in the medical field, based on large volumes of data (transcript of audio data, clinical studies,

medical results, etc.), can be an innovative use, especially given the uncertainty as to the results to be obtained.

Is the training of an artificial intelligence system a "large-scale" processing?

Large-scale collection is one of the 9 criteria that can lead to the implementation of a DPIA: while the development of an AI system often relies on the processing of a large amount of data, this does not necessarily fall within the scope of large-scale processing which aims to "*process a considerable amount of personal data at regional, national or supranational level [and which may] affect a significant number of data subjects*" (recital 91 GDPR). For AI systems, in particular, it will be necessary to determine whether the development involves a very large number of people.

Examples: A research organisation wants to build a large dataset of landscape photos (mountain, ocean, desert, cities, etc.) to improve the performance of computer vision systems. Some of these images feature images of individuals, sometimes recognizable.

Even if the dataset has millions of images covering the entire surface of the planet, if the number of images containing recognizable individuals (and therefore personal data) is limited (for example to a few thousand), the processing will not be called "large-scale processing". However, it is not excluded that a DPIA may be required according to the other criteria to be verified.

Where a provider of a conversational agent constitutes a dataset to train its language model (LLM) from a considerable volume of publicly accessible personal data on the Internet collected through web scraping techniques, the processing can be described as "large-scale processing".

Risk criteria introduced by the EU AI Act

The European AI Act aims to provide a legal framework for the development and deployment of AI systems within the European Union. It distinguishes several categories of systems according to their level of risk: prohibited systems, high-risk systems, systems requiring transparency guarantees and minimum risk systems. **The CNIL considers that for the development of all the high-risk systems covered by the AI Act, the realization of a DPIA will be presumed necessary when their development or deployment involves the processing of personal data.**

The realization of the DPIA may be based on the documentation required by the AI Act provided that the elements required by the GDPR (Article 35 GDPR) are included. The elaboration of more precise rules on the relationship between these requirements is the subject of European work in which the CNIL actively participates and which will be the subject of subsequent publications. This work will aim, in particular, to avoid any duplication of obligations on actors by prioritising the reuse of the elements constituted from one framework to another.

Moreover, **the CNIL considers that the development of a foundation model or a general-purpose AI system, in that their uses cannot be exhaustively identified in the majority of cases requires the realisation of a DPIA when it involves the processing of personal data.** Indeed, although these models and systems are not considered to be high risk by default by the AI Act, their dissemination and their future uses could entail risks for those whose data were processed during development, or for the persons concerned by their use.

The realization of a DPIA for foundation models and general purpose AI systems will facilitate the compliance of the processing implemented by their users. In this respect, the sharing or publication of the realized DPIA may facilitate the compliance of all the actors involved, in particular in the case of the dissemination of open source models, or the provision of systems for all.

Defining the scope of the DPIA

The scope of the DPIA may differ depending on the provider's knowledge of the use that will be made, by itself or by a third party, of the AI system it develops.

Where the operational use of the AI system in the deployment phase is identified from the development phase

If the system provider is also the data controller for the deployment phase and if the operational use of the AI system in the deployment phase is identified from the development stage, it is recommended to carry out a general DPIA for the entire processing. The supplier will then be able to supplement this DPIA with the risks associated with both phases.

If the provider is not the data controller for the deployment phase but identifies the purpose of use in the deployment phase, it may propose a model of DPIA accordingly. This may allow it, in particular, to take into account certain risks that are easier to identify during the development

phase. However, the user of the AI system, as controller, remains obliged to perform a DPIA, for example on the basis of the provider's template.

It should be noted that, in some cases, it is not possible to determine precisely and in advance the supervision of the deployment phase. For example, some risks can be reassessed after a calibration phase of the AI system under its deployment conditions. **The DPIA will then have to be modified iteratively** as the characteristics of the processing are defined at the deployment stage.

Where the operational use of the AI system in the deployment phase is not clearly identified in the development phase

In this case, the provider of the system will only be able to carry out its impact assessment on the development phase. It will then be up to the controller of the deployment phase to analyse, with regard to the characteristics of the processing, whether a DPIA is necessary for that phase. If the purposes of the deployment phase are multiple, the controller may decline the same general DPIA for each of the specific use cases

---

AI Risks to consider in a DPIA

Processing of personal data based on AI systems present specific risks that should be taken into account:

- the risks to data subjects related to misuse of the data contained in the training dataset, in particular in the event of a data breach;
- the risk of automated discrimination caused by the AI system introduced during development, for example linked to a lower performance of the system for certain categories of people;
- the risk of producing fictitious content on a real persons, which is particularly important in the case of generative AI systems, and may have consequences for their reputation;
- the risk of automated decision-making caused by automation or confirmation. This risk may arise in particular if the necessary explanatory measures are not taken during the development of the solution (such as the use of a trust score, or intermediate information such as saliency map), thus limiting the ability of the agent using the system to verify its performance under

real conditions. This risk may also arise when the staff member is unable to take a decision contrary to the outputs of the system without prejudice to them (due to hierarchical pressure, for example);

- the risks associated with known attacks specific to AI systems such as attacks by data poisoning, by inserting a backdoor, or by model inversion;

- the risks related to the confidentiality of the data that could be extracted from the AI system;

- Systemic and serious ethical risks related to the deployment of the system, such as impacts on the democratic functioning of society, or respect of fundamental rights (e.g. in cases of discrimination), which can be taken into account during the development phase.

- Finally, the risk of users losing control over their published online and freely accessible data, as large-scale collection is often necessary for training an AI system, in particular when it is collected by web scraping;

When several data sources are used for the development of the AI system, the risks mentioned here are to be taken into account for each source, but also for the overall set thus constituted. Moreover, where the system is developed on the basis of a pre-trained model provided by a third party, the model must still be subject to the risk analysis described above, for example on the basis of information provided by the body providing the model.

Finally, analyses from benchmarks published by the CNIL or by third parties may be integrated or associated with the DPIA. Among these benchmarks, the CNIL recommends using:

- the self-assessment guide published by the CNIL;

- the benchmarks and frameworks identified by the CNIL on the page "Other guides, tools and good practices ";

- the EU AI Act, and in particular its Annex IV detailing the technical documentation to accompany the placing on the market of high-risk AI systems.

Link between the documentation requirements of the AI Act and the implementation of a DPIA

While both documents are part of a risk anticipation logic and can overlap, there are significant differences between the DPIA and the documentation of compliance of the proposed AI Regulation.

On the one hand, they differ in their scope. Since some AI systems that are not classified as high-risk will rely on processing operations that pose risks to the protection of personal data, these will require the implementation of a DPIA.

On the other hand, it will be up to the controller in question, whether the latter concerns the development or deployment of the system, to carry out a DPIA, whereas the documentation requirements of the AI Act will essentially weigh on the provider of the AI system.

However, it is foreseen that in cases where an AI system provider subject to the documentation requirements of the AI Regulation is also required to carry out a DPIA, it is encouraged to include elements from the first document in the second document. The elaboration of more precise rules on the relationship between these requirements is the subject of European work in which the CNIL actively participates and which will be the subject of subsequent publications. They will explore the possibility of working only on a single document incorporating the requirements of the DPIA and AI Act documentation.

Find out more: The CNIL DPIA Guides

Actions to be taken on the basis of the results of the DPIA

The DPIA is an exercise that first determines the level of risk associated with the processing of personal data. Based on this level, a set of measures should be devised in the DPIA to reduce and maintain it at an acceptable level. These measures must incorporate the CNIL's recommendations that apply, whether they relate to AI techniques used or not.

Learn more: DPIA – Knowledge Bases

In addition, certain measures specific to the AI field – in particular of a technical nature – may be implemented, including:

- security measures, such as homomorphic encryption or the use of a trusted execution environment;
- minimisation measures, such as the use of synthetic data;

- anonymisation or pseudonymisation measures, such as differential privacy;
- data protection measures such as federated learning ;
- measures to facilitate the exercise of rights or remedies for persons, such as machine unlearning techniques, or measures to explain and trace outputs from AI systems;
- audit and validation measures, for example based on fictitious red teaming attacks, in particular to identify and correct biases or errors against certain persons or categories of persons.

Other, more generic measures may also be applied:

- organisational measures, such as supervision and limitation of access to training datasets, which may allow for a modification of the AI system, the limitation of access to data by third parties and subcontractors;
- governance measures, such as the setup of an ethical committee;
- measures of traceability of actions carried out in order to identify and explain abnormal behaviour;
- measures providing for internal documentation, such as the drafting of an IT charter.

These measures should be selected on a case-by-case basis in order to reduce the risks specific to the processing of data in question. They will need to be integrated into an action plan and monitored. In addition, being intended to protect data during the development of the AI system and in particular when setting up the dataset, they may be complemented by other AI-specific measures to be applied during the deployment phase. In particular, a description of the specific measures for the deployment of generative AI will be provided at a later stage.

Finally, the publication of all or part of the DPIA is recommended to improve transparency: while some parts of the DPIA do not have to be published to the extent that they may be covered by business secrecy or give confidential information on the security of the system, others present the risks and measures taken to limit them and their publication is of interest to system users and the general public.

6. Taking into account data protection when designing the system

07 June 2024

To ensure that the development of an AI system respects data protection, it is necessary to carry out a prior reflection when designing it. This sheet details the steps involved.

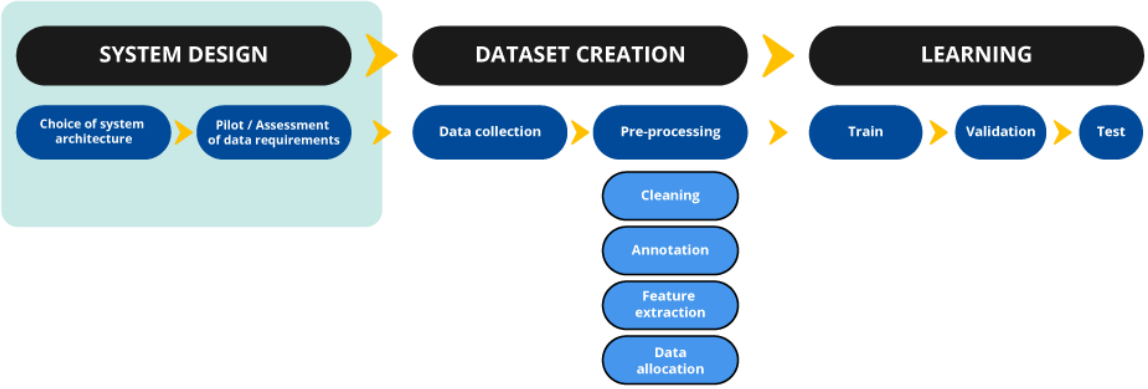
- [illegible]
- [illegible]

This content is a courtesy translation of the original publication in French. In the event of any inconsistencies between the French version and this English translation, please note that the French version shall prevail.

When considering the design choices of an AI system, the principles of data protection, and in particular the minimisation principle, must be respected. This approach takes place at four levels. A controller must therefore ask itself about:

- **the objective of the system** it wishes to develop;
- **the method to be used** which will affect the characteristics of the dataset;
- **the data sources mobilized** (see the how-to sheet on the compliance of the processing with the law, on open sources, on third parties, etc.) and among these sources, **the selection of data strictly necessary**, in view of the usefulness of the data and the potential impact their collection has on the rights and freedoms of data subjects;

- **the validity of the choices** previously made. Such validation may take different (non-exclusive) forms, such as a **pilot study** or the solicitation of an ethics committee.



The objective of the system

The aim of this step is to design, on the basis of the identified purpose (see how-to sheet 2 Defining a purpose), a system that complies with a specification, while limiting the potential consequences for the data subjects.

By specifying the use of the AI system in the deployment phase (whether implemented directly by the provider or by a third party), the system provider must determine:

- the type of expected results/outputs;
- acceptable performance indicators of the solution, whether quantitative (F1-score, mean squared error, computation time) or qualitative indicators (e.g. from human feedback);
- the context in which the system is used in order to identify priority information for its operational use;
- excluded contexts of use and information not relevant to the envisaged main use case(s) of the system.

Some AI techniques can allow for complex tasks that go beyond the initial objectives of the provider. By precisely defining the expected functionality, it is possible to avoid risks of over-collection.

Example: for the purpose of training an AI system using video protection camera images to estimate the number of persons standing in a tram , the following systems are technically feasible:

- a neural network used for the detection of the presence of people in a wagon, without posture analysis, integrated into an algorithm making a count of standing people (the number of standing people can be inferred from the number of seating positions);

- a neural network performing an analysis of the posture of people in a wagon integrated into an algorithm counting standing people.

The first network could provide less information (including the count of standing persons). However, if the estimate given is sufficient for the intended use case, in particular for the calculation of occupancy statistics, then it is preferable to use this model. Indeed, it will require a smaller amount of data for its training and at the same time meet the objective pursued, while the latter requires the collection and annotation of more specific and larger datasets. The principle of minimisation then converges with the reduction of system design costs, without prejudice to the accuracy of the system.

The method to be used

Quite often, the same task can be carried out by different techniques. However, not all of them are equivalent, as they do not necessarily involve using the same data and the same amount. They may not make it possible to achieve the same level of performance, present more or less important challenges in terms of explainability, be subject to different operational constraints (such as the computational cost). While taking these issues into account, **the system provider must select the technique most respectful of the rights and freedoms of individuals in order to respect the principle of data minimisation taking into account the objective pursued.** In other words, if a technique performs the same function/allows to achieve the same result with less personal data, it must be preferred.

In particular, machine learning methods require generally the use of a very large amount of data. In order to ensure compliance with the principle of proportionality and data minimisation, the use of these technical solutions must therefore be justified. If there is a method that does not use machine learning and serves the objectives pursued, it must be preferred. Thus, the use of deep learning must be justified and should therefore not be systematic.

Example: To ensure the safety of employees, a supplier wants to delineate a hazardous area not to be crossed in his warehouse. He wants a solution that detects the presence of a person in this area and triggers an audible signal to

warn the person of the danger. The use of an infrared motion detector should be preferred instead of an enhanced camera, as this solution does not collect people's image, in accordance with the principle of data minimisation and data protection by design.

Semantic analysis of the content of a text could be carried out by a neural network based on annotated textual data, by an ensemble method such as a forest of decision-making trees or by an unsupervised algorithm, such as a clustering algorithm.

At the model training stage , account should also be taken of any uncertainty about the performance of a given architecture: compliance with the principle of minimisation shall be assessed on the basis of available scientific knowledge.

According to the advances in the concerned field, this reflection must be based on several factors for each of the architectures under consideration. This technical analysis can be done through:

- **a state of the art,** by means, for example, of:
  - a study of scientific literature (census and study of academic or private publications, specialised conferences, etc.);
  - a survey of the practices followed by professionals in the field: computer code open sourcing (including by placing it under a free license) of certain players in the sector may help to compare techniques;
  - the solicitation of the community (online competitions or challenges, online forums, conferences and dedicated meetings, etc.);
- a comparison of the results obtained after the implementation of several architectures in the form of a 'proof of concept';

- a comparison of the results obtained from the use of an existing and pre-trained model (which may possibly require fine-tuning) and a model developed by the supplier.

While the choice of AI models and algorithms may limit data collection, other design choices should be taken into account, notably with regards to the privacy by design principle. The choice of the training protocol used, in particular, may make it possible to limit access to the data only to authorised persons, or to give access only to encrypted data. Two techniques, applicable in certain situations, are particularly interesting:

- Decentralised training protocols, such as federated learning, to which a LINC article has been dedicated. This technique makes it possible to train an AI model from several datasets kept separately and, thus, for each party in the chain to keep their hands on their data. However,

this technique has certain risks, concerning the security of decentralised datasets, as well as trust between actors among whom a malicious actor could conduct a poisoning attack for example.

- **The resources offered by cryptography.** Recent scientific advances in the field of cryptography can provide strong safeguards for data protection. Depending on the use cases, it may, for example, be relevant to explore the possibilities offered by secure multiparty computation, or homomorphic encryption. The techniques used in this field make it possible to train an AI model on data that remains encrypted throughout the learning process. However, they remain limited in that they cannot be applied to all types of models and because of the additional computational cost they induce. In addition, some of them, such as homomorphic encryption for training neural networks, are still under development. As technical developments are frequent in this area, it is advisable to keep an active watch on this subject.

This list of measures is not exhaustive, additional measures could be cited such as the use of a trusted execution environment, differential privacy applied during the training phase or machine learning. More generally, due to the rapid evolution of the technology, it is recommended to conduct a technological watch on the privacy practices applicable when developing AI systems.

The selection of strictly necessary data

The principle

The **principle of minimisation** provides that personal data must be **adequate, relevant and limited** to what is necessary for the purposes for which they are processed. Particular attention must be paid to the nature of the data and this principle must be applied in a particularly rigorous manner when special categories of data are processed (within the meaning of Article 9 GDPR).

In practice

The principle of minimisation does not mean that it is forbidden to train an algorithm with very large volumes of data: it involves having a reflection before training so as not to resort to personal data that would not be useful

for the development of the system. In order to identify the personal data necessary, four dimensions should be taken into account:

- **Volume:** number of data subjects, historical depth, accuracy of data, distribution of data according to situations and populations, etc. It may be justified, for example, by the limited computing capacities of the servers used for training, the needs in terms of representativeness of the dataset, the practices commonly accepted by the scientific community, a comparison of the results obtained by varying the volume of data, a statistical analysis demonstrating that a minimum amount of data is necessary to achieve significant results, etc.;
- **Categories:** age, gender, face image, social network activity, etc. The presence of special categories of data or highly personal data should be examined and justified (see how-to sheet 3, Determining the legal qualification of stakeholders). This analysis may be based on the need to train the model on counterfactual data (likely to give rise to false positives in practice), a study of the usefulness of the data categories concerned (see box below), etc. Among these categories of data, preference should be given to the least intrusive format without loss of information for the objective pursued, e.g. age or age range rather than a full date of birth;

- **Typology:** real, synthesised, augmented, simulation data, anonymised or pseudonymised data, etc.;

- **Sources:** as explained in the how-to sheet 3, Determining the legal qualification of stakeholders,identification of the data sources that are envisaged to be used, whether initial collection or re-use (data available in open source, previously collected by the provider or from data providers).

Although data selection is a generally necessary phase in order to design an AI system based on quality data, in some cases and in the alternative, it may be possible to process a dataset indiscriminately. The necessity will then have to be justified.

In addition to taking into account these technical dimensions, **particular attention will have to be paid to the nature of the data within the meaning of the GDPR**, and in particular in the case of sensitive or highly personal data.

Please note:

Issues relating to **data distribution and representativeness** should also be addressed at this stage. They are essential in order to **minimise the risk of discriminatory biases.**

Linked to this question, lies the one about the inclusion of “true negative” data in the training dataset (in particular for test and validation in order to verify the absence of certain edge cases).

As these questions are particularly important, a dedicated how-to sheet will later be published.

The validity of design choices

At the end of the previous three stages, design choices are theoretically validated and data collection can begin. In order to confirm the design choices quantitatively and qualitatively, several measures are recommended as good practice.

Conducting a pilot study

The objective of the pilot study is to ensure that the choices of a technical nature and those relating to the types of data identified are relevant. To do this, small-scale experimentations can be carried out. Fictitious, synthetic, anonymised or otherwise personal data collected in accordance with the GDPR may be used.

Examples: **The use of data from social networks on the personal pages of persons who gave their consent to the collection of their data.**
This type of experimentation does not always offer a representative view of the activity encountered on social networks, but it can be adapted to certain use cases such as the identification of hate content or the study of advertising targeting on these networks. This practice is beneficial because it offers a much higher level of transparency than certain practices such as web scraping.

The design of a film recommendation system
An organisation may collect from voluntary users the list of films viewed over a week and those viewed in the following days, either by declarative data or by collecting their viewing history on dedicated sites. It can conduct its pilot study on the data thus collected by anonymising the identifiers of each user.

Solicitating an ethics committee

The association of an ethics committee with the development of AI systems is a good practice to ensure that ethical issues and the protection of human rights and freedoms are taken into account upstream.

The ethics committee may have several tasks:

- the formulation of opinions on all or part of the organisation's projects, tools, products, etc. which may be subject to ethical problems;

- the facilitation of reflection and the elaboration of an internal doctrine on the ethical aspects of the development of AI systems by the organisation (e.g. what conditions for subcontracting);

- the creation of guidance regarding collective and individual attitudes and the recommendation of certain principles, behaviours or practices.

The composition and role of this committee may vary depending on the situation, but several good practices are recommended. The ethics committee should:

- **be multidisciplinary:** the profiles of the members of the committee – employees of the organisation and/or external persons – must be diversified. Members contribute to the committee's missions and can update issues that the development teams had not considered. A good practice is to assign certain committee seats to the employees of the organisation. In addition, the diversity of the members of the committee in terms of gender, age and ethnic and cultural origin is strongly encouraged;

- **be independent:** the opinions delivered by the committee may have important implications, for example for the commercial management of a company and thus favour or disadvantage some of its projects. Thus, the peoples in the committee must not be motivated by any gain (whether financial or other) to be derived from the decisions produced. Similarly, when employees sit on the committee, decisions rendered must not have consequences for them;

- **have a clearly defined role**: in order to ensure the systematic integration of the committee, a procedure must be established to determine the conditions under which the committee meets and must be associated. Depending on the situation, the committee may simply be advisory or adopt binding opinions: both approaches have advantages and disadvantages. If the committee delivers binding

opinions, its inclusion in corporate governance must be particularly well defined in terms of the body's statutes, in order to avoid its instrumentalisation. If the committee is advisory, its impact must be guaranteed, in particular by ensuring mandatory referral according to precise criteria and wide transparency of its opinions, at least within the organisation and possibly other measures such as the obligation for the project owner to reply in writing to the committee's comments;

- **be notified:** the committee is encouraged to monitor technological and usage developments, document its opinions and share its knowledge. The risks associated with the use of AI evolve with technical development and new uses in this field, and it is necessary to keep a watch, in particular through the academic literature and publications of entities competent in this field (such as the Défenseur des Droits, or the French National Advisory Ethics Council for Health and Life Sciences). The dissemination of acquired knowledge will support advice and spread good practices.

In the case of the development of an AI system, the opinion of the ethics committee could be sought on several issues:

- Do the data used for development meet the ethical criteria of the organisation?

- Could the intended operational uses for the AI system have serious individual or societal consequences? Can these consequences be avoided? Can these operational uses be excluded?

- Could the potential misuse of the AI system (whether voluntary or accidental, in particular for open source models) have serious consequences for people or society? What measures would prevent them?

- Are the technical choices sufficiently controlled by the body (in the case of the use of radically new approaches)?

- Are transparency measures sufficient for the exercise of the rights of persons or to enable them to exercise a possible remedy?

- Are the risks of discriminations that may result from the use of the system identified and have the necessary means been put in place to avoid their occurrence?

- Is the organisation structured in such a way as to prevent risks by design (whether as regards non-discrimination, data protection, copyright protection, computer security, etc.)?

Depending on the size of the organisations and the way they are structured, it is not always possible to set up an ethics committee. Nevertheless, it is essential that such reflections can be carried out to support the development of AI systems. The appointment of an 'ethics adviser' may be an alternative which allows these questions to be taken into account.

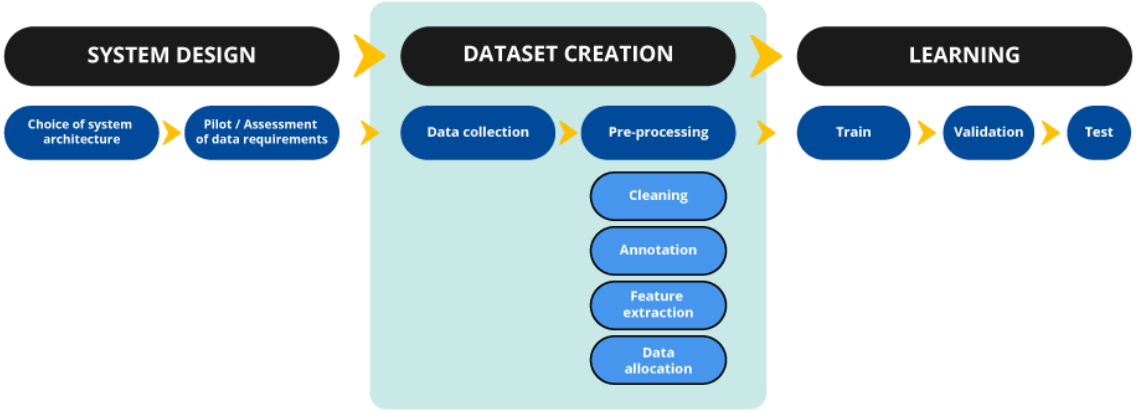
7. Taking data protection into account in data collection and management

02 July 2024

The development of an artificial intelligence system requires rigorous management and monitoring of training data. The CNIL details how data protection principles relate to training data management.

This content is a courtesy translation of the original publication in French. In the event of any inconsistencies between the French version and this English translation, please note that the French version shall prevail.

Once the data and its sources are identified, the AI system provider must implement the collection and create its dataset. To this end, it is necessary **to incorporate the principles of privacy by design from.**



Collection

The collection of data is accompanied by various checks and procedures depending on the modalities and sources of data. Technically, the aim is to ensure that the data collected is relevant in view of the objectives pursued, and thus to ensure compliance with the principle of minimisation.

Collection of data by web scraping

If the data controller re-uses publicly accessible data extracted from websites with web scraping tools, it must in particular ensure that the data collection is minimised, in particular by trying to:

- limit data collection to freely accessible data;
- define, prior to the implementation, precise collection criteria;
- ensure collection of relevant data only and deletion of irrelevant data immediately after its collection or as soon as it is identified as such (when this identification is not possible at the time of the collection).

Data cleaning, data identification and privacy by design

Data cleaning

Data cleaning helps in creating a quality training dataset. This is a crucial step that strengthens data integrity and relevance by reducing inconsistencies, as well as the cost of training. Specifically, it consists in:

- correcting empty values;
- detecting outliers;
- correcting errors;
- eliminating duplicates;
- deleting unnecessary fields;
- etc.

Identification of relevant data

The selection of relevant data and characteristics is a classic procedure in the field of AI. It aims to optimise the performance of the system while

avoiding under- and over-fitting. In practice, it ensures that certain classes that are unnecessary for the task are not represented, that the proportions between the different classes are well balanced, etc. This procedure also aims to identify data that is not relevant for training. Data identified as irrelevant will then have to be deleted from the dataset.

In practice, this selection can be applied to three types of objects constituting the dataset:

- **The data:** these may be 'raw', unstructured data (audio extract, image, handwritten text file, etc.) or structured (measures, observations, etc. in digital format);

- **The associated metadata:** literally "data on data", metadata provide information about the collection process (what was the acquisition process? by whom was it carried out? when? etc.), the format of the data (how should they be exploited?) or its quality;

- **The annotations and characteristics extracted from the data (or features):** descriptions attributed to the data in the case of annotations, or measurable properties extracted from the data for the characteristics (information relating to the shape or texture of an image, the pitch of sounds, the timbre or tempo of an audio file, etc.).

Several approaches can contribute to the implementation of this selection. The following is illustrative:

- The use of techniques and tools to identify the relevant characteristics (feature selection), sometimes prior to training. Principal Component Analysis (PCA) can also help identifying highly correlated characteristics of a dataset and thus retaining only those that are relevant. Many libraries such as Yellowbrick, Leave One Feature Out (LOFO) and Facets today offer implementations for selecting features.

- The use **of interactive data annotation approaches** such as active learning, which allows the user to review data performing the intended task and, where appropriate, to delete those that are not relevant. The Scikit-ActiveML library is an example of this.

- The use of data/dataset pruning techniques: this technique, discussed in several publications such as Sorscher et al., 2022 or Yang et al., 2023, reduces the computation time required for training without significant impact on the performance of the model obtained, while identifying data that is not useful for training.

Finally, in certain specific cases where the storage of data may be complex or problematic (due to the sensitivity of the data, issues related to

intellectual property, etc.), the principle of minimisation can be implemented by the exclusive storage of the extracted characteristics and the deletion of the source data from which they originate.

Example: For a study of the spread of hate speech in social networks, the analysis of comments associated with a post allows a classification of user reactions, but the content of the comments itself could be removed after this analysis.

Building a training dataset for AI also often **requires data annotations**. The production and use of such data must also be subject to special data protection measures. These will be detailed in a dedicated how-to sheet.

Privacy by design

Furthermore, in addition to these necessary steps, the provider of the AI system must implement **a series of measures to integrate the principles of privacy by design.**

They must take into account the state of knowledge, their impact on the effectiveness of the training, the costs of implementation and the nature, scope, context and purposes of the processing, and the risks (of which the likelihood and severity vary) of the processing for the rights and freedoms of individuals. These measures may include:

- **Generalisation measures:** those measures are intended to generalise, or dilute, the attributes of the persons concerned by changing their respective scale or order of magnitude;

- **Randomisation measures:** these measures aim to add noise to the data in order to decrease its accuracy and weaken the link between the data and the individual.

These measures must be implemented on the data and the associated metadata.

In some cases, these measures may extend to the anonymisation of the data, in particular if the purpose does not require the processing of personal data. If data selection and management qualify as processing of personal data subject to the GDPR (and thus to these how-to sheets), further processing will no longer be affected by the regulations on the protection of personal data.

Example: An organisation wishes to build a dataset of computer code relating to industrial machines (supervisory control and data acquisition, or

SCADA) from repositories of several developers. After removing any mention of the developers themselves, and then verifying the absence of identifiers or personal mentions in the comments, the dataset does not contain any personal data. It is no longer subject to data protection regulations.

For more information on these measures, see Opinion 05/2014 on G29 anonymisation techniques.

In addition, some measures, such as **differential privacy** or **federated learning**, protect data when training the AI system,. Although some of these techniques are still at the research stage, tools can be used to test their effectiveness, such as PyDP or OpenDP.

For Data

The measures depend on the categories of data concerned and must be considered in terms of their influence on the technical – theoretical and operational – performance of the system. The impact of these measures is particularly beneficial due to:

- on the one hand, their ability to reduce the consequences of a possible privacy leakage (by compromising the data contained in the dataset, or by an attack on the trained model such as a membership inference attack);

- on the other hand, the possibility of using the model in the operational phase on data subject to the same protection measures, thus offering the ability to better protect them in the operational phase.

Example: By generalising patient age information as part of the development of a diagnostic AI system, in the fields [month-year] or [year] instead of [day-month-year], the provider drastically reduces the risk of privacy leakage, without prejudice to the generalisation capacity of its system.

For metadata

Metadata may contain information that is useful to an attacker seeking to re-identify the data subjects (such as a date or place of data collection). The principle of minimisation also applies to such data and should therefore be limited to what is necessary.

For example, metadata may be required by the provider to respond to a request for the exercise of rights, as it sometimes identifies data relating to an individual. In this case, special attention should be paid to their safety.

However, if the processing of metadata is not necessary and it contains personal data, its deletion may be recommended for the purpose of pseudonymisation or anonymisation of the dataset.

For example: in the event that they reuse video protection images to constitute a training dataset, a provider that generalises the location of an image from an address to an IRIS (Ilots Regroupés pour l'Information Statistique) level may no longer be able to respond to a request for access to the data.

Monitoring and updating

Although data minimisation and data protection measures have been implemented during data collection, these measures may become obsolete over time. The data collected could lose their exact, relevant, adequate and limited character, in particular because of:

- **a possible data drift** under real conditions, that is, a discrepancy between the distribution of training data and the distribution of data under conditions of use. Data drift can have multiple causes:
    - upstream process changes, such as the replacement of a sensor, the calibration of which differs slightly from that previously installed;
    - data quality problems, e.g. a broken sensor that would always indicate a zero value;
    - the natural drift of the data, such as the variation in average temperature over the seasons;
    - the appearance of a new category in a classification problem;
    - drift due to sudden changes, such as the loss of a system's ability to detect faces following the massive wearing of masks during the Covid-19 outbreak;
    - changes in the relationship between characteristics;
    - malicious poisoning as part of continuous learning, which can for example be noticed by abnormal outcomes.

Tools exist to detect the occurrence of data drift, such as Evidently, or the Scipy Library whose statistical testing functions can be used for this purpose;

- **an update of the data**, such as a correction of the place of residence in the public profile of the user of a social network following a move;

- **the evolution of techniques,** which frequently demonstrates that a change of approach (use of a different AI system requiring a different data typology, for example) can bring better performance to the system, or that similar performance can be achieved with a smaller volume of data (as shown by the technique of few-shots learning, for example).

Thus, the system provider should conduct regular analysis to monitor the dataset. This analysis will be more extensive and frequent in situations where the above-mentioned causes are most likely to take place. This analysis should be based on:

- **a regular comparison** of data or a sample of data to source data, which can be automated;

- **a regular review** of data by staff trained in data protection matters, or by an ethics committee, responsible in particular for verifying that the data is still relevant and adequate for the purpose of the processing;

- **a watch** on the scientific literature in the field and making it possible to identify the emergence of new, more data frugal, techniques.

Data storage

The principle

Personal data cannot be stored indefinitely. The GDPR requires a period of time after which data must be deleted, or in some cases archived. This retention period must be determined by the controller according to the purpose which led to the collection of such data.

In practice

The provider must set a retention period for the data used for the development of the AI system, in accordance with the principle of storage limitation (Article 5.1.d GDPR).

Defining a retention period requires, in particular, the implementation of certain procedures described in the CNIL's practical guide on retention periods. The CNIL notes that open source datasets are constantly evolving (by improving annotation, adding new data, purging poor quality data, etc.): a storage period of several years from the date of collection must be justified.

Set a retention period for the development phase

First, the provider of the AI system will have to set a data retention period for the use made during the development of the system. During this phase, the provider processes the data for:

- the creation of the dataset, which should be limited to strictly necessary, cleaned, pre-processed and ready to be used data for training;

- the training phase, from the first training of the AI model to the test phase to determine the characteristics and performance of the finished product. During this phase, the data must be kept securely and accessible to authorized persons only. Depending on the case, this phase can last from a few weeks to several months, or on the contrary iteratively in the case of continuous learning. This duration should be defined upstream and justified (taking into account the previous experiences of the controller, the knowledge of the duration of IT developments, the human and material resources available to carry them out, etc.).

Data storage needs to be planned upstream and monitored over time. The defined retention periods must also be applied to all concerned data, regardless of their storage medium. Compliance with retention periods can sometimes be facilitated by the use of management and governance tools to define a retentionstorage period for each data and calculate the length of time that has elapsed since the date of entry into the dataset before automatically deleting them. Particular attention must therefore be paid to the traceability of any data extracted from the main dataset and stored on third-party media, for example to enable the engineers to analyse a sample on a case-by-case basis. The measures recommended in the "Documentation" section for data traceability will facilitate the tracking of data and the expected date for deletion.

Please note:

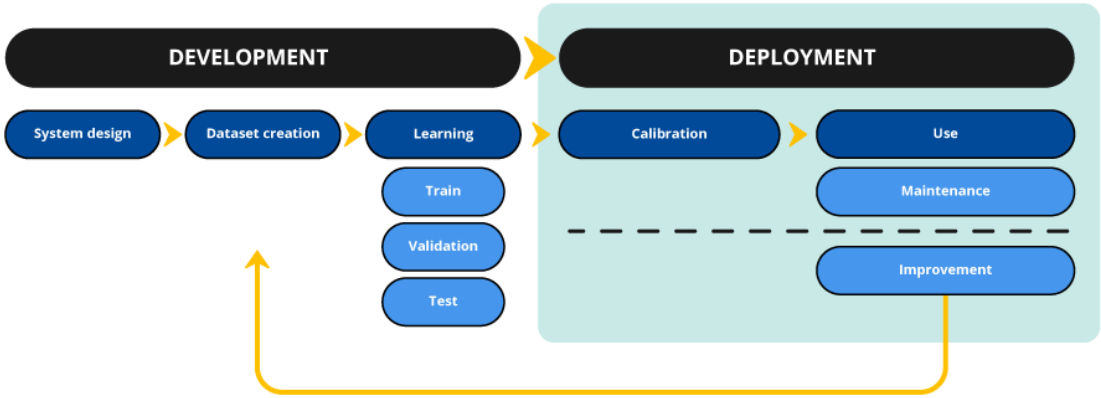
In the case of public bodies or private bodies entrusted with a public service mission, data may also be subject to specific archiving in compliance with the obligations of the French *Code du Patrimoine*.

This allows the data to be permanently stored in a public archive service according to the particular interest they present. Where the public archives contain personal data, a selection shall be made to determine the data to be retained and those, which are not administratively useful or of scientific, statistical or historical interest, to be deleted.

In any event, the data retained in the context of the definitive archiving are subject to processing for archival purposes within the meaning of the GDPR and, therefore, do not fall within the scope of these how-to sheets. In addition, the data storage period must be specified in the information notice that will be brought to the attention of the data subjects.

Set a retention period for the maintenance or improvement of the product

When the data no longer have to be accessible for the day-to-day tasks related to the development of the AI system, it should in principle be deleted. However, it can be kept for product maintenance (i.e. for a later phase of performance verification or for system improvement).



Maintenance operations

The principle of data minimisation requires keeping only the data strictly necessary for maintenance operations (by selecting the relevant data, performing pseudonymisation of the data where possible, such as blurring images for example, etc.).

These operations ensure the safety of those affected by the use of the AI system in the deployment phase, such as when the system has an effect on

people, when a drop in performance could have serious consequences for people, or when it concerns the safety of a product. Thus, **the storage of training data can allow audits to be carried out and facilitate the measurement of certain biases**. In these cases, and where a similar result could not be achieved through the storage of general data information (such as documentation on the model proposed in the documentation section, or information on the statistical distribution of the data), prolonged data retention may be justified. However, this storage must be limited to the necessary data and should be accompanied by enhanced security measures.

Once the data has been sorted, it can be stored on a partitioned medium, i.e. physically or logically separated from the training data. This partitioning makes it possible to strengthen the security of the data and restrict its access to authorized personal only. The duration of the maintenance phase can vary from a few months to several years when the storage of this data carries little risk to people and the appropriate measures have been taken. In the case of data from open sources, the retention period provided by the data source shall be taken into account in determining the duration of the maintenance phase. However, this period must be limited and justified by a real need.

Improving the AI system

The data of the previously created dataset may also be required to improve the product resulting from the AI system thus developed. This purpose, for which a legal basis must be identified, must be brought to the attention of the data subjects, in accordance with the principle of transparency.

Specifically, only the data needed to improve the AI system can be extracted from their partitioned storage space.

Please note:

The possibility of extending the cycle by a new development or maintenance phase will not, under any circumstances, allow an indefinite extension of the retention period. An analysis of the duration necessary for the processing operations must be carried out systematically.

Security

The principle

The controller and its processors (if any) must implement appropriate technical and organisational measures to ensure a level of security appropriate to the risks (Article 32 GDPR).

The choice of measures to be implemented must take into account the state of knowledge, the costs of implementation and the nature, scope, context and purposes of the processing and the risks, the likelihood and severity of which vary, for the rights and freedoms of data subjects.

In practice

Thus, the provider of an AI system must, in particular, put into place the appropriate measures in order to secure:

- **the techniques used for data collection** , e.g. through encryption and robust authentication methods. It is recommended to use the means provided by the diffuser to collect data, especially when it is based on APIs. The CNIL's recommendation on the use of APIs will then have to be applied;

- **the collected data**, using methods of encryption of backups, verification of their integrity, or logging of operations carried out on the dataset in accordance with the CNIL recommendation on logging measures. A frequent risk in the development of AI systems concerns duplication of data, the quality of which should be frequently analysed . Duplication of data should be limited to the extent possible and traced where unavoidable. Dedicated tools, such as NB Defense, Octopii, PiiCatcher, or techniques, such as regular expression (RegExp) search or named entity recognition for textual data, make it possible to verify the presence of personal data in certain contexts;

- **the IT system used for the development of the AI system, e.g. by means** of authentication methods and the training of staff with access to it, and the implementation of good IT hygiene practices;

- **the IT hardware,** in particular by means of methods of restricting access to premises and by analysing the guarantees provided by the data host when this is outsourced to a provider.

Security measures specific to the development and deployment phases of AI systems will be the subject of a subsequent how-to sheet. However, the recommendations and best practices traditionally implemented in IT, such as those present on the CNIL's website, as well as the GDPR guides of the

development and security team of personal data, constitute a useful reference to which the provider of the AI system can refer.

Documentation

The documentation of the data used for the development of an AI system helps ensurings the traceability requirement. It must make it possible to:

- facilitate the use of the dataset;
- demonstrate that the data were lawfully collected;
- facilitate the monitoring of data over time until it is deleted or anonymised;
- reduce the risk of unanticipated use of data;
- enable the exercise of rights for data subjects;
- identify planned or possible improvements.

In order to meet these objectives, a documentation model may be adopted, in particular where the provider uses multiple data sources or creates multiple datasets. Building on the existing models (such as those proposed by Gebru et al., 2021, Arnold et al., 2019, Bender et al., 2018, the Dataset Nutrition Label, or the technical documentation provided for in Annex IV of the AI Act), the CNIL provides below a model that can be used for this purpose, in particular where the dataset is intended to be shared. This documentation should be carried out for each dataset constituted, made available, or based on existing datasets to which a substantial changes were made. More specific documentation templates for each use case, such as the CrowdWorkSheets model, which is particularly relevant for documenting the annotation phase, may complement the proposed template.

The objectives of this documentation are to help the controller clarify its practices, to inform the users of the dataset about the conditions of its constitution and the recommendations concerning its processing, and finally, to inform people about this processing. Thus, it is recommended that this documentation be provided to users of the dataset or models it has been used to design.

It should be noted that this important documentation work can naturally feed into the data protection impact assessment (see how-to sheet 5 Carrying out an impact assessment if necessary).

8. Relying on the legal basis of legitimate interests to develop an AI system

05 January 2026

Controllers will most commonly rely on their legitimate interests for the development of AI systems. However, it may only be used if its conditions are fulfilled and sufficient safeguards are in place.

This content is a courtesy translation of the original publication in French. In the event of any inconsistencies between the French version and this English translation, please note that the French version shall prevail.

Legitimate interest is one of the six legal bases provided for in Article 6 of the GDPR.

It is often adapted for the development of AI systems by private bodies, espacially when the dataset used is not based on the consent of individuals (it is often difficult to obtain the consent of individuals at a large scale or when personal data are collected indirectly).

With regard to public bodies, they may rely on their legitimate interests when a public authority wishes to develop an AI system only when the activities concerned are not strictly necessary for the performance of its specific tasks but for other activities legally implemented (such as, for example, human resources management processing).

For more information on the use of legitimate interest by a public body, see in particular the use case illustrated in "How to choose the legal basis for processing? Practical cases with certain treatments implemented by the CNIL" (French version)

Reliance on legitimate interests is, however, subject to three conditions:

- The interest pursued by the body must be “legitimate”;
- The processing must fulfill the condition of “necessity”;
- The processing must not disproportionately affect the rights and interests of the data subjects, taking into account their reasonable expectations. It is therefore necessary to “balance” the rights and interests at stake in the light of the specific conditions for its implementation.

The controller is bound to examine the compliance of its processing with these three conditions. To this end, it is recommended, as a good practice, to document it. In any event, where a DPIA is necessary, the safeguards provided to limit the possible impacts on the rights of individuals must be described by the controller (see the how-to sheet “Carrying out a data protection impact assessment when necessary”).

Other legal bases may also be considered for the development of AI systems (see the how-to sheet “Ensuring the lawfulness of the data processing - Defining a legal basis”).

First condition: the interests pursued must be “legitimate”

The interest pursued, although closely linked to the purpose of the processing, should not be confused with it. The purpose is the specific reason for which the data are processed, whereas the interest refers to the broader benefit that the data controller or a third party may seek to obtain.

For more information on defining the purpose during the development phase : see the how-to sheet 2

Legitimate interests can be broadly defined. There is no exhaustive list of interests considered legitimate, but the interests pursued may be presumed as legitimate if they are cumulatively:

- manifestly lawful under the law,
- determined in a sufficiently clear and precise manner,
- and real and present (i.e., not hypothetical or speculative) for the organization concerned.

Thus, in the case of AI system development, the following interests could be considered a priori legitimate:

- carrying out scientific research (espacially for organizations which cannot rely on a task carried out in the public interest);
- facilitating public access to certain information ;
- developing new systems and features for users ;
- offering a chatbot service to assist users ;
- improve a product or service to increase its performance ;
- develop an AI system to detect fraudulent content or behavior.

A commercial interest constitutes a legitimate interest, provided that it is not contrary to the law and that the processing is necessary and proportionate (CJUE, 4 october 2024, Tennisbond, C-621/22). **By contrast, certain interests cannot be considered legitimate**, particularly when the envisaged AI system has no connection to the organization's mission and activities, or if it cannot be legally deployed.

Example: targeted advertising based on profiling to minors is prohibited by Article 28.2 of the Digital Services Act (DSA). An AI system intended to carry out automatic profiling of minors with a view to targeting them with advertising cannot therefore be legally deployed. The interest in developing such a system cannot therefore be regarded as lawful.

Please note: more generally, the development of systems that are categorically prohibited by regulations other than the GDPR cannot be considered legitimate. In this regard, particular attention should be paid to the to the AI-specific categorisation used in the European AI Act. It provides for on the prohibition of placing on the market, putting into service or using certain AI systems. The development of systems that are exclusively intended for such uses cannot, therefore, be considered lawful, and it will not be possible to rely on legitimate interests or any other legal basis to carry out the processing. It will be up to the controller to comply with the applicable regulation and keep up to date with future developments.

The interest pursued must be sufficiently precise and brought to the attention of individuals as part of the data controller's transparency obligations. Thus, with regard to the development and improvement of a general-purpose AI system, even when the specific use of the model is not known, it is recommended to refer to the objective pursued by the development of the model (indicating in particular whether it is commercial, public, scientific research, and whether it is internal or external to the organization).

In some cases, **the consent of the individual may be required under other regulations**. This may be the case, for example, where the controller is also a gatekeeper within the meaning of the Digital Markets Act (DMA) and the processing for the creation of the training database involves

implementing one of the practices listed in Article 5.2 of the DMA (cross-use of personal data from the essential platform service in the context of other services provided by the access controller, for example).

Second condition: the processing must be "necessary"

The condition of necessity means that the controller must ensure that the intended processing is capable**of achieving the interest pursued** and that **there is no other less intrusive way** of achieving that objective than to carry out the intended processing.

As such, if the development of the AI system requires **the use of personal data, the controller must ensure, with regards to the information at his disposal, that the development of that system is indeed necessary to achieve its objective, whether it is a research objective, a commercial objective**, an objective of fraud prevention, etc. If the development of the system does not require the processing of personal data, the GDPR is not applicable to that development and the question does not arise.

This condition relating to the necessity of the processing is also to be examined in connection with the principle of data minimization (see the how-to sheet 6 « Taking into account data protection when designing the system »). This means, in particular, that the data controller must ensure that it is necessary to process personal data or to store it in a form that allows direct or indirect identification of individuals, as well as the need to use, where appropriate, a technical solution that involves processing a large volume of personal data. In this regard, technological developments should be taken into account, as they may enable the development of models that require less personal data to be processed. Data controllers are encouraged to participate in the development of such technologies.

Third condition: ensure that the objective pursued does not threaten the rights and freedoms of individuals

It is necessary **to ensure that the legitimate interests pursued do not disproportionately affect the interests, rights, and freedoms of the individuals concerned.**

The controller must therefore balance their legitimate interests against the data subject's interests, rights, and freedoms. To do this, the controller must measure the benefits of its processing (anticipated benefits, including those presented below) but also the impacts on individuals. If necessary, **additional measures must be put in place** to limit these risks and protect the rights and freedoms of individuals.

This analysis must be carried out on a case-by-case basis, taking into account the specific circumstances of the processing.

The benefits provided by the AI system help justify the processing of personal data

The greater the anticipated benefits of the processing, the more likely the legitimate interest of the controller is to prevail over the rights and freedoms of individuals.

The following factors make it possible to measure the positive impact of the interests pursued :

- **The extent and nature of the expected benefits of the processing, for the controller but also for third parties**, such as the end-users of the AI system or **the interest of the public or society**. The diversity of applications implementing AI systems shows that there can be many benefits, such as improved healthcare, better accessibility of certain essential services, facilitation of the exercise of fundamental rights such as access to information, freedom of expression, access to education, etc.

  Example: a voice recognition system that allows users to automatically transcribe their words and, for example, helps with filling in administrative forms, can have significant benefits in making certain services accessible to people with disabilities. The importance of those benefits may be taken into account in the balancing of interests when developing such a system.

  In general, the fact that a data controller acts not only in their own interest but also in the interest of the wider community may give more « weight » to that interest.

Example: a private company wants to develop an AI system to fight against online real estate fraud. The commercial interest it pursues is reinforced by the convergence with the interest of users and the interest of the community to reduce fraudulent activities.

- **The usefulness of the processing carried out in order to comply with other legislation.**

  Example: the provider of a very large online platform or search engine that develops an AI system to better meet the provisions of Article 35.1 of the Digital Services Act (DSA) on the adaptation of online content moderation processes, may take this objective into account when assessing its interest.

- **The development of open-source model**, which, provided sufficient safeguards are in place (see the dedicated article in French) may have significant benefits for the scientific community, research, education and the adoption of these tools by the public. It may present benefits in terms of transparency, reduction of bias, accountability of the AI system provider or peer review. This may reflect the controller's objective of sharing the benefits of its processing to participate in the development of scientific research.

- **The specification of the interests pursued** : the more precisely an interest is defined, the more weight it will be have in the balancing exercise, since it makes it possible to specifically apprehend the reality of the benefits to be taken into account. Conversely, an interest defined too broadly (e.g. "providing new services to its users") is less likely to prevail over the interests of individuals.

Negative impacts on people need to be identified

Those benefits must be balanced against the impact of the processing on data subjects. Specifically, the controller must identify and assess the consequences of all kinds, potential or actual, that the development of the AI system and its subsequent use could have on the persons concerned: their privacy, data protection and other fundamental rights (freedom of expression, freedom of information, freedom of conscience, etc.) as well as other concrete impacts of the processing on their situation.

The actual impacts of the processing on people, as listed below, are to be assessed according to the likelihood that the risks materialise and the severity of the consequences, which depend on the particular conditions of the processing, as well as the AI system developed.

To this end, **it is necessary to take into account the nature of the data** (sensitive data, highly personal data), **the status of the data subjects** (vulnerable persons, minors, etc.), **the status of the company or administration developing and/or deploying the AI system** (the effects may be multiplied in the event of very wide use of AI), the way in which the data are processed (data combination, etc.) **or the nature of the AI system and the intended operational use**. In some cases, the impact on individuals will therefore be limited, either because the risks are low or because the consequences present little severity with regard to the data used, the processing carried out and the interest pursued (for example, the development of an AI system used for the personalisation of an auto-completion feature of a text editor software presents little risk for data subjects).

The following impacts on people should therefore be considered and the level of associated risks should be assessed in the case at hand. Three types of risks can be distinguished :

1. Impacts related to the development of the AI model

- **The risks related to the collection of publicly available online data**, especially through scraping tools, which may infringe on individuals' privacy and the rights guaranteed under the GDPR. Such practices may also impact other rights, including intellectual property rights, certain types of trade or professional secrecy, or freedom of expression — due to the surveillance-like effect that widespread and systematic data scraping can produce (for more information, see the focus sheet on web scraping).

- **Risks of loss of confidentiality of the data contained in the dataset or in the model**: the risks related to the security of training datasets are likely to increase the risks for data subjects linked to misuse, in particular in the event of a data breach, or the risks related to attacks specific to AI systems (attack by poisoning, backdoor insertion or model inversion).

  For more information: see the article « Small taxonomy of attacks on AI systems » (in French).

- **Risks related to the difficulty of ensuring the effectiveness of the data subject rights,** in particular due to technical obstacles to the identification of data subjects or difficulties in transmitting requests for the exercise of rights when the dataset or model is shared or available in open source. It is also complex, if not technically impossible, to guarantee data subject rights on certain objects such as trained models.

- **Risks associated with the difficulty of ensuring transparency towards data subjects**: these risks may result from the technicity inherent to these topics, rapid technological developments, and the structural opacity of the development of certain AI systems (e.g. deep learning). This complicates the availability of intelligible and accessible information on the processing.

2. Impacts on persons related to the use of the AI system

Certain risks, which may arise when using the AI system, must be taken into account at the training stage because of their systemic nature. It is indeed necessary to anticipate, as soon as the design phase, the guarantees necessary to effectively limit these risks. These risks depend on the uses of the AI system. As a general matter, the following risks can be mentioned in particular :

- **There are risks of memorization, extraction, or regurgitation of personal data (particularly in the case of generative AI systems) during the use of certain AI models, potentially infringing on privacy.** In some instances, personal data contained in training datasets can be inferred—whether accidentally or through attacks (e.g. membership inference, data extraction, or model inversion) from the use of AI systems (see notably the LINC article « Small Taxonomy of Attacks on AI Systems »). This creates privacy risks for individuals whose data may resurface through the system's use (e.g., reputational damage, security risks depending on the nature of the retained data, etc.).

- **Risks of reputational damage, spread of false information or identity theft, where the AI system** (particularly generative AI) produces content on an identified or identifiable natural person (e.g. a generative image AI system may be used to generate false pornographic pictures of real persons whose images are contained in the dataset). Note that this risk can also occur with AI systems that have not been trained with personal data.

Example: a news article generated by an AI system may present defamatory information about a real person, although the dataset does not contain information about that person, in particular where the text was generated at the request of a user who specifies the identity of the data subject in the prompt.

- **Risks of infringement of certain rights or secrets provided for by law** (e.g. intellectual property rights, such as copyright, business or medical secrecy) in the event of memorisation or regurgitation of protected data.

  Example: a text-generative AI system trained on copyright-protected literary works may generate content that constitutes infringement, in particular where that content results from the regurgitation of the content that would have been memorised by the AI system.

- **Serious ethical risks, which may impact certain general legal principles or the proper functioning of society as a whole, related to the development of certain AI systems.** These risks must be taken into account in the assessment (e.g. discrimination, the safety of people in case of malicious use, incitement to hatred or violence, disinformation, which may undermine the rights and freedoms of individuals or democracy and the rule of law). The development of AI systems can thus harm certain fundamental rights and freedoms during the deployment phase if safeguards are not anticipated by design (e.g. amplification of discriminatory biases in the training database, lack of transparency or explainability, lack of robustness or automation biases, etc.).

Taking into account the IA Act :

When the data controller is a provider of high-risk AI systems within the meaning of Article 6 of the AI Act, they may usefully take into account the identified risks as part of the risk management system they are required to implement under Article 9 of the AI Act. Likewise, when acting as a provider of a general-purpose AI model presenting systemic risks within the meaning of Article 51 of the AI Act, they may consider the identified risks in fulfilling their obligations under Article 55 of the AI Act.

Reasonable expectations of individuals are a key factor in assessing the legitimacy of treatment.

The controller must take into account the **reasonable expectations of the data subjects when assessing the impact of the processing on individuals.** Relying on legtimate interests requires that individuals are not surprised by the modalities as well as the consequences of the processing.

Reasonable expectations are a contextual aspect that the controller must consider when balancing the rights and interests at stake. To this end, information to individuals may be taken into account to assess whether data subjects can reasonably expect their data to be processed. However, it will only be an indicator.

During the development of an AI system, some data processing operations may exceed the reasonable expectations of data subjects. The controller must conduct this assessment, taking into account notably the following set of indicators :

- **For data collected directly from data subjects :**
    - The relationship between the controller and the data subject.
    - The privacy settings of the data shared by the data subject.

      Examples: A platform that provides an online coaching service wants to use the exchanges between individuals and their interlocutors to fine-tune a generative AI model in order to develop a chatbot capable of answering users' questions. In this case, people who communicate with their online interlocutors expect a certain level of confidentiality, particularly given the sensitivity of the information that may be shared, and cannot reasonably expect the data to be used for training purposes. It will therefore be necessary to obtain their consent.
    - The use of private exchanges between two people using an online virtual meeting service for the development or improvement of an AI model for summarizing meetings does not fall within the reasonable expectations of individuals.
    - The context and nature of the service where the data was collected (e.g., whether the service was provided through an AI system);
    - Whether the processing of user data only affects the service provided to the user in question or whether it is used to improve the service as marketed (e.g., if a company collects data from its customers in order to develop a tool for its sole use but which is not otherwise marketed).

- **When reusing online accessible data:** in light of the recent technological development (big data, new AI technologies, etc.), data subjects may be aware that the information they share online might be accessed, collected, and reused by third parties. However, they cannot expect such processing to take place in all situations and for all types of publicly accessible data about them. Several factors must be taken into account, including :
    - the publicly accessible nature of the data ;
    - the context and nature of the source websites (e.g., social networks, online forums, dataset repositories)
    - the restrictions set by these websites, such as in their terms of us or through technical safeguards like exclusion files (e.g., robots.txt) or blocking mechanisms like CAPTCHAs. In this regard, the CNIL considers that processing cannot fall within the reasonable expectations of data subjects if the controller does not exclude from collection websites that explicitly object to scraping via robots.txt or CAPTCHAs

      Example: Where an individual uploads their data to a content-sharing platform that explicitly prohibits scraping via robots.txt files and clearly indicates that user data will not be used for the development of AI models, it is not reasonable to expect that third parties would collect such data for that purpose.
    - the type of publication (for example, an article published on a freely accessible blog is not private, whereas a post on a social network published with access restrictions may remain private, since the internet user less aware of the risk of it being collected and reused by third parties).
    - the nature of the relationship between the data subject and the controller.
- **It may be difficult to fully anticipate the wide range of potential uses of a dataset or model, particularly when it is shared or disseminated.**

  Yet, some of these uses may fall outside the reasonable expectations of data subjects, especially in the case of unlawful reuse, since a person cannot reasonably expect their data to be used to develop AI systems that are later reused for other purposes.

  Example: data subjects could not expect their data to be used to

develop an open-source image classification model, which would then be used to classify people based on their sexual orientation.

Example of processing that may fall within the reasonable expectations of individuals :

A chatbot provider wishes to reuse future user conversations with the AI system to improve the AI model. It informs data subjects specifically of the risks associated with this reuse, including, where applicable, the risks of memorization, by alerting them to the risks associated with the collection of sensitive data, and allows them to object to the processing in advance and at their discretion, as well as at any time thereafter, without this affecting their use of the service. It also only collects the data subject'conversations, excluding any other personal data, ensures that the data collected is strongly pseudonymized, and ensures that the risks of memorization and regurgitation are limited. In this case, the processing may be considered to be within the reasonable expectations of individuals. In this case, the processing may be based on legitimate interest, provided that the balancing test is met.

Additional measures to limit the impact of processing

The organization may put in place **compensatory or additional measures in order to limit the impact of processing on data subjects.** These measures will often be necessary to reach a balance between the rights and interests at stake and will allow the controller to rely on this legal basis.

These measures are in addition to those necessary to comply with other obligations laid down by the GDPR, and should not be confused with them: compliance with these provisions is imperative, regardless of the legal basis for the processing (data minimization, data protection by design and by default, data security, etc., see the dedicated practical how-to sheets). Compensatory measures consist of additional safeguards to the other requirements of the GDPR.

The measures may be technical, organizational, or legal and must be able to limit the risk of harm to the interests, rights, and freedoms previously identified.

The following measures have been identified as relevant to limit the impact on data subject rights and freedoms. They must be adapted to the risks posed by the different processing of the development phase.

For more details on the measures to be taken in the event of web scraping, see the dedicated focus sheet.

1. Measures to limit the collection or storage of personal data

- **Provide for the anonymization of collected data within a short period of time or, failing that, the pseudonymization of collected data.** In some cases, anonymization of data will be necessary when anonymous data is sufficient to achieve the objectives defined by the controller.

  Example: if a company wants to build a dataset from comments accessible online to develop an AI system to assess the satisfaction of customers who have purchased its products, pseudonymisation of data collected at short notice after collection may be an additional measure to limit the risks associated with data collection that may reveal a lot of information about the person making the comments.

- **Where it does not adversely affect the performance of the model developed, synthetic data should be used**. This may also have a number of advantages, such as making certain data available or accessible and modelling certain specific situations, avoiding the use of real data, particularly sensitive data, increasing the volume of data for training or minimising the risks associated with data confidentiality, etc. It should be borne in mind that synthetic data are not systematically anonymous.

  Example: if a supplier wishes to develop an image classification system that automatically detects the carrying or use of a weapon, the use of computer-generated images allows, for example, to avoid the collection of data likely to presume the commission of an offence, to help varying the possible configurations or to improve the representativeness of the dataset, in particular because of the possibility of describing the characteristics of the synthetic image of the person (size, weight, skin colour, etc.) and of the weapon to be detected (shape, colour, etc.).

- **Put in place measures to limit the risks of memorization, extraction, and regurgitation in generative AI, or attacks on AI models or systems.** Without prejudice to technological developments that may lead to other measures, the CNIL recommends implementing the following measures :
  - Measures to limit the risks of memorization:

        - The deletion of rare or outlier data;
        - The deduplication of training data;
        - The reduction of the ratio of the number of model parameters to the volume of training data ;
        - The explicit regularisation of the cost function;
        - Using algorithms that provide formal guarantees of confidentiality for adjustment (for example, in terms of differential privacy);
        - Any measures aimed at limiting overfitting ;
    - Measures limiting the risks of extraction or regurgitation, in the context of generative AI, or attack :
        - Measures that limit likelihood :
            - Restrictions of access to the model;
            - Modifications to the model's outputs (such as filters, for example, or limitations on output accuracy) ;
            - Security measures aimed at preventing or detecting attack attempts (which may, however, be required under other GDPR obligations) ;
        - Measures to limit severity :
            - Provide for legal or technical recourse in the event of extraction, regurgitation in the context of generative AI, or a successful attack, such as opening a help desk with the provider where individuals can report regurgitation.

In certain cases, the implementation of these measures may lead the controller to conclude that it is impossible to extract personal data or regurgitate it, in the context of generative AI, and therefore that the model or system developed is anonymous (see the AI how-to sheet on the status of an AI model with regard to the RGPD). The anonymity of the model or system will constitute a particularly strong guarantee to limit the harm to individuals whose data is processed for training the AI model.

If the data controller is unable to conclude that the model or system developed is anonymous, these measures will still constitute additional guarantees.

2. Measures enabling individuals to retain control over their data

- **Implement technical, legal and organisational measures in addition to the obligations laid down in the GDPR in order to facilitate the exercise of rights :**

- **Provide for a discretionary and prior right of objection in order to strengthen data subjcts' control over their data.**
    - Exercising this right could be made easier by informing the data subject on the controller's website, and providing for a simple checkbox that's easy to find. For example, users of an online service whose data is used for the development or improvement of an AI system should be able to quickly access the page allowing them to object to the collection of their data for this purpose. The controller must ensure that the individual can object to this processing without their use of the service being affected;

    - In the case of online data collection, the CNIL encourages the development of technical solutions that facilitate compliance with the right to object prior to data collection. In addition to the opt-out mechanisms put in place for intellectual property (see the focus sheet on web scraping), "rejection list" mechanisms could, for example, be implemented when appropriate for the processing. This would enable the data controller to respect individuals' objections by refraining from collecting their data;
- **Include a discretionary data deletion right for information** stored in the database ;

- **Implement measures to enable or facilitate the identification of data subjects**: Technical and organizational measures should be considered to retain certain metadata or other information about the source of data collection, in order to facilitate the retrieval of a person or a specific piece of data within the database. This will be particularly relevant when the information is publicly accessible and its retention does not pose additional risks to the individuals concerned.

  Example: In the case of an image dataset created through web scraping of freely accessible online data from a limited number of websites, retaining the display name and URL source of each collected image would help facilitate the identification of individuals. Indeed, individuals could directly provide the relevant URLs by locating the data concerning them via a general search engine, or through a specific website or web archive library.

- **Implement measures to ensure and facilitate the exercise of data subjects' rights when the model is subject to the GDPR** (see how-to sheet on the status of AI models and AI systems) such as observing a reasonable delay between the dissemination or collection of a training dataset and its use (particularly when exercising rights on the model is difficult), and/or planning for periodic model retraining to allow for the effective consideration of data subjects' rights when the data controller still holds the training data.

  For more details on the steps to take to exercise your rights, see the how-to sheet 10 "Ensuring and facilitating the exercise of data subjects' rights".

- When the model open source, **identify and implement measures to ensure that rights are exercised throughout the chain of actors**, in particular by including in the terms and conditions the obligation to extend the effects of the exercise of the rights of opposition, rectification, or erasure to systems developed subsequently.

- **Facilitate the notification of rights:** for example, where possible, the CNIL recommends the use of application programming interfaces (APIs) (particularly in the most high-risk cases), or at the very least techniques for managing download logs.

- **Communicate more widely about dataset or model updates,** for example in the dataset documentation or on the providers' website, to let data subjects know to what extent their requests have been met. This also involves encouraging recipients of previous versions to delete them or replace them with the latest version.

- **Ensure increased transparency regarding the processing activities carried out for the development or improvement of the AI system**, in addition to the obligations set out in Articles 12 to 14 of the GDPR, by implementing the following measures:

  - **Provide information on the risks related to data extraction or regurgitation, in the context of generative AI**, when the AI model or system is subject to the GDPR:

    - the nature of the risk associated with data extraction from the model or system, such as the risk of data regurgitation

in the case of generative AI;

        - the measures taken to mitigate these risks, and the available recourse mechanisms should these risks arise, such as the possibility to report an instance of regurgitation or extraction to the organization.
    - **Provide for the publication of the Data Protection Impact Assessment** (DPIA), where applicable (this publication may be partial when certain sections are subject to protected secrets, such as trade secrets);

    - Provide for the publication of any documentation related to the dataset (for example, **based on the** model proposed by the CNIL), the development process, or the AI system and its functioning;

    - **Provide for the publication of information that supports greater public understanding of how these technologies work**: the CNIL considers that public acceptance of AI technologies cannot be achieved without such efforts. It therefore encourages stakeholders, both developers and users, to make an effort to be transparent and popularise their practices, as well as explain how AI work and its associated risks. This may be achieved by implementing recommended transparency practices in the field, such as:

        - embracing open-source development approaches (e.g., publishing model weights, source code).
        - promoting transparency around non-data-protection related aspects, such as :
            - fundamental concepts of machine learning, such as training, inference, memorization, and different types of attacks on AI systems ;
            - measures taken to mitigate malicious or harmful uses of the system ;
    - **Carry out media campaigns** to ensure the widest possible dissemination of information to individuals, particularly when the development involves large-scale data collection, such as with large language models (LLMs), and implement multiple alternative methods of informing data subjects.
- **Implement measures and procedures to ensure the transparent development of the AI system, in particular to enable its auditability during the deployment phase.** This includes a comprehensive documentation of the development process, activity logging, management and monitoring of the different versions

of the model, recording of parameters used, and performance and documentation of evaluations and tests. Such measures may also be essential to prevent automation or confirmation bias during the deployment.

3. Measures to mitigate risks during the operational phase

- **In the case of general-purpose AI systems, limit the risk of illicit reuse of the AI system by implementing technical measures** (e.g. digital watermarking of outputs to prevent deceptive uses, or restriction of functionalities by design to exclude those that could lead to illicit uses) **and/or legal measures** (e.g. contractual prohibition of certain illicit or unethical uses of the database or AI system, which data subjects could not reasonably expect).

- **Implement licenses restricting uses aimed at re-identifying individuals.**

- **Implement measures to address certain serious ethical risks.**

  For example, ensure the quality of the training dataset to limit the risk of discriminatory biases during the operational phase, notably by ensuring data representativeness and by verifying and correcting the presence of biases in the dataset or resulting from annotations performed (see how-to sheet 11 "Annotating Data").

4. Other measures

- **In view of the severity and likelihood of the identified risks, appoint an ethics committee or, depending on the size and resources of the organization, an ethics officer.** This ensures that ethical considerations and the protection of individuals' rights and freedoms are taken into account from the outset and throughout the development of such systems (for more information see how-to sheet 7 "Taking into account in data collection and management").

Examples

Example where legitimate interest cannot be relied upon :

A controller wishes to develop a generative AI system for images. He build the training dataset by indiscriminately collecting images online from numerous websites, without ensuring the exclusion of certain categories of sites, such as those containing sensitive data, like pornographic websites, and without implementing safeguards to limit the risks of data

memorization or extraction by the model. The purpose, as defined in the controller's privacy policy, is vaguely stated as « the provision of new services ». In such cases, it is unlikely that the balancing test could be considered as satisfied.

Examples where legitimate interest may be relied upon :

A social network offering an online forum, whose core purpose is to make exchanges between users freely accessible, wishes to develop a conversational agent to facilitate searches across user posts, notably by synthesizing search results to directly answer users' queries. To train the model, the platform collects only data that users have made freely and manifestly public, explicitly excluding private user data (such as private conversations or account information). Strong safeguards are implemented, including a discretionary and advance opt-out mechanism and enhanced transparency (e.g., a notice on the homepage linking directly to the opt-out option). In such a case, the balancing test will generally be considered as met.

Note: If this processing purpose was not initially communicated to users, a compatibility assessment under Article 6(4) of the GDPR must be conducted (see how-to sheet n° 4, part 2/2 for more details).

An organization aims to develop a generative AI system for text. It exclusively uses data from freely and publicly accessible online sources, where the data subjects have manifestly made the content public. It also excludes any content protected by copyright (i.e., using only content in the public domain or for which rights holders have not objected to text and data mining as permitted under Directive 2019/790 on copyright and related rights in the Digital Single Market). In addition, it implements a range of safeguards to limit data memorization and regurgitation, restricts problematic content generation through technical or contractual measures, facilitates the exercise of data subjects' rights when reidentification is possible, and clearly indicates data sources in a publicly available privacy policy. In such a case, the balancing test may generally be considered as met.

A retail company using a self-checkout equipped with an algorithmic videosurveillance system that automatically detects customer errors at checkout wishes to reuse the collected data to improve the AI system. To this end, it retains only data in a form that limits reidentification, ensures that customers are informed of the system's operation, and allows them to object freely and easily. In this case, the balancing test may generally be considered as met.

9. The legal basis of legitimate interest: focus sheet on the measures to implement in the case of data collection by web scraping

05 January 2026

The collection of data accessible online via web scraping must be accompanied by measures aimed at safeguarding the rights of the data subjects.

This content is a courtesy translation of the original publication in French. In the event of any inconsistencies between the French version and this English translation, please note that the French version shall prevail.

The collection of personal data available online through web scraping is generally based on legitimate interest. The controller must implement additional measures to mitigate the impact this may have on individuals' interests, rights, and freedoms.

Reminder on the doctrine of the CNIL

The scraping of publicly accessible online data has significantly expanded, particularly with the rapid and widespread growth of generative AI systems, which rely on vast amounts of freely accessible online data. However, there are inherent risks associated with the use of such techniques for data subjects' rights and freedoms, as individuals have little control over how their publicly available data is reused.

The widespread use of web scraping has fundamentally **changed the nature of internet use,** in that all data published online by an individual can now potentially be read, collected, and reused by third parties. This can pose significant risks for individuals, including the following:

- **Risks to privacy and rights guaranteed by the GDPR**: the use of such tools can have major impacts on data subjects, due to the large volume of data collected, the high number of individuals concerned, the challenges of exercising the right to erasure, and the risk of collecting data relating to data subjects' private lives (e.g., through the use of social networks), or even sensitive or highly personal data, without sufficient safeguards. These risks are even more serious when they involve data concerning vulnerable individuals, such as minors, who require special attention and appropriately tailored information.

- **Risks of carrying out unlawful data collection**: certain data may be protected by specific rights, such as intellectual property rights, or their reuse may be subject to the consent of the data subjects.

- **Risks of undermining freedom of expression**: the indiscriminate and large-scale data collection, and their possible memorization into AI systemsmay undermine data subjects' freedom of expression (e.g. a chilling effect due to a perceived sense of surveillance, which could lead internet users to self-censor — especially considering the difficulty of avoiding web scraping), even though the use of certain platforms and communication tools is essential in daily life.

However, data scraping is not prohibited per se, but must be analysed on a case-by-case basis.

Nevertheless, the CNIL has regularly called for vigilance regarding these practices and issued a series of recommendations to be respected in order to carry them out. The CNIL has also advocated for the creation of an ad hoc legislative framework (see, in particular, the CNIL opinion of December 15, 2022 on the "Polygraphe" project, in French)

In some cases, the CNIL has deemed such practices prohibited in the absence of a legal framework (in particular where processing operations are carried out by competent authorities for the purpose of detecting infringements). Conversely, they have been accepted in other cases, provided that stringent safeguards were implemented, for example for searching the internet for information leaks (RIFI).

For the moment, in the absence of specific legal framework, **this how-to sheet recalls the controllers' obligations and specifies the conditions under which such processing could be implemented for the development of an AI system.**

The legality of web scraping depends in particular on the possibility of relying on a valid legal basis. Collecting data accessible online to create a training dataset may be based on the legitimate interest, provided that it complies with the conditions set out in the legitimate interest how-to sheet. (see the how-to sheet 8 "Legitimate interest and development of AI systems").

Risks of violating other regulations

While the use of scraping techniques is not in itself incompatible with the requirements of the GDPR, it may be prohibited by other regulations (e.g. by terms and conditions of use based on database producer rights or copyright law). In this regard, research organizations may consider benefiting from the « text and data mining » exception under the French Intellectual Property Code (Articles L122-5 and 122-5-3), unless the rightholders have reserved their rights in an appropriate manner , in particular by machine-readable means in the case of content made publicly available online. This includes metadata and terms and conditions of a website or a service (recital 18 of Directive 2019/790 of April 17, 2019 on copyright and related rights).

Mandatory measures

Certain measures are mandatory, including under the principle of data minimization (Article 5.1.c of the GDPR):

- **define, in advance, specific collection criteria;**

- **exclude certain categories of data from the collection** when they are not necessary:
    - **where possible, through filters** (for example, if they are not necessary, bank transaction data, geolocation data, etc.);
    - **where filtering is not possible, exclude certain types of sites** (e.g., sites or social networks used mainly by minors) from the collection that structurally contain these categories of data (e.g., data concerning vulnerable persons such as minors or certain sensitive data);
- **ensure that any irrelevant data that may have been collected despite these criteria is deleted** immediately after collection or as

soon as it is identified as such (for example, if, on a public forum, people's pseudonyms are collected when only the content of the comments is necessary).

- **exclude from the collection websites that clearly oppose the scraping of their content** for the purpose of creating training databases by using robots.txt exclusion protocols or implementing CAPTCHA, which, by requiring an action that can only be performed by a human being, aims to prohibit access to pages by robots.

How can website publishers protect their content from scraping?

There are various ways in which a website publisher can express its opposition to webscraping, although there are no standards in this area (see, in particular, Alexandra Bensamoun's mission report on the implementation of the AI regulation in the field of copyright).

The CNIL encourages organizations to participate in the effort to standardize interoperable opposition mechanisms and to comply with new standards that may emerge, by implementing state-of-the-art technologies.

If they wish to protect the content of their site, publishers should implement a robot.txt exclusion protocol or CAPTCHAs, which the controller should be required to comply with.

Website publishers are also encouraged to implement other measures. A distinction can be made between blocking measures, which aim to technically prevent robots (crawlers) from accessing content, and non-blocking measures, which do not prevent the collection in practice but describe the rules desired by the website publisher in this regard.

Measures blocking access to the website:

- Integration of CAPTCHA tests (“Completely Automated Public Turing test to tell Computers and Humans Apart”);

- Blocking IP addresses: analysis of HTTP request headers, number of requests, detection of "suspicious" IP addresses (location, internet service provider); maintaining a register of IP addresses, devices, and VPNs known to host scraping bots; detection of bots concealed by requests to browser APIs;

Non-blocking measures:

- Other exclusion protocols (in addition to robots.txt, ai.txt (Spawning AI), TDMRep (tdmrep.json, W3C);
- Dynamic Page Loading to limit the raw HTML content of the site;
- Use of meta tags (e.g., DeviantArt's "noai" or "noimageai" meta tags);
- Registering the domain in a registry opposing collection for the purpose of developing AI models and systems (e.g., "do-not-train").

What to do in the event of incidental collection of sensitive data?

Particular attention should be paid to the collection of special categories of data within the meaning of Article 9 of the GDPR when using web scraping tools that involve the processing of large volumes of data. The controller is required to implement all measures to automatically exclude the collection of irrelevant sensitive data, in particular by excluding the collection of certain categories of data or by excluding certain websites containing sensitive data by nature. The controller it must be able to demonstrate it.

If, despite these measures, the controller incidentally and residually processes sensitive data that it did not seek to collect, this shall not be considered illegal. This aligns with the Court of justice of the European Union's stance, which recalls that that prohibition applies to the operator of a search engine "within the framework of his responsibilities, powers and capabilities" (CJEU, Grand Chamber, 24 September 2019, GC and Others, C-136/17). On the other hand, if the organization becomes aware that it is processing sensitive data, in particular through the data subject, it must immediately and automatically delete such data as far as possible.

This is without prejudice to the possibility of collecting or storing sensitive data, by way of exception, where its processing is necessary for the purpose pursued, and provided that it is based on an exception under Article 9.2 of the GDPR, in particular where it relates to personal data that has been manifestly made public by the data subject. This involves verifying whether the data subject has "explicitly made the choice beforehand, as the case may be on the basis of individual settings selected with full knowledge of the facts, to make the data relating to him or her publicly accessible to an unlimited number of persons" (CJEU, July 4, 2023, Meta Platforms, C-252/21 para. 85).

For example: An organisation that wishes to develop a tool that specifically generates political speeches constitutes a database from transcriptions of

videos published online by public figures may consider that this sensitive data has clearly been made public..

For more information: see how-to sheet 4 "Ensuring the lawfulness of the data processing".

Respect reasonable expectations

To ensure the expected balance in terms of legitimate interest, **the controller must limit the impact on data subjects' rights and freedoms,** taking into account their reasonable expectations in particular.

In this regard, given the recent technological development (big data, new AI technologies, etc.), data subjects may be aware that the information they share online is likely to be accessed, collected, and reused by third parties.

However, they cannot expect such processing to take place in all situations and for all types of publicly accessible data about them that are accessible online. Several factors should be taken into account, including:

- the **publicly accessible nature** of the data;
- the context and **nature of the source websites** (social networks, online forums, dataset repositories, etc.)
- the **restrictions set by these websites**, such as in their terms of use, or through technical measures such as exclusion protocols(e.g. robot.ttx), or blocking mechanisms such as CAPTCHAs. **In this regard, the CNIL considers that the processing cannot fall within the reasonable expectations of data subjects if the controller does not exclude from collection websites that explicitly object to scraping through robots.txt or CAPTCHAs.**
- the **type of publication** (for example, an article published on a freely accessible blog is not private, whereas a post on a social network published with access restrictions may be considered private by internet users).
- the **nature of the relationship** between the data subject and the controller.

Additional safeguards

As indicated in the how-to sheet 8 "Legitimate interest and development of AI systems", the choice of appropriate measures depends in particular on the intended use of the AI and the actual impact of this system on the data subjects. The CNIL recommends the implementation of the following measures in particular:

- **set out a list of websites from which data collection would be excluded by default**. This would apply to certain sites that contain particularly intrusive data due to their sensitivity (such as pornographic sites, health forums, etc.) or the level of information they provide about individuals (such as genealogy sites or sites that contain large volumes of structured data about individuals);

- **exclude collection for websites that oppose the scraping of their content or its reuse for the purpose of creating training datasets, through technical or legal measures, such as terms of use;**

- **limit the collection to freely accessible data** (i.e., content accessible to any user who is not registered on the site in question and without creating an account) **and that individuals are aware of making publicly available**. This means excluding, for example, data published on social networks for private use (information contained in profiles or private groups) and/or published on certain sites whose public nature is not obvious (online petition sites, for example);

- **disseminate information about data collection and individuals' rights** as widely as possible by using multiple media (e.g., online articles, the data controller's social media accounts), and by publishing an updated list of websites involved in data scraping (see how-to sheet 9 "Informing data subjects"). Publishing the information on the website where the data is collected may be a good practice;

- **provide for a discretionary and prior right to object**, in order to strengthen data subjects' control over their data. The CNIL encourages the development of technical solutions that would facilitate compliance with the right to object prior to data collection. In addition to the opt-out mechanisms put in place for intellectual property (see box above), "push-back lists" could, for example, be implemented when appropriate for the processing. This would allow the data controller to respect individuals' objections by refraining

from collecting their data;

- apply **anonymization or pseudonymization** measures immediately after data collection;

- **prevent any combination of data based on individual identifiers**, for example by replacing them with random pseudonyms specific to each piece of content (e.g., each post on a freely accessible online forum) rather than each identifier, unless the data controller demonstrates the need to be able to group together different data concerning a particular individual for the development of the AI system or model in question.

Note: It is up to the data controller to assess the relevance and necessity of implementing these measures on a case-by-case basis, taking into account the specific processing methods.

For example: An organization that collects numerous voice recordings online in order to develop and market an AI system for voice generation, without taking any additional measures to protect the training data or limit the risks of unlawful or malicious reuse, cannot rely on the legal basis of legitimate interest.

10. Informing data subjects

05 janvier 2026

Organizations that process personal data to develop AI models or systems must inform concerned data subjects. The CNIL specifies the obligations in this regard.

This content is a courtesy translation of the original publication in French. In the event of any inconsistencies between the French version and this English translation, please note that the French version shall prevail.

Ensuring the transparency of processing

The principle of transparency requires organisations that process personal data to inform data subjects so that they understand the uses that will be made of their data (why and how) and are able to exercise their rights (rights to object, right of access, rectification, etc.).

This principle applies to any processing of personal data, regardless of whether the data are:

- **directly collected from data subjects (also known as first party data)**: for example, in the context of a contract with voluntary actors to create a training dataset, when providing a service, in the context of a relationship between a citizen and an administration, etc.;

- **or indirectly collected (also known as third party data)**: for example, when data is collected on the Internet via file downloads, the use of web scraping tools or using application programming interfaces (APIs) made available by online platforms to re-users; when the information is obtained from institutional or business partners such as data brokers, or by reusing an existing dataset, etc. This also includes data generated by the controller itself (CJEU, judgment of 28 November 2024, Case C-169/23).

Note: Where the controller has not directly collected the personal data from the data subjects, it may be exempted from the obligation to inform them individually if such information is impossible in practice or would require disproportionate efforts. However, general information (e.g. on its website) must be provided, containing all the elements provided for in Article 14 GDPR and detailed below.

When should the information be provided?

Where the controller collects the training data directly from the data subjects themselves, it must inform them at the time of such collection. When it intends to further process the data for a purpose other than that the one for which the data were collected (subject to the compatibility of such re-use, see the dedicated how-to-sheet), it must inform the data subjects about this (Article 14.4 GDPR).

For example: a digital platform wants to reuse its users' data to train an AI model. It must inform them in advance.

When the data have not been collected directly, the organisation must inform the data subjects as soon as possible, and at the latest at the time of the first contact with the data subjects or at the time of the first communication of the data to another recipient where appropriate. In any case, the organisation must inform the data subjects within a period not exceeding one month after the date on which it retrieved their data.

As a good practice, where data are particularly sensitive to individuals, the CNIL invites organisations to respect a reasonable period of time between the moment when individuals are informed that their data are contained in the training dataset and the training of a model on that set (by itself or following the broadcast of the dataset). This good practice will allow data subjects to exercise their rights during this period given the technical difficulties in exercising these rights on the model itself and the risks this entails (in particular depending on the nature of the data stored).

How do I provide the information?

Ensuring the accessibility of the information

It must not be difficult for data subjects to access or understand the information.

Information notices must be distinguished from other information unrelated to data protection (general terms and conditions, legal notice, etc.). In this regard, while the information notices published on the websites of controllers may relate to many processing operations and concern different categories of persons (e.g. users of the website in question, data subjects involved in the development phase of AI systems, data subjects involved in their deployment, etc.), it is recommended to clarify which part of the information notices applies to which categories of persons (e.g. by clearly distinguishing information relating to development processing operations from information relating to other processing operations).

In practice, there are several ways to provide it:

- where individual information is provided, it may appear on the online form used to collect data, be mentioned in e-mails or letters sent by the data re-user during his or her first contact with data subjects, or be delivered via a pre-recorded voice message, etc.

- when providing general information (i.e. in the cases detailed below), it may for example take the form of information notices published on a freely accessible website or on a notice board.

Ensuring the intelligibility of information

The GDPR provides that information must be provided in a concise, transparent, intelligible and easily accessible form, using clear and plain language. The complexity of AI systems should not prevent the proper understanding of information by data subjects.

In this regard, it is recommended that controllers clearly define the main consequences of the processing: in other words, what will actually be the effect of the specific processing. The information could thus detail, for example by means of diagrams, how the data is used during the training phase, the functioning of the AI system developed, as well as the distinction that needs to be made between the training dataset, the AI model and the outputs of the model.

Point of attention: if it is possible to provide this information within existing documentation templates (such as datasheets, model cards or cards for AI systems), it must be easily accessible, clear and intelligible for the data subjects. This means that it must stand out clearly in such documentation.

For example: the description of the constitution of a dataset in a scientific publication using a technical vocabulary difficult to understand by data subjects is not sufficient to fulfil the requirements of intelligibility of the information.

To achieve these objectives, the CNIL recommends setting up **information in several levels, prioritizing essential information** (identity of the controller, purposes and rights of individuals) **at the first level** but offering complete information elsewhere.

With regard to processing of minors' data, particular attention should be paid to ensure that the information is sufficiently intelligible.

For more information on the design of information mentions: Data & Design by LINC

Derogations from individual information

In principle, the content of the information referred to above must be brought to the attention of the data subjects individually, i.e. directly (e.g. on a data collection form, account creation form, e-mail, etc.)

The GDPR provides for several derogations from the obligation to inform individuals individually (e.g. where a provision of EU or national law allows it to be excluded under Article 23). The following developments focus on the most relevant exemptions for AI development, but are not exhaustive (see Article 14.5 GDPR).

Situation 1: The data subject has already obtained the information on the processing for development purposes (14.5.a GDPR)

Where data subjects have already been informed of all the characteristics of the processing, in particular of the purpose and identity of the controller of the training operations, new information is not necessary.

To be noted: where the data are collected from a third party, the controller will have to ensure that full information on its own processing has already been provided to the data subjects.

As a good practice, the CNIL encourages data re-users to rely on the data broadcaster to inform individuals, in particular when the latter is still in contact with the data subjects.

For example, the provider of an online education service could inform its customers that their data will be processed by a named third party in order to develop an AI system for teachers by referring to the information notice of the latter. If such provider has referred to all information about the processing, the re-user will no longer have to do so.

For example, the publisher of a dataset on a training data exchange platform could usefully centralise the information mentions of re-users on the download page of such dataset.

On the contrary, if the provider of such dataset has correctly informed people about its processing of making the dataset available, but has not provided all the information on the processing of re-users, the latter will have to inform the data subjects by their own means.

Note that in this case, re-users of the dataset will most often find themselves in situation No. 2 (which allows to simply provide general information).

Situation 2: Information would require disproportionate effort (Article 14.5.b GDPR)

The controller can then simply make the information publicly available.

This argument is often invoked by organisations that are not or no longer in relation with the persons whose data they process (e.g. in the case of re-use of a dataset created by a third party). Indeed, in this case, they usually do not have their contact data.

A case-by-case analysis must be carried out, considering the specific context of each processing.

The organisation must assess and document the disproportionate character of the measure, by weighing, on the one hand, the interference with the privacy of the persons whose data are processed, and, on the other hand, the burden that an individual provision of the information to each data subject would entail.

- In order to assess the **extent of the efforts** to be made, account should be taken of the lack of means of contact of the data subjects, or the oldness of the retained contact data (with uncertain accuracy, e.g. contact details of more than 10 years), or the number of data subjects and the cost of communication.

  For example: the controller who intends to reuse the data of its customers and still has their e-mail address should always use it to inform them individually.

  Conversely, the controller intending to collect indirectly identifying data will generally not have to search for the real identity or contact details of persons in order to inform them directly (general information on its website being sufficient).

- In assessing **the invasion of the privacy** of data subjects and the intrusiveness of the processing, account should be taken of the risks associated with the processing (more or less directly identifying nature of the data, sensitivity of the data, etc.) and any safeguards put in place (such as pseudonymisation, carrying out a data protection impact assessment (DPIA), shortening the retention period or implementing various technical and organisational security measures, see the Legitimate Interest Sheet for a more detailed list).

  For example, depending on the risk resulting from the nature of the data and the context of its publication, the re-user of a publicly accessible online dataset may rely on the measures taken by the original controller to inform data subjects about the possibility of re-use by third parties for training purposes. The re-user can then simply provide general information (on his website).

Special case of online data collection

When lawfully collecting indirectly identifiable data published online, individual information will most often be disproportionate since finding ways to contact individuals involves searching for or collecting additional or more identifying data such as the actual identity of individuals.

For example: general information may be used when scraping or re-using a training dataset lawfully published in open source and containing only indirectly identifying data (such as publications or comments whose content is likely to identify the author).

The same will most often apply to the collection of data published under a pseudonym if such pseudonym is not collected or retained by the controller.

When collecting directly identifiable data, a case-by-case analysis should be carried out to assess whether it is necessary to seek to inform individuals individually through a means of contact (e.g. by searching for their contact details or by using a messaging system implemented on the website in question).

Finally, although the volume of data cannot on its own presume that individual information is disproportionate, this will most often be the case for the lawful collection of data which do not pose a risk to data subjects, from a large number of websites for the purposes of developing a large language model, and for which data subjects cannot be unaware that their data are publicly accessible, such as open source encyclopaedias.

To be noted: this derogation will more easily apply to organisations constituting training datasets of AI systems for scientific research purposes.

For example: the provision of general information will be sufficient for the use of a dataset of freely accessible profile photographs in the development of a deep fake algorithm for scientific research purposes.

Appropriate measures that may be taken by the organisation in addition to general information

Beyond providing general information by making the information publicly available (e.g. by publishing the information on the organisation's website), other appropriate measures may be taken by the organisation in this case, such as:

- Carrying out a DPIA, including where not required by Article 35 of the GDPR;
- Applying data pseudonymisation techniques;
- Reducing the number of data collected and the retention period;
- Implementing technical and organisational measures to enhance the level of security.

What information should I provide?

In case of individual information

Where the controller provides individual information - either because it collects the data from individuals (Article 13 GDPR) or because it collects the data from third parties but has a means of contact and this does not represent a disproportionate effort (see above) - **it is generally required to provide all of the following information**, as provided for in Articles 13 and 14 GDPR.

The organisation that builds or uses a training dataset to develop an AI system based on personal data must inform data subjects about the following, regardless of whether the data was collected directly or indirectly:

- **his/her identity** and contact details (such as e-mail address, postal address or telephone number) and the means of contacting his/her data protection officer;

- **the purpose and legal basis** of the processing, including, where appropriate, details of the legitimate interest pursued if the processing is based on that interest;

- **the recipients** or at least the categories of recipients of the data, with, where appropriate, details of the planned transfers of those data to a country outside the European Union;

- **the retention period** of the data (or, failing that, the criteria for determining it);

- **the rights of data subjects** (rights of access, rectification, erasure, restriction, right to portability, right to object or withdraw consent at any time);

- **the right to lodge a complaint** with the CNIL.

To be noted: While information on the retention period and the exercise of rights does not have to be provided systematically for all processing operations, it will be almost systematically required for the compilation and use of training datasets. Indeed, they are necessary to ensure fair and transparent processing towards data subjects.

In the case of indirect collection, the organisations must provide, in addition:

- **Categories of personal data** (e.g. identities, contact details, images, social media posts, etc.);

- **Where necessary to ensure fair and transparent processing, a precise indication of the source(s)** of the data (including whether or not they are publicly available sources).

Such information should enable individuals to anticipate whether they are affected by the processing and facilitate the possible exercise of their rights over the source processing.

In case of publication of a general information notice

Where individual information is not possible, because the controller cannot identify the persons in the dataset, does not have contact data of the data subjects or contacting them individually would require disproportionate efforts, appropriate measures must be taken. It is necessary to publish an information notice, for example on a website, which includes, if possible, the information that would have been provided in case of individual information.

Furthermore, this information must include, where applicable, **the fact that the controller will not be able to identify individuals, including to respond to their requests for the exercise of rights** (in accordance with Article 11 GDPR). In this case, the CNIL recommends, if possible, to indicate to persons wishing to exercise their rights what additional information they can provide to enable their identification.

When informing data subjects on sources, two cases are to be distinguished:

- **Where the controller has used a limited number of sources** to build up its training dataset, it is generally required to provide precise information on those sources, unless it can justify an exception.

- **Where many sources are used**, for example a large number of publicly available sources online, overall information, such as source categories, or even the names of a few main or typical sources, is generally sufficient.

In case of re-use of a dataset or AI model subject to the GDPR

In addition to indicating the source of the data used, the CNIL recommends, at least for the datasets that present the greatest risk to individuals, providing the means of contacting the controller from which it was

retrieved. A good practice is to refer directly to the website of the original controller, and to accompany the information with a concise and clear explanation of the conditions for data collection and annotation.

Examples of references:

This training data comes from a publicly accessible dataset (hyperlink to the publication) containing 70 000 images and consisting of photographs published online under an open license on the social network _____ between 2020 and 2021.

This data comes from a dataset provided by _____, a data broker (whose contact details are _____). This dataset consists of 3,000 images initially collected from volunteer actors playing different facial expressions, annotated to transcribe their emotions.

As part of the development of this AI system, we are reusing a large language model developed by the _____ company that has memorised personal data. For more information, we refer you to its privacy policy available at the following address: _____.

In case of scraping on websites or reuse of scraped data

If the scraping concerns a few websites, the CNIL recommends precise information on the sources used. Where sources are very numerous, it recommends providing the categories of source sites concerned, at least those **posing the greatest risk to persons.** This recommendation applies to scraped data, but also to controllers who re-use datasets made from scraped data.

Examples of sufficiently precise statements:

To this end, we have collected freely accessible data by scraping on the following platforms: _____. These data consist of publications made manifestly public by their authors on the subject _____. Comments related to publications were not collected. The images and pseudonyms were processed at the time of collection but were not kept.

The data was collected by scraping websites specialised in the field studied and may contain personal data such as the name of the author, or of a person quoted in a freely accessible blog post. The images contained in the article are not collected.

Where possible, providing information on domain names and URLs of scraped web pages as well as the date or period of collection is a good practice, but is not required under the reporting obligations.

In case of development of a general-purpose AI model within the meaning of the AI Regulation

In parallel with the information obligation under the GDPR, Article 53 of the AI Act, clarified by Recital 107, requires providers of general-purpose AI models to make available to the public a sufficiently detailed summary of the content used to train these models, in accordance with the template provided by the AI Office (European Commission).

This includes, for example, listing the main datasets or collections used to train the model, such as large-scale public or private data archives or datasets, and providing explanatory text on the other data sources used.

The first version of the summary template, as published by the AI Office in July 2025, is a tool that provides some of the information required to ensure compliance with the GDPR's information obligation for providers of general-purpose AI models. This information must be completed by the provider.

To train our large language model described above [see in particular the sheet on the precision of the definition of the purpose of the processing], we reuse data publicly available online on the following categories of site [to be completed] that we collected on [date] within the _____ dataset.

Examples of source website categories:

- institutional sites
- open source encyclopedia
- research paper exchange platforms
- national [or international] press sites
- website of national or international audio-visual media
- specialised discussion forums [describing these specialities, e.g.: IT development, education, health, cultural events, sporting events, etc.] or generalist events, etc.
- platforms for sharing images, audio or audio-visual content (music, photographs, audio recordings, videos)
- professional social networks
- online sales websites

On the specific case of AI models whose processing is subject to the GDPR

A number of AI models are considered anonymous: the GDPR does not apply to them as such, including the obligation to provide information. On the contrary, training an AI model can sometimes lead to it 'memorising' part of the training data (see EDPB Opinion 28/2024 on certain aspects of data protection related to the processing of personal data in the context of AI models). Where the model itself is found to be subject to the GDPR, individuals should be informed about the memorised data.

The provider of the AI model or system should then specify the information elements indicated above (purpose, controller, recipients, etc.).

As a good practice, the supplier is also recommended to specify:

- the nature of the risk associated with extracting data from the model, such as the risk of regurgitation of data in the case of generative AI;

- the measures taken to limit those risks, and the existing redress mechanisms in the event that those risks arise, such as the possibility of reporting an occurrence of regurgitation to the organisation.

11. Ensuring and facilitating the exercise of data subjects' rights

05 janvier 2026

Individuals whose data is collected, used or reused to develop an AI system have rights over their data that allow them to maintain control over it. It is the responsibility of the controllers to comply with them and to facilitate their exercise.

The exercise of rights is closely linked to the provision of information on processing operations, which is also an obligation.

-
-

This content is a courtesy translation of the original publication in French. In the event of any inconsistencies between the French version and this English translation, please note that the French version shall prevail.

General reminder on applicable rules

Data subjects have the following rights over their personal data:

- right of access (Article 15 GDPR);
- right of rectification (Article 16 of the GDPR);
- right to erasure, also known as the right to be forgotten (Article 17 of the GDPR);
- right to restriction of processing (Article 18 GDPR);
- right to data portability where the legal basis for processing is consent or contract (Article 20 GDPR);

- right to object where the processing is based on legitimate interest or public interest (Article 21 GDPR);
- right to withdraw consent at any time where the processing of personal data is based on consent (Article 7(3) GDPR).

Data subjects must be able to exercise their rights both:

- **on training datasets** and,
- **on AI models if they are not considered anonymous** as specified in EDPB Opinion 28/2024 on certain aspects of data protection related to the processing of personal data in the context of AI models.

While the exercise of a right of access, rectification or erasure on a training dataset presents quite comparable problems compared to other large datasets, the exercise of the same rights on the AI model itself presents particular and unprecedented difficulties. This must lead to **the adoption of realistic and proportionate solutions, in order to guarantee people's rights without preventing innovation in artificial intelligence. The CNIL thus considers that the GDPR makes it possible to understand the specificities of AI models for the exercise of rights. The complexity and costs of applications that would prove disproportionate are thus factors that can be taken into account.**

With regard to the development of AI models or systems: how to respond to data subjects' rights requests?

In practice, it is quite different to respond to requests for the exercise of rights depending on whether they relate to the training data or to the model itself.

The CNIL recommends that controllers clearly inform those exercising their rights about how they interpret their request (on training data or on the AI model) and how they respond to it. This is particularly important when the modification of their data in the training datasets is not reflected (or at least not immediately) in the AI model or system already developed (provided that this is justified by one of the derogations described below).

For the exercise of rights on training datasets

- **Difficulties in identifying the data subjects**

Where the controller does not or no longer need to identify data subjects and can demonstrate that it is unable to do so, it may indicate this in response to data subjects' rights requests.

This will often be the case for the development and use of training datasets. The provider of an AI system does not, in principle, need to identify the persons whose data are present in its training dataset. When identification data are no longer available, certain metadata and precise information on the sources of each data may make it possible to find people in a training base but, again, the retention of this information is not mandatory (on the issue of information on sources, see below). For example:

- An organisation does not have to keep the faces of an image dataset for the sole purpose of enabling the exercise of rights in a set of photographs if compliance with the principle of minimisation requires it to blur the faces.

- An organisation does not have to keep identification data in the dataset for the sole purpose of allowing the possible withdrawal of consent of individuals if they have been duly informed of this and have consented to it in an informed manner (e.g. by being informed when erasure of the data stored by the AI model will not be possible).

Where the controller is unable to identify the data subjects, it is also not necessary for the controller to retain the training data in order to respond to requests for the exercise of rights (e.g. to consider retraining an AI model as further developed below).

However, it is not because the controller cannot identify the data subjects on its own that such identification is impossible. In this particular case, the GDPR leaves the possibility for **individuals to provide additional information in order to help controllers identify them and thus exercise their rights.**

In this regard, the GDPR does not provide for any particular form. A data subject could therefore, for example, provide an image or a pseudonym (such as a username under which the data subject has an online activity). Moreover, it is only if and only if the organisation has reasonable doubts as to whether the data belong to the applicant that it may ask the applicant to attach any document proving that the data in question are indeed its own.

Under the principle of data protection by design and the obligation to facilitate the exercise of rights, it is recommended to anticipate such identification difficulties by indicating additional information that may allow the identification of data subjects (e.g. in the case of homonymy). This may include allowing them to provide a particular file (such as an image, audio or video recording) but also other information when this is not possible.

Such additional information, provided by individuals, may not be processed for any purpose other than the exercise of their rights.

- ## With regard to the right to receive a copy of the training data (under the right of access)

The right of access allows any person to obtain, free of charge, a copy of all the data processed concerning him or her. This includes the right to obtain extracts from training datasets where this is necessary to enable the data subject to exercise effectively his or her other rights (CJEU, 4 May 2023, Case C-487/21). In this regard, the CNIL recommends providing personal data, including annotations and associated metadata, in an easily understandable format.

Such communication shall be without prejudice to the rights and freedoms of others, which shall include in particular the rights of other data subjects, or the intellectual property rights or trade secrets of the dataset holder.

- ## With regard to information on data processing (under the right of access)

Allowing data subjects to know the precise recipients and sources of their data is essential to ensure effective control over their data. This information allows them to exercise their rights vis-à-vis the controllers holding their data. This is particularly important due to the often-complex chain of actors in the development of AI systems.

If the person is present and identifiable in the dataset, the controller must be able to provide all the information required by Article 15 GDPR. Among these, however, information on sources calls for clarification specific to this type of database.

Where the data have not been collected directly from the data subjects (for example, in the case of transmission by a data broker), **the right of access makes it possible to obtain 'any available information as to their source'.**

However, as seen above, the controller will not always have to keep such information when it does not or no longer needs to identify the data subjects, and when traceability is not necessary for the purpose or to ensure the proportionality of the processing of the training data.

It will then have to provide any relevant information at its disposal to the data subjects who request it, i.e. on all the sources used.

A case-by-case analysis is necessary to determine what information is reasonable and proportionate to retain in order to ensure individuals' rights over their data. Although, in particular in the case of collection from public sources, the GDPR does not fall within that level of detail by not requiring the retention of information on each URL used, it is nevertheless necessary to establish sufficient documentation on the sources of the training data in order to maintain their consistency with the rights guaranteed by the Regulation, in particular by Article 15 of the GDPR, and to allow the controller to document its compliance with the GDPR.

For example:

In case of re-use of a medical dataset to create a medical imaging analysis AI, the controller will need to keep the information on the source used and where possible the means of contact of the source controller, in order to be able to provide it to individuals.

The developer of an AI model that has lawfully collected data by scraping a significant number of web pages builds a textual dataset whose very large volume makes it very difficult to search by keywords. In order to be able to verify the presence of indirectly identifying data of the persons exercising their right of access, that developer could request to provide the URL(s) of the web pages concerned and implement an indexation of the URLs targeted by the scraping allowing it to easily navigate in the dataset (in the manner of the indexation carried out for Common Crawl). The retention of URLs of scraped web pages and the indexing of training data is one way to achieve this objective, however the GDPR is not prescriptive and the controller is only required to provide the information available on the sources in the context of the right of access.

In any case, information on data sources is useful to demonstrate the compliance of the training base. Data controllers will therefore have to keep certain information on sources under the principle of accountability and data protection by design. In some cases, the EU AI Act also requires the provider of the AI system or model to document training data, including its source (Articles 11 and 13 for high-risk systems and Article 53 for general purpose AI models).

- ## With regard to the rights to rectification, objection and erasure of one's data contained in a training dataset

Data subjects have the right to rectify the data concerning them. In the present context, this may concern incorrect annotations which the data subjects would like to see corrected.

The right to erasure makes it possible to require the deletion of data in a number of cases provided for in Article 17 GDPR, for example where the data subject reveals to the controller that it holds sensitive data concerning him or her (within the meaning of Article 9 GDPR) and for which no derogation justified their processing.

Furthermore, **where the processing is based on a legitimate interest or the performance of a task carried out in the public interest, data subjects may, at any time, request to object on grounds relating to their particular situation.** The data controller must then do so, unless there are compelling and legitimate reasons for continuing to process the data.

For example: objection, and subsequent erasure, are in principle a legal right in the case of the retention of compromising photographs in a dataset or of personal statements made on the web when the person was a minor.

In the event of web scraping of data accessible online, the CNIL encourages the development of technical solutions that would facilitate compliance with the exercise of the right to object prior to data collection. By way of comparison, we can mention the opt-out mechanisms put in place in the field of intellectual property. There are also 'rejection list' mechanisms for certain processing operations, which could be transposed where appropriate in the light of the data processing carried out. In this way, the controller could respect the objection of individuals by refraining from collecting their data.

- ## With regard to the notification of the rights exercised (rectification, limitation and erasure)

Article 19 GDPR provides that a controller shall notify each recipient to whom the personal data have been disclosed of any rectification, erasure of personal data or restriction of processing carried out, unless such communication proves impossible or requires disproportionate effort (depending on available technologies and implementation costs). For example, where possible, the CNIL recommends the use of application programming interfaces (APIs) (particularly in the most risky cases), or at least techniques for managing the logging of data downloads.

In case of dataset sharing, it is good practice to inform about the different versions of the datasets, and to provide for a contractual obligation (e.g. in the dataset re-use licence) to pass on the effects of the exercise of the rights of objection, rectification or erasure by their re-users.

For the exercise of rights on models whose processing is subject to the GDPR

Some AI models are trained on datasets containing personal data but are, in themselves, anonymous.

However, in other cases, the model itself contains personal data that can be extracted from it and therefore cannot be considered anonymous (see EDPB Opinion 28/2024 on certain aspects of data protection related to the processing of personal data in the context of AI models). In particular, this is generally the case for large language models which, fed by public sources, can provide information on natural persons, especially public figures.

The rights available to individuals under the GDPR then apply to the model, but there are significant difficulties in implementing them. While certain safeguards will have to be considered in this case, the CNIL considers that the requirements of the GDPR are sufficiently balanced to capture the specificities of AI models. In particular, the constraints of AI model providers in exercising rights over the data they contain should be considered, such as the difficulty (or even impossibility) of identifying the data of a particular person within the model or the complexity and costs of retraining a model that may be disproportionate.

- **With regard to the identification of the data subject within the model**

Where the GDPR applies to the model, two situations can be distinguished:

- Either the presence of data of the person in the model is obvious (e.g. some AI models are specifically designed to provide output personal data used for their training);

- Either that is not the case, and the question arises as to the assessment of the likelihood that data concerning that person is in the model. **The controller will then be able to demonstrate that it is unable to identify persons within its model within the meaning of Article 11 GDPR.**

Once the presence of a person within the model has been identified, the question also arises of identifying the personal data contained therein.

Influence of a person's data on model parameters

When training the most complex machine training models such as neural networks, training data is used to optimise model parameters. However, due to the large number of iterations required to train the model and the nature of the techniques used (such as gradient descent), the contribution of each piece of data to the model is diffuse and methods to trace it are still being researched.

The field of machine unlearning, the principle, advantages and limitations of which are described in the Linc article 'Understanding machine unlearning' and in the EDPB's Support Pool of Experts programme document 'Effective implementation of data subjects' rights', is frequently the subject of promising advances. For example, the use of influence functions, which allow to keep track of the contribution of data on model parameters during training, is one of the techniques that could solve the question of the contribution of each data. These techniques would, for example, make it possible to identify the weights influenced by the outliers contained in a dataset and thus correct their value.

Pending the progress of research on these subjects, it does not seem possible today, in the general case, for a controller to identify for a particular person, all the data concerning him which have been memorised by the AI model without the latter providing additional information. On the other hand, it may sometimes be possible for the model to determine whether the model has learned information about a person by conducting fictitious tests and attacks, such as membership inference attacks or attribute reconstruction attacks. These attacks are described in the Linc article 'Small taxonomy of attacks on AI systems'.

The CNIL warns data controllers about the fact that this position is only valid in the light of the current state of the art, and that it actively encourages research and the development of practices to ensure the exercise of rights and the principle of data protection by design.

It should be noted that there are, however, special cases such as when the model parameters explicitly contain certain training data (which may be the case for certain models such as support vector machines or SVMs, certain data partitioning algorithms, or clustering, when an AI system is connected to a knowledge base (such as augmented recovery generation or RAG): it will then be technically possible to exercise the rights over the parameters of the model.

As with the exercise of rights over training data, **the controller must, if possible, inform data subjects that it is unable to identify them on its own**, and allow them, if possible, to provide additional information, enabling them to be identified so that they can exercise their rights.

The CNIL recommends that the model provider informs the data subjects of the additional information to be provided in order to identify them.

- **When the training data are still available to the controller**, it may be relevant to identify the person within the training data, before verifying whether they have been stored by the model and are likely to be extracted from it.

- **Where the controller no longer has the training data**, the latter may rely on their typology to anticipate the categories of data that may have been stored, in order to facilitate attempts to identify the person (e.g. by testing and queries on the AI model in question).

In the case of generative AI, the CNIL recommends that the developer establish an internal procedure entailing the querying of the model (e.g. through a list of carefully selected prompts) in order to verify whether it has retained personal data concerning an individual on the basis of the information supplied.

Example:

The developer of a large language model (LLM) who has trained its model on data collected by scraping from various websites on the web may indicate to a person wishing to exercise his or her rights that he or she will need to provide the (prompt) queries which, according to him or her, reveal that his or her personal data is memorised by the AI model.

To that end, the data subject may, for example, and if he or she has it, use a copy of the training data relating to him or her in order to verify that certain information may be extracted from the model (for example, by asking the model to complete a part of his or her biography accessible on an open-source encyclopedia (in the case of a public figure), or an article from a website).

Due to the probabilistic functioning of these models, it is possible that the result provided does not result from a memorisation of training data but from a generation based on correlations learned from other data. These results are sometimes referred to as hallucinations when they are factually unfounded but presented as truthful.

In some cases, it will be important to clearly distinguish the model from the system within which it is integrated. Indeed, the system – which can be

considered as a kind of interface between the user and the AI model it integrates – can add different data to the query of the model or its result (e.g. through a web search or from a knowledge base in the case of the RAG). It is therefore possible for a person to mistakenly believe that an AI model contains data about him or her, whereas the results in question are caused by other components of the system. It is therefore essential to keep this distinction in mind in order to identify the right controller. For example, if a knowledge base (in the case of the RAG) is integrated into the system by its supplier, the latter will also have to take into account the requests for the exercise of rights concerning it. On the contrary, if this knowledge base has been added by a third party, the data subjects will have to turn to that third party. A dedicated how-to-sheet will soon clarify the issues of responsibility in this area.

- **With regard to the information on the processing of the model (under the right of access) and the right to obtain a copy of the data:**

Where the controller has been able to identify the data subject and verify that the data has been memorised, the controller must confirm this.

Where the person has exercised his or her right to obtain a copy of his or her data, the controller should provide him or her with the result of its investigations concerning him or her, in an understandable format, in particular with examples of outputs containing his or her personal data for generative AI systems.

Where it has not been possible to verify the presence of a memorisation, but the controller has not been able to exclude that it is possible (in particular because of the technical limitations of the current methods), the CNIL recommends to inform individuals that it is not impossible that training data concerning them have been memorised by the model.

If the data controller still has the training data, the CNIL recommends that it responds to the person by confirming that his or her data has been processed for training and that it may have been stored.

Where applicable, information specific to the model should be provided, such as information on the recipients of the model (15.1.c), its retention period or the criteria used to determine it (15.1.d), the rights that can be exercised on the model (15.1.e and f), as well as its provenance when it has not been designed by the controller (15.1.g).

- **With regard to the exercise of the rights to rectification, objection or erasure on the model**

Not all rights of individuals over their data are absolute. This is particularly the case for the right to erasure, which essentially results from the right to object (the conditions of which are set out more specifically below): a balance must be struck between the right of the individual and any 'legitimate and compelling reasons', under the GDPR, of the controller.

Although the identification of data from the parameters of a model presents significant technical difficulties to date, some practical solutions make it possible to respond to the exercise of rights (in particular retraining of the model or the application of filters) but they are, to date, either particularly expensive and delicate or imperfect.

Thus, whether or not the response to the exercise of a right is proportionate will depend on:

- **the sensitivity of the data** and the risks that their regurgitation or disclosure would pose to individuals.

  For example, a person may wish to object to the processing of his or her data due to hallucinations or inaccuracies against him or her that may cause him or her harm (e.g. by wrongly attributing wrongful or criminal conduct or presenting the person as deceased).

- **the infringement of the data controller's freedom to conduct a business**, which depends on the practical feasibility and cost of the measures to be taken to comply with the data subject's request, in particular with regard to a possible retraining of the model (in terms of computational, environmental, human and financial resources).

  For example: a large language model is fed by a large number of public sources and properly informs users about the functions of certain public figures. A public figure asks to be erased from the model. The retraining of the models comes at a very high cost. The request for erasure may in principle be rejected.

  For example: an AI model to help insurance companies has been trained on a set of real cases. The model is not anonymous as its anonymity would have undermined its performance. A person, who had not objected to his presence in the training base, realises that information about the financial settlement of his claim comes out in the results of the model when some questions are asked. The controller must then in principle propose solutions to respond to the request for erasure of model data.

Techniques to ensure people's rights to their data in AI models are evolving: controllers must remain alert to the fact that some requests, which could be refused today, will have to be processed tomorrow if the state of the art, in particular on re-identification and unlearning techniques, progresses. Without prejudice to effective methods that can be developed by the actors, the CNIL identifies, to date, two main techniques:

- the most effective is retraining, which makes it possible to erase or rectify data at the heart of the model;

- alternatively, where retraining is not possible, filters can be used to address certain effects of the model without deleting data from the model itself.

They will be examined in turn.

Where the controller still has the training data, a retraining of the model makes it possible to respond to the exercise of rights following their implementation in the dataset.

This retraining may take place periodically in order to handle several requests for the exercise of rights at the same time. In principle, the controller must respond to a request as soon as possible, and at the latest within one month. However, the GDPR provides that this period may be extended by two months in view of the complexity and number of requests (e.g. depending on the extent of the retraining to be carried out), provided that the person is informed thereof. When retraining is not planned or possible within this timeframe, the use of filters (see below) may be considered pending the next training of the model.

The controller will then have to provide an updated version of the AI model to its users, if necessary by contractually requiring them to use only a regularly updated version. A good practice is to communicate more widely about updates to datasets or templates, for example in the documentation of the dataset or on the suppliers' website, to allow data subjects to know the extent to which their requests have been complied with. This also involves encouraging recipients of earlier versions to delete them or replace them with the latest version.

Alternatively, when the retraining of the model proves disproportionate (temporarily or definitively), the CNIL recommends the implementation of other types of measures to protect the data and privacy of individuals. If the state of the art evolves rapidly, the CNIL recommends in particular the use of measures consisting in filtering the outputs of a system to allow to respond to the exercise of the rights to rectification, objection

or erasure if the controller demonstrates that they are sufficiently effective and robust (i.e. they cannot be circumvented).

In practice, the most robust measures in this area are not applied to the model itself but to the AI system that implements the model, in order to limit its outputs. The model provider must therefore ensure that these measures are effectively put in place, by the model provider and/or by the users, depending on the deployment mode. A how-to-sheet dedicated to the allocation of responsibilities between the provider and the deployer of a non-anonymous AI model will be published soon.

- It is recommended to use general rules preventing the generation of personal data, rather than a 'blacklist' of those who have exercised their rights.

- These general rules should seek to detect and pseudonymise the personal data concerned in outputs where the production of personal data is not the intended purpose, for example through named entity recognition techniques.

- Otherwise, a blacklist should be considered. Its safety should be ensured and the impact of the filter on outputs should be assessed, in particular by assessing the increase in the risk of an membership inference attack that it may induce by modifying the statistical distribution of outputs, thus making it possible to identify persons who have objected.

The provider of the AI model or system should then provide its deployer with the means to implement those measures to enable it to meet its own obligations.

Good practice

As the technical solutions currently available are not satisfactory in all cases where a model is subject to the GDPR, the CNIL invites providers as a priority to anonymise training data or, if they are unable to do so, to ensure that the AI model is anonymous after its training.

Derogations from the exercise of rights on datasets or on the AI model

Point of vigilance: where it can rely on certain derogations, the controller must inform persons in advance (i.e. at the time of the provision of the

information) that their rights are subject to restrictions and explain the reasons for the refusal of the exercise of a right to the persons who have requested it.

Apart from situations in which the controller is unable to identify the data subjects (see the dedicated developments above), the controller may derogate from the exercise of rights in the following cases:

- **The request is manifestly unfounded or excessive** (Article 12 GDPR).
- **The organisation receiving the request is not the controller in question.**
- **The exercise of one or more rights is excluded by French or European law** (within the meaning of Article 23 GDPR).
- **For processing operations for scientific or historical research purposes, or for statistical purposes: where the exercise of the rights would be likely to render impossible or seriously impede the attainment of those specific purposes** (within the meaning of Article 116 of the Decree implementing the Law on information technology and freedoms).

For more information: consult this set of articles on the rights of individuals

12. Annotating data

05 January 2026

The data annotation phase is crucial to ensure the quality of the AI model. This challenge can be achieved by means of a rigorous methodology guaranteeing performance for the system and protection of personal data.

This content is a courtesy translation of the original publication in French. In the event of any inconsistencies between the French version and this English translation, please note that the French version shall prevail.

The data annotation phase is a decisive step in the development of a quality AI model, both for performance issues and for the respect of people's rights. This step is central in supervised learning, but also to provide a validation dataset in unsupervised learning. It consists of assigning a description, called label, to each of the data that will serve as a "ground truth" for the model which must learn to process, classify, or discriminate data based on that information. The annotation may relate to all types of data, personal or not, and contain all types of information, personal or not. Annotation can be human, semi-automatic, or automatic. It can be an independent process, or result from existing processes in which data characterisation has already been performed for a certain need and then reused for training AI models (as in the medical diagnosis use-case described below). In some cases, AI training will be based on existing data and annotations. This sheet, as well as those on data protection during the design of the system and the collection of data, will then have to be applied. The scope of this sheet covers all the cases mentioned above where the annotation relates to or contains personal data.

Examples of annotations:

- In order to train a speaker recognition AI model integrated into a voice assistant, voice recordings are annotated with the identity of

several speakers;

- In order to train a fall detection AI model integrated into the video surveillance system of a nursing home, images are annotated with the position of the persons represented according to several labels such as "standing" or "laying down";

- In order to train an AI model for the recognition of license plates embedded in an access gate to a private space, images are annotated with the position of pixels containing license plates;

- In order to train an AI model for predicting the risk of a certain pathology, intended to be used as a diagnostic aid by healthcare staff in a hospital, the blood results of patients are annotated with the diagnosis made by a doctor on the pathology in question.

The stakes of annotation for people's rights and freedoms

When it relates to personal data, the annotation must be done in compliance with the GDPR. It generally aims to the same purpose as the one defined for the processing and must comply with the principles laid down by the GDPR. In view of the risks for individuals in both the development and deployment phases, the CNIL wishes to draw the attention of stakeholders using annotation to the principles of minimisation, accuracy and loyalty.

The principle of minimisation

Minimisation consists of processing only data "adequate, relevant and limited to what is necessary in relation to the purposes for which they are processed" (Article 5.1.c GDPR). In practice, this means that the annotations, as much as the training data to be annotated, must be limited to what is necessary for the training of the model, as described in the sheet "Taking data protection into account in data collection and management".

Annotations containing information that are not relevant to the intended purpose do not comply with the principle of minimisation. In some cases, information indirectly related to the purpose may be useful for improving the performance of the model (such as images of billboards for training a traffic sign identification model, as this addition should allow better avoidance of certain false positives). Information is relevant if its link to model performance is proven

(theoretically, or empirically, notably in scientific publications) or sufficiently plausible.

Annotated datasets used by the developer of an AI system following a previous collection, purchase or download (from an open source or not) should contain only annotations relevant to the functionalities of the system. Where this is not technically possible, the controller must be able to justify it and try to use the most relevant annotated dataset. A triage of the data must then be carried out to limit the retained annotations to those that are relevant.

Example: Annotating an image with the profession of the represented individual will not be useful for an algorithm aimed at detecting a person's presence. On the other hand, annotating the position of its members may be a useful indication for the model that might be able to detect partially occulted people.

Where the activity of an organisation consists of setting up training datasets for the service of third parties, two situations must be distinguished:

- either, as recommended, the training set is created or configured specifically for the customer's needs; the provider of the training dataset is then subcontracted to its customer for the application of the GDPR; the subcontractor must ensure that the dataset contains only relevant annotations;

- either the supplier makes available training sets already constituted; it must then have designed his product in such a way as to enable compliance with the principle of minimisation; a solution may be to provide for several categories of annotations, separable or cumulative, or to offer several distinct sets according to the types of annotation.

In any case, the training datasets must have been constituted and made available in compliance with the GDPR.

The CNIL's recommendations on data minimisation made in the how-to sheets "Take data protection into account in the system design choices" and "Taking data protection into account in the collection and management of data" are applicable.

Annotations may include contextual elements that are useful for measuring and correcting errors and biases. In the case of probabilistic systems such as the majority of AI systems, performance management relies on the ability to measure and correct errors and biases most likely to impact system efficiency. It may therefore be relevant to annotate training, testing or validation data with context elements (date and time, weather, etc.), in particular to measure possible performance

deviations depending on the situation. On the other hand, particular attention must be paid to annotation with personal data such as a person's name or sensitive data (religion, skin colour, etc. – see below).

Example: an automatic image analysis system is driven from camera data in different locations at times where people visit them. In order to measure its performance, the designer annotates the data with the following information: day/night, type of habitat filmed, weather.

The principle of accuracy

Accuracy requires for the data to be accurate and, where necessary, kept up to date. This principle implies that the annotation must contain only accurate information about the person to whom the data correspond. **An incorrect annotation or one that is based on inappropriate or arbitrary criteria will not respect the principle of accuracy.** In practice, this means that the developer will have to take appropriate steps to ensure that the annotation criteria are objective. This issue appears all the more important because the annotation is usually a single word, or a short expression, which is not enough to fully describe a person. This annotation has a risk of being perceived as degrading by people who should not be overlooked, especially since **the system could reproduce the inaccuracies of the annotation later, during the deployment of the system and lead to inaccurate, even degrading or discriminatory exits.**

Example: Annotating a set of images with the profession of the persons represented could lead to inaccurate annotations if the job categories used in the annotation are too specific. Thus, an image on which a person in a white coat is represented without further information could just as well be a doctor or a nurse and assigning it the annotation "care giver" would be more respectful to the principle of accuracy.

Other principles that are less specific to annotation, such as **loyalty**, **transparency**, **confidentiality** or **integrity**, also apply.

Ensure the quality of the annotation

The CNIL invites stakeholders to implement the following measures:

- **Defining an annotation protocol**, in accordance with the principles of accuracy and minimisation. The CNIL recommends following the following steps:

- The choice of annotation labels. They should be adapted to the intended purpose for the deployment of the system, and limited to information relevant for training. Although this purpose is not always known precisely when designing the model, in particular for foundation models, the labels chosen should correspond to the expected functionalities at the end of the learning process. For more information on the purpose of foundation models and general purpose systems, please refer to the "Defining a purpose" how-to sheet. In addition, they must allow an objective and unambiguous annotation. Since these labels serve to characterise a person's data, their choice must be made in a fair manner towards persons whose data are annotated and in particular exclude any degrading, depreciative or term and value judgement that may damage the reputation of persons. Since annotations may serve as proxy values for other information about the person, such as special categories of data, particular attention must be paid to the fact that it does not lead to the unintended introduction of bias, and possible discriminations, into the system. In the event that the annotation results from an existing business process, a phase of triage or requalification of labels may be recommended in order to limit the annotations to what is necessary and relevant for the training of the AI model. Finally, when aiming to anonymize the data to be annotated, it may be relevant to consider the role of labels in the anonymization process. Indeed, labels can facilitate the cross-referencing of data, potentially leading to re-identification.

- **The definition of an annotation procedure**. It should:
  - be documented;
  - provide for clear assignment of tasks, thus limiting access to data only to authorised persons;
  - allow persons performing the annotation to provide feedbacks on the annotation protocol, and in particular on labels and data, in order to identify when the protocol can be improved or is inappropriate;
  - include a validation phase to confirm the choice of labels and the functioning of the procedure, during which, for example, the inter-annotative agreement will be evaluated when several persons perform the annotation. An in-depth analysis of a random sample of annotated data will identify certain errors, inaccuracies, or recurrent

inaccuracies during this phase;

- be tracked by logging changes, or using a versioning tool;

- rely on a reliable, robust and controlled annotation tool. Many annotation tools, often specific to certain types of data (images, text, sound, tabular data) exist; it is recommended to check their safety and relevance to the intended purpose, in particular when they incorporate a semi-automatic annotation feature. Etalab's guide to preparing and conducting its annotation campaign proposes several criteria for selecting the most appropriate text annotation software for its situation (some of these criteria remain relevant for the annotation of other types of data).

  In the event that the annotation results from a business process, the latter must incorporate the previous recommendations and make the annotation of the data a fully-fledged objective.

- **The definition of a continuous verification procedure.** This procedure to control the quality of the annotation should be implemented shortly after the start of the annotation phase and then continue through regular or continuous checks. It should be documented and may, for example, be based on:
  - discussion panels including the annotation team, the system development team, and system users when known;

  - the analysis of random samples of annotated data;

  - an internal or external audit;

  - an analysis of the relevance of annotations for each new use case requiring training data (a set of images created to train a vehicle recognition algorithm should be reviewed before being used for pedestrian detection, for example);

  - a procedure for taking into account feedback from users of the dataset or model trained on the quality of the annotation and on the corrections to be

made;

        - the quality control procedure provided for in business processes, which will have to be adapted in order to include the quality of the annotation as an objective in its own right.
- **Involve an ethics referent or committee**, as a good practice, upstream and then throughout the annotation phase. The multidisciplinary and independant nature of this committee will enable to:
    - Choose the best option for data annotation, be it through in-house processing, subcontracting (and the choice of the subcontractor), or using a solution that does not require annotation (use of an existing set or synthetic data for instance);
    - Establish an annotation protocol, in particular to select and define the labels used for the annotation;
    - Verify the application of the annotation protocol;
    - Monitor the quality of the annotations and their suitability for the intended task in the deployment phase.

      In each of these tasks, the following detailed recommendations should be taken into account by the ethics committee. Best practices concerning the objectives and composition of this committee are to be found in the how-to sheet "Taking data protection into account in the design choices of the system". It should be noted that the setting up of an ethics committee must be adapted to the structural constraints of the organisation. For less resourced structures, an ethics referent will be able to play the role of the committee;

In the case of an annotation resulting from a business process, these measures must be integrated into that process (for example, if information collected as part of the business procedure, such as a medical diagnosis, is subsequently reused for training).

Information and the exercise of rights

Persons must be informed of the annotation operations

The information of the individuals whose data are collected, whether individual or collective, must mention the annotation phase of the data (see how-to sheet "Informing data subjetcs"). In addition to the information to be provided in accordance with the GDPR, it is recommended, as a good practice, to increase transparency by providing the following information:

- the purpose of annotation, such as identifying people in an image, or matching a patient's medical diagnosis with their consultation notes.

- the organisation in charge of the annotation, whether it is a team formed by the controller, a processor, or a community of collaborators. In the case of the use of a subcontractor whose teams are located outside the European Union, the information must specify the existence of transfers outside the EU. The use of a processor must also be subject to contractual clauses such as those proposed on the CNIL's "Standard contractual clauses between controller and processor" web page.

- the criteria of corporate social responsibility met under the contract linking the persons responsible for the annotation to the controller, such as guarantees concerning working conditions, remuneration, or psychological support where the annotation relates to data that may contain shocking content.

- the security measures taken, and in particular those concerning the annotation phase.

Once the annotation has been completed, and where it is possible to inform the persons concerned a posteriori, they may be informed of the results of the annotation and in particular of the label which is assigned to their data with a view to transparency. This may be a good practice in some rare cases, in particular when:

- the annotation is likely to have consequences for people, which may be the case when its data represent the whole or a significant part of the training dataset. This may be the case when a person's data is used to fine-tune the model for its particular use on the basis of an annotated sample.

  Example: For the parameterisation of a tool to help a household to

reduce its gas consumption by automated analysis, allowing the users of the tool to confirm that the installations (such as heating, water heater or gas oven) detected are the right ones can allow a better analysis.

- the annotation is likely to have consequences for individuals, for example where unintentional disclosure of the data could damage the reputation of individuals.

Individuals must be able to exercise their rights over annotations

The rights may be exercised to labels associated with a person's data when the derogations provided for in the texts (the GDPR and the law "Informatique et Libertés") do not apply, as described in the how-to sheet dedicated to the exercise of rights . Indeed, the annotation attributed to personal data may in many cases also be considered personal data. It follows that:

- **the right of access** applies to the annotation: the information provided following a request for a right of access must contain the annotations attributed to the person's data;

- **the rights to rectification, erasure** (in particular following withdrawal of consent), **opposition, and limitation** apply to annotations. Where these rights are exercised, the same processing must be applied to the data concerned and their annotation.

- **the right to portability** applies to the annotation only where it has been provided by the person and the processing is based on the legal basis of the consent or on the basis of the contract;

Examples: In the case of medical results obtained after a blood test and collected following the patient's consent, measurements (such as blood sugar) may be training data and results (such as diagnosing diabetes), annotations. In this scenario, the right to portability applies to measurements and results, if the set was specifically provided by the patient for research purposes.

In the case of sound recordings obtained during the use of a tool such as a voice assistant where people have consented to share their data with the controller for the improvement of their language comprehension algorithm, the annotations (containing for example the analysis of the content of the recording) are provided by the controller's teams. In this scenario, the right to portability does not apply.

Distinguish annotation, profiling and automated decision-making

Although the annotation consists of assigning one or more characteristics to the data of the person who may thus constitute a profile, it is generally not a profiling defined in Article 4 GDPR or an automated decision within the meaning of Article 22 GDPR.

Indeed, the profiling referred to in the definition in paragraph 4 of Article 4 must result from automated processing, the purpose of which is to assess personal aspects, in particular to analyse or make predictions about the data subjects. The use of the word "evaluate" suggests that profiling involves some form of appreciation or judgment towards a person. In the vast majority of cases, annotating consists in a classification in order to serve as a "ground truth" for the model that will have to learn to process, classify, or discriminate data based on this information. The aim is generally not to assess by judgment individual characteristics and therefore this does not constitute profiling.

Furthermore, automated decisions referred to in Article 22 of the GDPR, which may include profiling, must have legal effects concerning the person or significantly affect the person. The annotation of a person's data for training will generally not have an impact on the data subject at this stage of data processing.

Thus, annotation will only rarely be considered profiling, and it will generally not fall within the scope of Article 22 GDPR, unlike the outputs of the AI system in the deployment phase, which can often be considered as exclusively automated decision-making.

Annotation from sensitive data

The annotation can sometimes reveal special categories of data (ethnic origin, data on the health of the data subjects, political or trade union opinion, etc.) **without the source data being itself a special category of data. The processing of this data is prohibited in principle by Article 9 GDPR; however, some exceptions exist. The organisation responsible for the annotation processing will have to identify one of these exceptions in order to be able to implement it legally.**

Example: as part of a study on the spread of disinformation online, researchers are collecting publicly accessible publications on social media.

The role of some users who have clearly made public their political affiliation on their public profile is analyzed in this study, and this membership is used to annotate publications and train an AI model. Political opinions are covered by Article 9 of the GDPR, insofar as these data have been manifestly made public, this processing is not prohibited.

This kind of annotation is therefore not impossible but is subject to special provisions which must be complied with. In the case of health research projects on data collected during care, for example, the exceptions provided for in Article 44-3 of the French Data Protection Act and 9-2-j of the GDPR may apply. The mobilisation of these exceptions and the completion of one of the formalities provided for in Article 66 of the French Data Protection Act, such as a commitment to comply with a reference methodology, or an application for authorisation granted by the CNIL, will allow the processing of annotated health data for the development of an AI system.

In view of the risks that the processing of these data entails for individuals, such as the risk of discrimination, the CNIL recommends using as much as possible other categories of data, such as synthetic data.

Where the applicable provisions are fulfilled and the treatment is lawful, special measures must nevertheless be taken in view of the increased risk to persons. In particular, the CNIL recommends the following measures:

- **Annotate according to objective and factual criteria** (such as the measurement of skin colour according to the RGB system rather than annotation of the ethnic origin of the person represented in a picture), which can be permitted by the use of technical annotation tools leaving no room for the annotator's interpretation;

- **Limit the annotation to the context of the data** by avoiding drawing conclusions beyond the information present in the data;

- **Strengthen the verification stage of annotations**, in particular with regard to their regularity (e.g. by a higher frequency), their completeness (e.g. by analysing a larger volume of data), or checking their effectiveness (e.g. by logging the results of the checks, or by an external audit of the procedure). This verification step seems particularly crucial when automatic or semi-automatic annotation tools are used;

- **Increase the security of annotated data** by performing in-house annotation processing, processing data locally, and ensuring their security through encryption, logging, and stronger access restrictions;

- **Study the risk of regurgitation and inference** of special categories of data on models trained from them. Where the controller of the annotation of the dataset does not develop a model but merely makes the data available to other bodies, it should encourage them to conduct this analysis on the models they develop. The CNIL wishes to interrogate the organisms concerned by this matter on the cases where these risks are the most important and on the measures that help in reducing them through a dedicated questionnaire (whether special categories of data are processed or not). The resulting recommendations will be published after the consultation phase. When the controller of the annotation of the data set does not train a model themselves but merely makes the data available to other bodies, it is recommended as a good practice to encourage those bodies to carry out this reflection regarding the models they develop, for example by providing information on the data distribution (such as the presence of outliers or duplicates).

13. Ensuring the security of an AI system's development

05 January 2026

The security of AI systems is an issue too often overlooked by their designers. However, it remains an obligation to guarantee data protection both during the development of the system and in anticipation of its deployment. This how-to sheet details the risks and measures to be taken as recommended by the CNIL.

This content is a courtesy translation of the original publication in French. In the event of any inconsistencies between the French version and this English translation, please note that the French version shall prevail.

The security of the processing of personal data is an obligation laid down in Article 32 of the GDPR. It states that it must be implemented taking into account "the state of the art, the costs of implementation and the nature, scope, context and purposes of processing as well as the risk of varying likelihood and severity for the rights and freedoms of natural persons". The security of processing is therefore an obligation to be implemented by risk-appropriate measures.

In practice, for the development of an AI system, including the adjustment of a pre-trained model (fine-tuning), a "traditional" security analysis should be combined, in particular on "environmental" security (including infrastructure, clearances, backups, physical security) and the security of software development and its maintenance (which includes in particular the implementation of good development practices, or the management of vulnerabilities and updates) with a risk analysis specific to AI systems and large training datasets.

This sheet details:

- The methodological approach to manage the security of the development of an AI system,
- The main security objectives to be pursued when developing an AI system,
- the risk factors to be taken into account, some of which are AI-specific,
- recommended measures to make the level of residual risk acceptable.

The methodological approach to be adopted

The security obligation laid down in the GDPR is based on the implementation of adequate measures in view of the risks to the rights and freedoms of data subjects. To this end, a risk analysis should be carried out which will make it possible to select the relevant safety measures.

In the case of the development of an AI system, this analysis may lead to the inclusion of specificities concerning the sources of risk (e.g. the provider of a re-used database), targeted tools (such as software libraries) or impacts on people (such as discrimination) that can be anticipated during the development phase.

Due to the very recent development of many approaches to developing AI systems, it is recommended to pay particular attention to the use of components (such as datasets, libraries, and infrastructures) that have not been subject to a thorough security assessment. This vigilance must be increased for uses that involve significant risks to the rights and freedoms of individuals, such as the use of sensitive data or the pursuit of high-risk purposes. The lists of Annexes I and III of the European AI Act provide useful information to determine whether the uses concerned are at high risk.

To this end, it is recommended that a Data Protection Impact Assessment (DPIA) be carried out. This analysis may be mandatory in some cases, as described in the how-to sheet "Carrying out a data protection impact assessment when necessary". The DPIA is a tool that makes it possible to identify risks and appropriate measures in a cross-cutting manner, and thus to list existing and appropriate measures.

Security objectives related to AI development

The security objectives to be pursued when developing an AI system concern:

- **the confidentiality of data:** in the case of data with restricted access, but also when it is publicly accessible (and their annotation may also include personal data), a lack of security of the dataset can lead to loss of confidentiality of the data. Breaches are also likely to occur when manipulating the model or system trained on the personal data. Indeed, risks of memorization, reconstruction or membership inference exist and may lead to the disclosure of training data. Such loss of confidentiality may have serious consequences for the data subjects, in particular on their reputation, or lead to malicious practices such as phishing. Taking into account the risks to data privacy is critical, where data is usually in large quantities and can contain personal, highly personal or sensitive data about individuals.

- **the performance and integrity of the system:** although the risks related to poor system performances only materialize in the deployment phase, the majority of measures need to be taken during the development phase. Indeed, a risk to data integrity, unreliability of the data, pre-trained models, tools or protocols used, flaws in development, testing, or organisational procedures can lead to serious consequences for users – i.e. organisations operating the AI system in the deployment phase – and thus end-users – i.e. the people to whom the output produced by the system is applied. On the other hand, systems incorporating continuous learning features need to be given increased vigilance on maintaining performance over time and monitoring their impact on people.

- **the security of the information system at large**: the functionality of AI systems generally relies largely on the models used, but the most likely risks today relate to other components of the system (such as backups, interfaces, and communications). It can thus be easier for attackers to exploit a vulnerability of the software to access training data than to carry out an attack by membership inference. The corresponding risks and measures relating to information systems are described in the CNIL's guide on the security of personal data.

Risk factors for the security of an AI system

Some factors are to be considered when assessing the level of risk for the AI system in question. These factors relate to:

- **The nature of the data:** security measures should be adapted to the seriousness of the consequences that a security breach could have for people;

  Example: a person's postal code is personal data that should be protected, but its disclosure will have fewer consequences than the disclosure of his or her bank details.

- **Control on the data, models and tools used:** AI is an area where the use of open resources, or decentralised protocols such as federated learning, is common, but the reliability of sources is not always verified. The use of these unverified tools increases the likelihood of a security breach;

  Example: AI models from collaborative platforms can contain corrupted files or backdoors and introduce a security flaw into the system, or cause unexpected behavior. These risks were highlighted in a study on the safety of the YOLOv7 model by *TrailOfBits*.

- **System access modalities** (such as restricted access, software as a service or SaaS, open source distribution of the model, web exposure) **and the content of system outputs** (such as system operation indicators, or confidence scores): access modalities increase the attack surface and can facilitate its implementation. Information on how the system works facilitates attacks such as membership or attribute inference attacks. These modalities and information thus increase the likelihood of a vulnerability;

  Example: a language model trained on personal data could have memorised training data and allow the inference of information about people. Its open source publication and use in a system will increase the possibility of such attacks. This risk should be taken into account in advance.

- **The intended use context for the AI system:** the severity of a vulnerability depends on the criticality of the system in the overall processing, both in its availability and in the role given to its outputs, as well as on the technical maturity of its users. When the AI system

interacts with other components of an information system, the quality of its outputs can be critical to security. Thus, the effective and robust integration of the AI system into information systems and its user control can reduce the likelihood of a security breach.

Example: a medical diagnostic assistance system will require more measures to improve its robustness and ownership by caregivers than an augmented reality system used for virtual dress fittings.

Security measures to consider for the development of an AI system

The following measures may be considered to ensure the security of the AI system. They concern **the training data, the development** and **operation of the system,** as well as **transversal measures.**

As mentioned above, the measures listed here are indicative and do not necessarily have to be put in place for all the development of AI systems developments: it is the responsibility of the controller to determine the measures necessary to limit the risks it has identified, taking into account its context.

Measures on training data

The quality and reliability of an AI system rely mainly on the data used for its training. The measures recommended for them and for their safety are therefore paramount. The following measures are particularly recommended:

- **Verifying the reliability of training data sources and their annotations:** this verification can take place at the stage of collection (or acquisition if the collection is carried out by a third party), and should be continued throughout the life cycle of the AI system when a change can be expected (such as when the data is collected continuously, or where there is a risk to the integrity of the data);

- **Checking the quality of the training data and their annotations:** implementing, or verifying that the collection was carried out under strict conditions, and then studying the quality of the data during collection and then during its life cycle, reduces the

risk of data quality loss (in particular where data drift could take place, such as in the case of continuous learning, or where the collection is based on sensors whose performance could be deteriorated over time);

- **Verifying the integrity of training data and their annotations throughout their life cycle:**this verification should be carried out on a regular basis, with a view to detecting the most common flaws such as attempts to poison data. These checks may be implemented by means of iterative learning control techniques, in particular through active learning, as described in the LINC article "*Sécurité des systèmes d'IA : les gestes qui sauvent*";

- **Log and versioning**: tracking and documenting changes to datasets makes it possible to detect an attempt to intrude or modify it, and thus prevent malicious disclosure or poisoning of the data. It is also recommended to keep traces of the version of the dataset on which a model has been trained;

- **Using fictitious or synthesised data:** when the use of real data is not necessary, such as for security testing, integration, or for some audits, resorting to fictitious data limits the risks to individuals. The techniques, advantages and limitations of the synthesis of data are described in the two part LINC article "Synthetic data";

- **Encrypting backups and communications**: using state-of-the-art cryptography protocols helps to limit the severity of the consequences of an intrusion, especially when web-exposed access points are provided as in the case of software as a service (SaaS), or in the case of federated learning. Recent scientific advances in the field of cryptography can provide strong safeguards for data protection. As indicated in the sheet "Taking data protection into account in the system design choices", depending on the use cases, it may be relevant, for example, to explore the possibilities offered by secure multiparty computing or homomorphic encryption. The techniques used in this field make it possible to train an AI model on data that remains encrypted throughout the learning process. However, they remain limited in that they cannot be applied to all types of models and because of the additional calculation cost they induce. In addition, some of them, such as homomorphic encryption for training neural networks, are still being studied. As technical developments are frequent in this area, it is advisable to keep an active watch on this subject;

- **Controlling access to data:** where the data is not disseminated as an open source, restrict access to the data and provide authentication procedures for access to data, according to differentiated levels of authorization according to the types of access (in particular user or administrator) prevent certain malicious intrusions, thereby reducing the risk of a loss of integrity, availability or confidentiality;

- **Anonymising or pseudonymizing data:** deletion of certain data (e.g. by obfuscation), adding random disturbances (e.g. by differential privacy), generalisation (by data aggregation or decreasing accuracy) are all categories of measures to be considered according to the types of data processed and the context in which the model is used. Such processes may in particular make it possible to visualise or export anonymised extracts from the dataset, or to anonymise query results;

- **Partitioning sensitive datasets:** where the training data contains a significant proportion of special categories of data (e.g. a health database), it is recommended to provide for logical storage partitioning, for example via encryption distinct from that of the system in which it is hosted, as well as dedicated access modalities (project-specific accounts and access rights). However, care must be taken to ensure that this partitioning does not make it easier to locate sensitive data in the information system;

- **Preventing loss of control over data by organisational measures:** monitoring and tracking of exports and data sharing helps to keep track of the data journey, in particular by following the recipients of the data. Defining a data retention period and ensuring compliance with it will also prevent loss of control in the long term. The tracking of data after its publication or sharing can be ensured through methods such as digital watermarking which will allow a posteriori verification of the origin of the data, and thus to identify the origin of a loss of confidentiality. Similar measures, such as digital watermarking or signature measures, including hashing, may also be applied to trained models in order to ensure their traceability and integrity;

Measures relating to the development of the system

From the upstream reflection of the design to the integration of the model into a system, several safety measures must be taken into account:

- **Taking data protection into account in the design choices of the system:** the methodology to be followed for this preliminary phase is described in the dedicated how-to sheet on taking data protection into account in system design. Data minimisation, which is a mandatory approach, resulting from this phase will have beneficial consequences for security by limiting the consequences for people;

- **Complying with good security practices in the field:** using libraries, tools (programming, such as development, development environments, such as version management or versioning tools, or access to data, such as APIs), pre-trained templates and verified configuration files will limit the risk of attack or failure. Special attention should be paid to the presence of backdoors in these files. A check of their reliability as well as compliance with updates is recommended. Finally, several good development practices are recommended, such as:
    - the use of secure formats for the import and backup of configuration files and templates such as safetensors (rather than formats that facilitate code injection attacks, such as YAML or pickle files);
    - prohibiting the use of overly permissive functions that could execute undetected malicious code;
    - cleaning and revising the computer code;
    - paying attention to alerts raised by tools;
    - the compilation of the code (rather than the use of tracing or scripting) in order to prevent alteration of the system's behaviour once deployed;
    - the use of relevant privacy enhancing technologies (PET).
- **Using a controlled, reproducible and easily deployable development environment:** many tools such as containers or virtual machines make it easier to control the development environment by automating its configuration. In addition, a secure test environment, often referred to as a sandbox, should be used in case of doubt. Attention should also be paid to the security of the hardware used, and the use of secure execution environments (*Trusted Execution Environement*, or TEE) should sometimes be considered. In addition, a secure test environment, often called sandbox, should be used in case of doubt;

- **Implementing a continuous development and integration procedure:** this mandatory procedure, based on a specific environment and comprehensive and robust unit testing and the modification of which is restricted by authentication, in particular for changes to the production code, will limit the risk of the insertion of a loophole into the system. Methodologies known as *DevSecOps*(for

development, security and operations) may be relevant in this context;

- **Building a comprehensive documentation:** this documentation for developers and users of the system may include information regarding:
    - the design of the system, including the data and models used and the analyses which led to their selection and validation, and the results of those analyses. An inventory of the components used, in the form of a software bill of materials, for example, may be useful in strengthening the security of the software supply chain;
    - operation of the system throughout its life cycle, performance, analysis of bias and performance obtained, conditions of use and limitations of use, such as cases where performance may be insufficient;
    - the material equipment necessary for the use of the system, the expected latency or the maximum capacity for systems accessible in SaaS;
    - the protection measures implemented, including the management of access, secrets or encryption measures;
    - any useful information concerning the anonymity and/or security of the model. For more information, see the how-to sheet on analysing the status of an AI model.
- **Conducting security audits:** these analyses can be conducted internally or by third parties, based on recognised references (see the useful resources section below), and implement the most common attack attempts on the example of red teaming.

The CNIL has also published a GDPR guide for the development team identifying a set of best practices that are applicable more generally.

Measures relating to the operation of the system

Although the risks to the operation of the system relate to the deployment phase (the security of which will be addressed in subsequent publications), it is more appropriate to take into account some of them in the development phase. These measures include:

- **Informing the user of the limitations of the in-lab system and the intended use contexts**: an explanation of the guaranteed or recommended conditions of use and conditions limiting performance or excluded (whether in terms of use or operating

conditions) is recommended;

- **Providing information enabling the user to interpret the results**: this information should in particular identify a possible error (such as a confidence score, or information on the logic of the system, such as a saliency map for detection, taking into account the risk of an attacker exploiting that information). A dedicated interface or communication channel can also be used to collect feedback from users, in order to identify and correct system defects observed during the deployment phase. This information may also be collected by providing for a specific logging of the system's outputs, in particular when it is integrated into an information system;

- **Checking the outputs of AI:** the productions of AI systems, including generative systems, can be problematic, can contain personal data, or can be misleading. Measures such as output filters, Reinforcement Learning from Human Feedback (RLHF) or digital watermarking of generated content (the effectiveness of which is demonstrated in particular on image and video content) reduce their likelihood.

Transversal measures

These measures concern the development of the system as a whole:

- **Implementing and monitoring a security action plan:** including the measures to be taken into account in an action plan will make it possible to verify their implementation and the effective reduction of risks throughout the development of the system, and until the secure deletion of the data. An incident response plan or rollback plan can also be used to plan the procedure to follow in the event of an incident, including the procedure to inform the people concerned and the authorities, if necessary;

- **Setting up a development team with multidisciplinary skills:** seeking diversified expertise and advice will help identify security vulnerabilities throughout the data lifecycle. It is recommended:
    - To include employees with complementary skills (such as data analysis and engineering, user interface and experience, quality control, IT infrastructure administration, or business need) in the development process;
    - To ensure that developers and data analysts are trained on good security practices in data management and model development, and on the most common vulnerabilities;

- **Managing clearances, tracking accesses, and analyzing traces:** restricting access to datasets and templates to authorised persons according to their profile and maintaining a list of privileged users, logging access, changes, additions and deletions to datasets and analysing these traces (in real time in an automated or, failing that, on a regular basis) reduces the likelihood and severity of an intrusion by preventing or detecting it as soon as possible;

Useful resources

The following resources will be useful in order to secure the AI system as a whole, taking into account in particular AI-specific risks:

- The ANSSI EBIOS-RM methodological guide,
- The ANSSI's Safety recommendations for generative AI systems,
- The ANSSI high-level analysis on AI "Building trust in AI through a cyber risk-based approach"
- Resources from the CNIL for the realization of a DPIA,
- The CNIL's guide to the security of personal data,
- The LINC article series on the security of AI systems,
- The report " Artificial Intelligence Cybersecurity Challenges" by the European Union Agency for Cybersecurity (ENISA),
- The Federal Bureau for Information Security (BSI)'s AI Security Guidelines,
- The OWASP AI Security and Privacy Guide,
- The "Guidelines for secure AI system development" of the National Cyber Security Centre (England),
- Mapping attacks on AI systems, or "Adversarial Threat Landscape for Artificial Intelligence Systems" (ATLAS) by MITRE,
- The project "Privacy Library of Threats 4 Artificial Intelligence" or Plot4AI,
- The "Data-Centric System Threat Modeling" and "Adversarial Machine Learning" guides of the National Institute of Standards and Technology (USA),
- Mozilla's Rapid Risk Assessment Guide.

14. Analysing the status of an AI model with regard to the GDPR

05 janvier 2026

AI models may be subjected to the GDPR if they store personal data from their training process. The CNIL proposes a method for providers to assess whether or not their models are subjected to the GDPR.

This content is a courtesy translation of the original publication in French. In the event of any inconsistencies between the French version and this English translation, please note that the French version shall prevail.

AI models can be anonymous; the GDPR does not then apply to them.

In some cases, AI models store part of the data used for their training; it then becomes possible to extract personal data from them, if some were present in the training set. When this extraction takes place using means that are reasonably likely to be used, these models fall within the enforcement scope of the GDPR. The CNIL is helping model providers to determine whether or not this is the case.

Introduction and scope of the sheet

Purpose of the sheet

This how-to sheet, intended for providers, details the methodology for assessing and documenting the likelihood of re-identification of natural persons/individuals from an AI model trained on personal data or an AI system based on a model that cannot be considered anonymous.

Once this analysis has been carried out, unless the likelihood is insignificant, the GDPR will apply to the processing operations relating to the model or system. In this how-to sheet, the **status** of a model or the use of a system will be referred to as the conclusion of the analysis with regard to the applicability of the GDPR.

This analysis will make it possible, when appropriate, to draw the consequences of the application of the GDPR, in particular through a precise/accurate assessment of the likelihood of re-identification associated with each type of personal data in the training database. A future practical sheet will specify the consequences of the GDPR enforcement to a processing operation involving an AI model.

The two figures below summarise the conduct of the analysis in the following two situations:

- **Figure 1:** Managing the analysis as a provider or representative of the status of an AI model;
- **Figure 2:** Managing the analysis as a deployer of the status of an AI system based on a non-anonymous model.

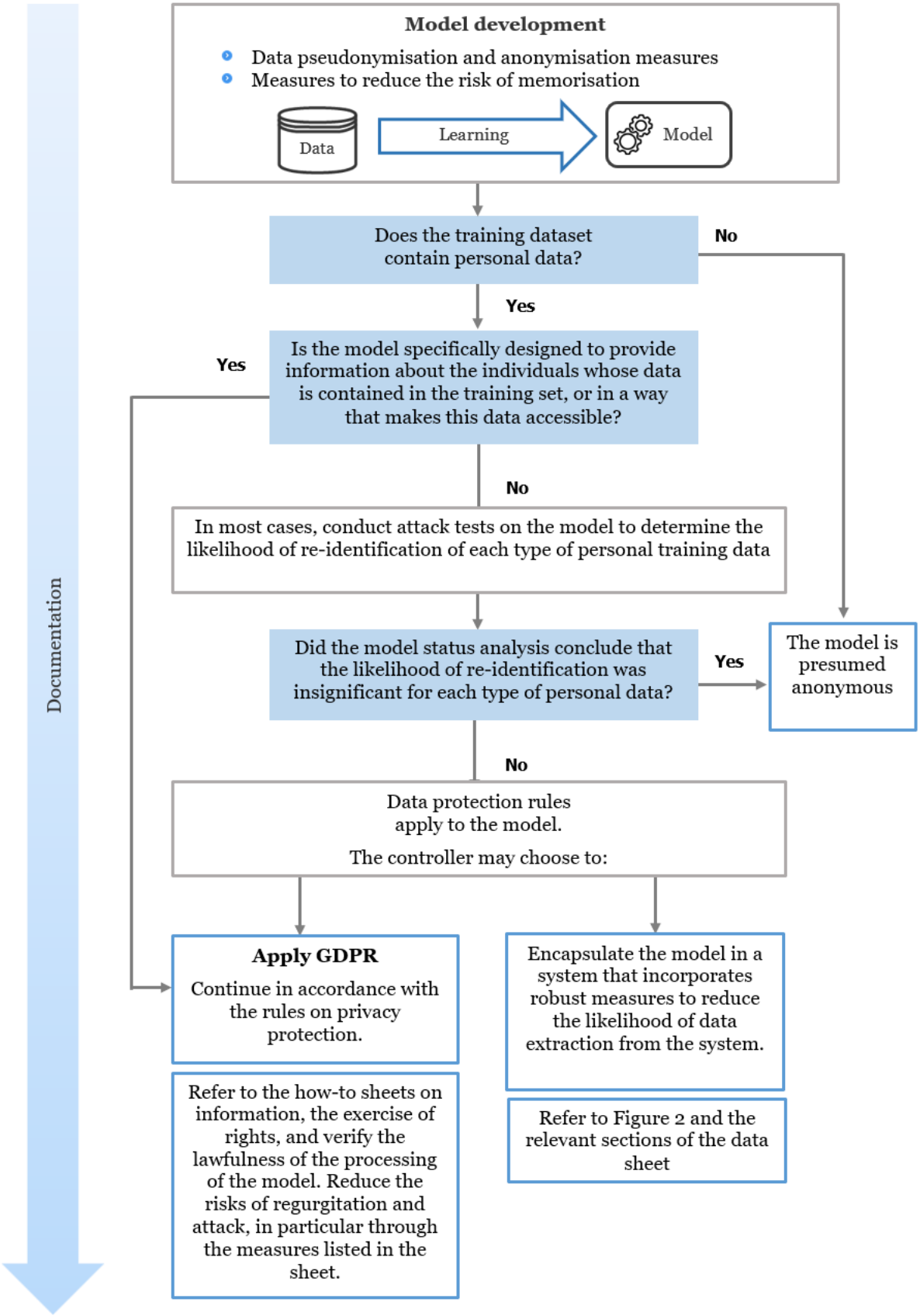


Figure 1 - Managing the status analysis of an AI model

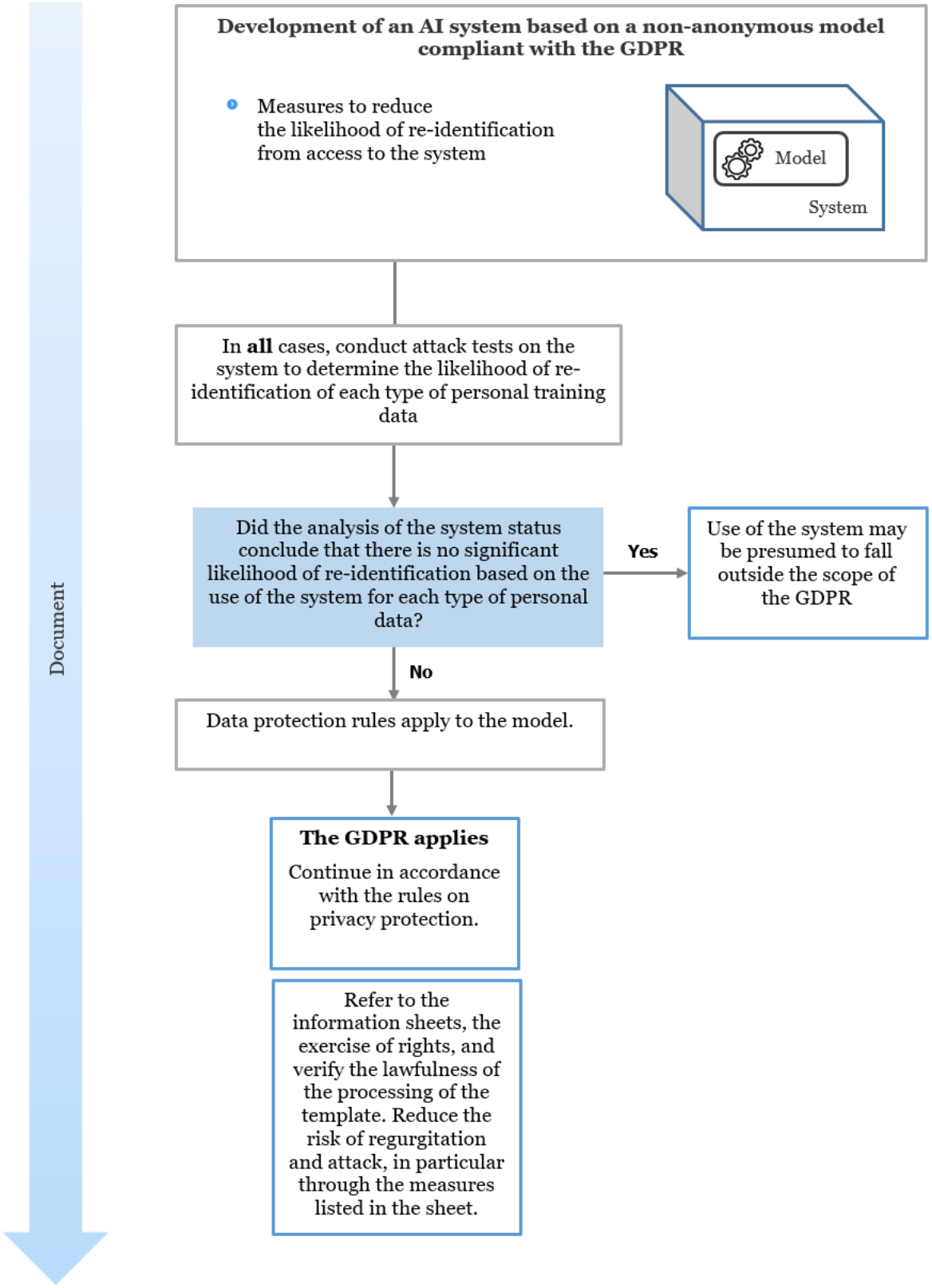


Figure 2 - Managing a status analysis of an AI system based on a non-anonymous model

AI models and systems concerned

An AI model is a statistical representation of the characteristics of the database used to train it. Numerous academic studies have shown that, in certain cases, this representation is acute enough to lead to the disclosure of certain training data. This reconstitution can take the form of data regurgitation during use in the case of generative AI systems, or following an attack such as those described in the LINC article "Small taxonomy of attacks on AI systems". **As specified in the opinion of the European Data Protection Board (EDPB) (see box), where it is possible, intentionally or unintentionally, for an AI model or system to regurgitate or be the subject of extractions of personal data using means that are reasonably likely to be used, the GDPR enforces to processings concerning the AI model or system.**

Status analysis therefore concerns any AI model trained on personal data or any AI system that incorporates a non-anonymous AI model. If the status analysis of an AI model concludes that it is excluded from the enforcement scope of the GDPR, then an AI system based exclusively on that model is also excluded.

Necessity to analyse the status of the AI model or system

Any data controller must adequately document the compliance of its personal data processing (in line with the principle of accountability), for example in a data protection impact assessment.

So then, when an AI model is trained using a database containing personal data, an analysis must be carried out systematically to determine whether the GDPR enforces to the AI model in order, where appropriate, to draw the consequences.

The model provider (to whom this how-to sheet is addressed) will most often be responsible for this development processing since that it determines the purpose and characteristics of the model (its purpose, functionalities, deployment context, etc.) as well as the personal training data. **When the latter concludes that the AI model is not subjected to the GDPR, the documentation of the analysis of the model's status must be able to be presented to the data protection authorities, such as the CNIL. It must demonstrate that the likelihood of re-identification of natural persons whose data is contained in the training base from the model or system is insignificant.**

The documentation must therefore detail the measures taken when training the model in order to limit the likelihood of re-identification from access to it, and **in most cases**, include the results of re-identification attack tests.

Where an AI model cannot be considered anonymous, consideration may be given to mitigating the likelihood of re-identification of individuals, by integrating it into an **AI system** that implements robust measures to prevent its potential extraction. In some cases, these measures may allow to remove the use of the system from the enforcement scope of the GDPR. The provider of such a system will therefore have to conduct and document its analysis, which must, **in all cases**, include the results of tests of re-identification attacks on the system.

When an AI system provider integrating a non-anonymous AI model claims that its use is no longer subjected to the GDPR, the CNIL recommends sharing or publishing sufficient documentation to allow its users to verify this status, and thus demonstrate that they are not processing personal data contained in the model. For providers of AI models analysed as anonymous, sharing this analysis is a good practice.

For the supplying of a non-anonymous AI model by its provider, the applicable obligations (including documentation) will be detailed in a later sheet. They will also apply when the model concerned is shared with a third party who intends to encapsulate it in a system to remove it from the scope of the GDPR.

Focus on EDPB Opinion 28/2024 on some data protection aspects of the processing of personal data in the context of AI models

The EDPB has adopted an opinion on the use of personal data for the development and deployment of AI models. The opinion examines 1) when and how AI models can be considered as anonymous, 2) whether and how legitimate interest can be used as a legal basis and 3) the consequences under the GDPR when an AI model is developed using personal data that has been unlawfully processed.

With regard to the status of AI models, the opinion reiterates that the question of whether a model is anonymous must be assessed on a case-by-case basis by the data protection authorities. In particular, it states:

- that a model specifically designed to produce or infer information about natural persons contained in its training set therefore contains personal data. It is subject to the GDPR.

- that, for a model trained in particular on personal data, but which is not specifically designed to produce or infer information about such

individuals, to be anonymous, it must be highly unlikely (1) for someone to directly or indirectly identify the individuals whose data has been used to create the model on the basis of the parameters of the model ("white-box attacks"), and (2) to extract such personal data from the model through queries.

The notice provides a non-prescriptive and non-exhaustive list of methods for demonstrating anonymity on which this method sheet is based.

Consequences when models or AI systems are not considered anonymous

The provider of an AI model or system subjected to the GDPR will have to comply with its obligations under the GDPR and, in France, the Data Protection Act.

The same will apply to any player in the chain (other AI system providers, distributors, deployers, etc.) who will have to comply with GDPR obligations when handling or using them.

This will involve ensuring the legality of the processing, informing individuals, enabling them to exercise their rights, guaranteeing the security of the model, etc.

In practice, compliance of the model with the GDPR relies heavily on the provider, an upcoming sheet will help players to determine their obligations. The response to these requirements, and the relevant level of guarantees, will depend on the nature of the personal data contained in the model and likely to be extracted from it.

A word of caution: it is possible that the GDPR may apply to the use of an AI model or system that is nevertheless considered anonymous by its provider. This situation is discussed at the end of this how-to sheet.

Conducting the analysis

Documenting the status analysis of an AI model or a system based on a non-anonymous model

This section aims to guide the data controller in documenting the status analysis of an AI model or the use of a non-anonymous model-based system. The following table provides a **non-exhaustive** list of information to be included in the documentation of a model or system.

TYPE OF INFORMATION	DOCUMENT	CONDITION FOR INCLUDING INF STATUS ANALYSIS DOCUME	
		Case of an AI model trained on personal data	Case of th based on
General Governance	Any information relating to a DPIA, including any assessment or decision that led to the conclusion that the DPIA was not necessary.	As soon as the information exists	As soon as exists
	Any advice or opinions given by the Data Protection Officer (DPO) (where a DPO has or should have been appointed)	As soon as the information exists	As soon as exists
	Documentation of residual risks	Including, where applicable, the documentation that is intended to be sent to the data controller deploying the system and/or to the data subjects, in particular, documentation concerning the measures taken to reduce the likelihood of re-identification and concerning possible residual risks	Including, documenta to be provi controller by its prov
Technical governance	Any information on the **technical and organisational measures taken at the design stage to reduce the likelihood of re-identification,** including scenarios by a broad set of attackers (from the weakest to the strongest) and the risk assessment on which these measures are based.	Including the specific measures taken for each source or type of source of training data, including where relevant the URLs of the sources on which these measures have been taken by the data controller (or already taken by the distributor in the case of data made available by a third party).	Including taken for e data source model, inc relevant th sources on measures the data co taken by th case of a n by a third
	The **technical and operational measures taken at any stage of the lifecycle** which have either: (i)	As soon as the information exists	As soon as exists

	contributed to or; (ii) verified the absence of personal data in the model or through the use of the system.		
Resistance to attacks	Preliminary documentation demonstrating **speculative** resistance to re-identification techniques.	As soon as the information exists, this may include in particular a theoretical analysis with regard to the state of the art (for example taking into account the ratio between the quantity of training data and the size of the model, or which aims to demonstrate the intrinsic capacity of a model to memorise data).	As soon as available, particular with regar art (e.g. ta existence measures to be got a
	The results of *ex-post*re-identification attack tests: • - Metrics on the likelihood of re-identification with respect to the current state of the art; • - Reports on how the model was tested (by whom, when, how, and to what extent); • - The results of re-identification tests by a wide range of attackers (from the weakest to the strongest).	In most cases, determined by a combination of clues. See *Characterising the necessity to carry out the re-identification attack test*	**In all case**

Characterising the necessity to test for re-identification attacks on an AI model

A set of indicators can be used to assess whether it is necessary to carry out a re-identification attack test to determine the status of the model. It is up to the data controller to assess the risk revealed by one or more of these indicators. Sometimes, a single indicator is enough to show that the risk of memorization is high, but in other cases, this same indicator may be less decisive. In these cases, the other criteria would need to be examined. This

list of indicators is for information purposes only and may change in the light of the state of the art and scientific understanding of the phenomenon of memorisation in models.

The lack of presence of these indicators does not provide any certainty about the lack of memorisation, **nor does it ever rule out the need for a re-identification attack test**: this implies that a more detailed analysis should be carried out.

For example, in the case of generative AI, **the regurgitation of** certain training data, not necessarily personal, can sometimes be demonstrated by rapid tests (such as very specific prompts). This test leads to a positive conclusion about memorisation, but does not rule it out if no data is regurgitated. The same applies to the criteria listed below: when an indication is not verified, it cannot be considered individually to have a sufficiently low likelihood of re-identification, and the others one must also be considered.

INDICATORS OF EVIDENCE OF THE PRESENCE OF PERSONAL DATA IN THE M
Indicators relating to the training data set
The identifying and precise nature of the data in the training set, such as the presence of surnames, first photographs, voice extracts, addresses or exact dates of birth. *To mitigate this:* Consider deleting identifying information, or as far as possible, using data generalisation, a perturbation or pseudonymisation technologies.
Data variety, or the presence of rare or outlier data, corresponding to unique individuals or individ characteristics are in minority in the training database. These data, by falling outside the theoretical statisti training data, are more likely to cause overfitting. During the training of the model, they will tend to be mem *To mitigate this:* carrying out a statistical pre-analysis of the training dataset to identify and then remove rar perform aggregations to smooth the statistical distribution of the training data.
The duplication of training data, i.e. the presence of exact or approximate repetitions in the training data, a factor leading to overfitting and memorising of this data. By being represented several times in the theoretic distribution of training data, duplicated personal data will tend to be memorised first. *To mitigate this:* clean up the training data set to remove both exact and approximate duplicates (deduplicati
Indicators relating to the architecture of the model and its training

The large number of model parameters in relation to the volume of training data. A larger number of p
to enable finer modelling of the training data and thus learning about the characteristics of the data and not ju
distribution. It should be noted that the limit for the number of parameters indicating a high risk of memoriz
determined according to the context, and in particular the functionality of the model or the volume of trainin

To mitigate this: Use models with fewer parameters, particularly on the basis of the state of the art.

Potential **overfitting**, using a relevant metric, i.e. the fact that a model has learned a statistical distribution t
training data.

To mitigate this:

- - Implement measures to limit overfitting, such as explicit regularisation of the cost functio
  measures such as drop-out;
- - Estimate the overfitting level of the model during the training stages, and stop training bef
  phenomenon appears.

Absence of confidentiality guarantees in the training algorithm, such as differential privacy.

To mitigate this: Implement measures to limit the impact of individual data points on the training, such as: a
guarantee acceptable levels of differential privacy (for example, by adding noise to the gradient in the optim
cost function).

The use of personal data when fine-tuning and transfer learning the model. This phase, in the same way as
of a model can lead to the memorisation of training data.

To mitigate this risk: consider making fine-tuning data anonymous, or using algorithms that provide formal
confidentiality for adjustment (expressed, for example, in terms of differential confidentiality).

Indications relating to the functions and uses of the model

Functionalities aimed at reproducing data similar to the training data, such as **content generation** or t**extual**

In the particular case of generative AI, the generation by prompt of (not necessarily personal) data (te
presumably relating to the training data.

Successful attacks on the type of model developed in a comparable context, as documented by scientific
articles.

The examples below are intended to illustrate the practical implementation of this set of indicators:

- A large language model is trained by an organisation on colossal textual datasets freely available on the Internet. The organisation reused these data sets as they were, without modifying the content. The presence of personal data in the datasets can be suspected given the wide variety of sources from which they come, the absence of measures to anonymise them, and the functionality of the model. This set of indicators leads us to conclude that it is necessary to carry out a re-identification attack test.

- A model used in the field of environmental health to predict the risk of a population exposed to certain atmospheric pollutants developing lung cancer is trained on patients' geographical data, medical history and lifestyle habits. As certain areas in the region studied are under-represented in the database, the data from certain patients constitute rare data, or outliers, in the geographical distribution of the cohort as a whole. In view of the risk that an attacker could use the prediction scores obtained by making inferences on the model trained on these people's data to know whether they have lung cancer, the criterion corresponding to the presence of rare data is deemed sufficient to consider the management of the re-identification attack test necessary.

- An energy consumption database collected from several households is used to train a neural network to recognise the domestic appliances used. If an appliance is only found in a small number of these households (this is rare data), the trained neural network could be significantly more confident in its predictions when used on data from households in the learning base that have the appliance. This difference can be used to determine the households in which the collection took place (membership inference attack). Two criteria are met here: the presence of rare data and the use of a model with a large number of parameters. Re-identification attack testing is deemed necessary.

Carrying out re-identification attack tests on an AI model

In most cases, particularly on the basis of the previous set of indicators, it will be necessary to subject an AI model trained on personal data to re-identification attacks, which may constitute means reasonably likely to be used to re-identify individuals. The purpose of these attack tests is to

estimate the likelihood of re-identification of individuals based on the model. To conclude that the model is anonymous, the likelihood of extraction by reasonable means must be insignificant.

Determining the means reasonably likely to be used to extract data from an AI model

Characterising the means reasonably likely to be used by the controller or any other person is an essential step in analysing the status of the model. This characterisation must be based on objective criteria, which may include:

- additional information which would allow re-identification, and which would be accessible to the person;
- the cost and time required for such a person to obtain this additional information;
- the state of the art of technology available and in development, in particular concerning techniques for extracting data from AI models.

The assessment of the means reasonably likely to be used must take into account the possibility of access to the model not only by the data controller, but also by third parties who should not have had access to it. Although measures to reduce the likelihood of personal data being extracted can be taken during both the development and deployment of an AI model, the assessment of the anonymity of the model must also take into account the possibility of direct access to it.

Simply restricting access to the data (and/or the model) does not systematically guarantee its anonymity. However, limited access can reduce the likelihood of re-identification (without automatically make it insignificant). The means reasonably likely to be used to extract personal data may depend on the context in which a model is developed and deployed. As a result, the levels of testing and resistance to attack required may vary according to this context. The conclusion of the analysis may therefore be different between a model that is publicly accessible to an unlimited number of users and a model that is internal to a company with access limited to only a few employees, as it is detailed later in this document on the analysis of AI systems based on non-anonymous models.

The criteria set out above take account of the technical specificities of AI models and the way they are designed. They cannot therefore be automatically transposed to the analysis of anonymisation in other fields. Furthermore, legal and contractual guarantees aimed at limiting the access or use of a model do not replace the anonymisation techniques that could be

implemented on the training dataset or during the learning phase, but complement them.

AI model testing and resistance to attack

The following list provides criteria that can be used to assess the likelihood of an AI model trained on such data being extracted from personal data using attack techniques.

The relevance of the scope, frequency, quantity and quality of the data extraction tests that the data controller has carried out on the model must be assessed in the light of the state of the art, as well as the means reasonably likely to be used in relation to the model. These tests may include in particular:

- Training data regurgitation tests, in the case of generative AI models;
- Membership inference attacks;
- Exfiltration attacks;
- Model inversion attacks;
- Reconstruction attacks;
- A measure of the intrinsic memory capacity of the model architecture.

It should be noted that resistance to a technique implementing one of these types of attack does not prejudge resistance to another technique.

Recommendations concerning the management of tests and attacks

Certain types of attack presented above require demanding technical knowledge and resources to be implemented. It is therefore recommended that attacks on the AI model should be carried out with increasing difficulty of implementation. When an attack allows personal data to be extracted from the AI model, the type of personal data concerned by this extraction must be determined. The data controller can then choose to:

- **Stop the analysis at this stage**, considering that all the data types present in the training set can be extracted with the likelihood given by the easiest attack having succeeded on a particular type;

- **Continue the analysis by managing all the tests and attacks** constituting means reasonably likely to be used, in order to establish the likelihood of extraction associated with each type of training data. More in-depth re-identification tests may, for example, make it possible to separate the likelihood of extraction from pre-training and fine-tuning data, which may present different risks for the individuals concerned.

Example: The data office of a hospital wants to develop a large language model to help write medical consultation reports. To do this, it pre-trains a large language model on the basis of publicly accessible data (to equip it with certain textual skills), then carries out a fine tuning phase on the basis of a dataset of previously pseudonymised medical reports (to specialise in this type of text). After the fine-tuning phase on sensitive personal data, the indicators of evidence concluded that it was necessary to conduct re-identification attack tests. During the testing and attack phase, the data controller begins by performing simple queries on the model in an attempt to extract training data. The result is that simple queries can be used to extract personal data from the pre-training dataset. At this stage, the data controller may:

- Stop conducting the analysis, and considering in the consequences of the application of the GDPR that all types of training data, including sensitive data from the fine-tuning phase but which have not been extracted at this stage of the analysis, can be extracted from the model with simple attacks, and therefore, a high likelihood;

- Continue the analysis using attacks that are more difficult to implement, in order to accurately assess the likelihood of extraction of sensitive data, in order to refine the analysis of the consequences of applying the GDPR. The guarantees to be implemented will not be the same depending on whether the personal data contained in the model is publicly accessible data or confidential and sensitive data from the adjustment phase.

Once this analysis has been carried out, the data controller will be able to determine whether the GDPR applies to its model. If this proves to be the case, various consequences may follow. A future how-to sheet will specify the consequences of the application of the GDPR to processings concerning an AI model in the near future.

Reducing the likelihood of re-identification from an AI system based on a non-anonymous model

When an AI system is based on an AI model that falls within the scope of the GDPR, it is possible to put in place measures which, if sufficiently effective and robust, could make it possible to render the likelihood of re-identification of individuals insignificant. The use of the latter could then fall outside the scope of the GDPR, subject to the results of the analysis to be carried out. To do this, the provider of the AI system that it plans to

anonymise will have to **assess the likelihood of re-identification, in particular on the basis of attack tests on the system.** This section is intended to guide this analysis.

Please note: The following developments are not transposable to other forms of anonymisation analysis.

The following list details measures that can reduce the likelihood of re-identification from an AI system incorporating a model for which this likelihood is not insignificant. This list is indicative, and does not prejudge the existence of other sufficiently robust measures to reduce this likelihood.

MEASURES REDUCING THE LIKELIHOOD OF RE-IDENTIFICATION AT SYSTEM
Impossibility of direct access or recovery of the model from interactions with the system. It must be imp of the system, even a malicious one, to access the model directly or to recover it using any means reasonably
Restrictions on access to the system, such as: • - access subject to authentication to authorised persons only, • - ensuring that the system user is human, for example by using CAPTCHA (**Completely Au Turing test to tell Computers and Humans Apart**), • - restrictions imposed on users (for example on the number of inferences per user - which is itself, for example in the event of collusion between attackers - or the possibility of modifyin of the generation algorithm, such as temperature), • - or any other measure that sufficiently limits the system's attack surface.
Modifications made to the model's outputs to limit the risk of re-identification of individuals from access users. For example, it is possible to: • **- Limit the precision of the model's outputs** through the system, for example by roun noising the output vector. Great care must be taken when implementing these measures, an based on reliable, state-of-the-art research. Indeed, some of them have been shown to be in (such as limiting the output of a classification system to a single value rather than the full ve counter-intuitively, this filter does nothing to prevent an attack). • **- Filtering model output**, for example in the case of generative AI, to detect personal dat exposure to system users. Great care must be taken when implementing these measures, an based on reliable research that complies with the state of the art. Indeed, some of them (suc name generation based on a blacklist) have been shown to be ineffective in practice.
Security measures designed to prevent or detect attempted attacks, such as encrypting the model, logging a modifications and uses of the model, or using strong authentication methods.

Carrying out re-identification attack tests on an AI system based on a non-anonymous model

The aim of these tests is to estimate the likelihood of personal data being extracted from use of the system, and from any means reasonably likely to be used, including attack methods whose result is probabilistic. In order to consider that the use of the AI system does not fall within the scope of the GDPR, this likelihood of extraction must be insignificant.

Determining the means reasonably likely to be used to extract data from an AI system

As with the analysis of the status of models, the characterisation of the means reasonably likely to be used is an essential step in managing the analysis of the status of the use of the system. This characterisation must be based on objective criteria, which may include:

- the context in which the AI system is deployed, which may include access limitations as well as legal protections;
- the extent of access to the internal workings of the model through use of the system;
- additional information that would enable re-identification, and that would be accessible to the individual, including beyond publicly available sources;
- the cost and time required for such a person to obtain this additional information;
- the state-of-the-art technology available and in development, in particular concerning techniques for extracting data from AI systems.

The assessment of the means reasonably likely to be used must take account of the possibility of access to the system by any person, considering the case of persons who should not have had access. It should be noted that simply restricting access to the model and/or the system does not systematically guarantee their anonymity. Restricted access may reduce the likelihood of re-identification (without, however, automatically rendering it insignificant). Furthermore, legal and contractual guarantees aimed at limiting access to or use of a model do not replace anonymisation techniques, but can complement them. As a result, the levels of testing and

resistance to attack required may vary according to this context. The conclusion of the analysis may therefore be different between an AI system that is publicly accessible to an unlimited number of users and one that is internal to a company with access limited to a small number of employees, although this is no substitute for minimising the likelihood of personal data being extracted from the model.

AI system testing and resistance to attack

This section aims to guide the assessment of the likelihood of re-identification by attacks, through the use of the system by any person.

The appropriateness of the scope, frequency, quantity and quality of the data extraction tests that the controller has carried out on the system must be assessed in the light of the state of the art, as well as the means reasonably likely to be used to re-identify individuals from use of the system, including in the near future. These tests may include in particular:

- Tests aimed at obtaining partial or direct access to the AI model through use of the system;
- Training data regurgitation tests, in the case of generative AI models;
- Membership inference attacks;
- Exfiltration attacks;
- Model inversion attacks;
- Reconstruction attacks.

It should be noted that resistance to a technique implementing one of these types of attack does not prejudge resistance to another technique.

Recommendations concerning the management of tests and attacks

Certain types of attack presented above require demanding technical knowledge and resources to be implemented. It is therefore recommended that attacks on the AI system should be carried out with increasing difficulty of implementation. When an attack enables personal data to be extracted from the AI system, the type of personal data concerned by this extraction must be determined. The data controller may then choose to:

- **Stop the analysis at this stage,** considering that all the data types present in the model can be extracted with the likelihood given by the easiest attack having succeeded on a particular type;

- **Continue the analysis by carrying out all the tests and attacks** that are reasonably likely to be used, in order to establish the likelihood of extraction associated with each type of training data.

More in-depth re-identification tests may, for example, make it possible to separate the likelihood of extraction from pre-training and adjustment data, which may present different risks for the individuals concerned.

Cases where AI models or systems incorporating them are wrongly excluded from the scope of the GDPR

Re-identification of individuals from a model may occur when the provider had considered its likelihood to be insignificant, for example if the provider was unaware of a vulnerability or because of improvements in data extraction techniques.

For this reason, as part of their security obligations, **the CNIL recommends that providers regularly check the validity of their analysis** (taking into account developments in the state of the art), **and anticipate any data breaches that may occur.**

It is good practice to provide a means for users to report incidents (e.g. via a function in the system interface, a contact form or model version management). This practice complements the obligations of the European AI Act (AIA), which provides for post-market surveillance of providers of high-risk AI systems (article 72 of the AIA) and for the reporting of these risks by the deployers of such systems (article 26 of the AIA).

Where an extraction of personal data takes place, any exploitation of the vulnerability should be prevented and, where possible, consideration should be given to whether the re-identification vulnerability has been exploited, and by whom. The provider will also have to consider whether there has been a data breach (within the meaning of Article 33 of the GDPR) and to draw the consequences, in particular to document this data breach (including the nature of the data, the method of distribution and the resulting consequences), to notify the CNIL within 72 hours if this breach is likely to give rise to risks for individuals, and even to inform individuals if the risks in question are high (Article 34 of the GDPR), by documenting.

Please note: The fact that the extraction of personal data is described as a data breach does not necessarily mean that the provider is at fault. For example, the provider may not be held liable if it has concluded that its model is anonymous by carrying out a sufficient and properly documented analysis, and that an extraction is subsequently made possible by an unforeseeable change in the state of the art, but that the provider reacts correctly to this data breach by properly fulfilling its obligations in this area.

Depending on the seriousness of the incident, and any resulting breaches of the GDPR, the CNIL may require to re-train or remove the model in question.

15. CHECKLIST

Development of AI Systems: What should be checked?

The CNIL provides a checklist of points to verify, based on its recommendations for the development of AI systems compliant with the GDPR.
This checklist is intended for designers and developers of AI systems (product managers, developers, data protection officers, legal teams, chief information security officers, etc.) in order to secure all stages of the development of an AI system, from data collection to integration, including model training and annotation. This checklist aims to ensure that, from the very start, the principles of the GDPR are correctly implemented: purpose limitation, data minimization, security, information, data subject rights, transparency, and governance.
Please note: Where applicable, the obligations established by the EU AI Act should also be considered during the development of these systems. These obligations are not addressed in this checklist.

Identify whether the training dataset contains personal data (including data obtained through web scraping).
Identify whether the GDPR applies
Analyze whether the GDPR applies to the model learned from training dataset containing personal data or whether it can be presumed to be anonymous.
• To do this, establish the necessity of conducting re-identification attacks on the AI model, the depth of these attacks, and the likelihood of extraction of personal data, providing as much detail as possible by data type.

Determine the applicable legal framework and your responsibility
If you believe that a system incorporating a non-anonymous AI model may fall outside the scope of the GDPR, ensure that the measures put in place are sufficiently effective and robust to render the likelihood of re-identification of individuals insignificant.
• This assessment necessarily involves conducting re-identification attacks on the AI system.
Implement a process for regularly reassessing the anonymity of the model or system.
Determine your responsibility and that of other parties involved in the processing of personal data (data controller, joint controller, or processor).
Define the responsibilities of the relevant actors
Where applicable, make sure you sign a contract to outline joint liability.
Where applicable, make sure you enter into a contract to document the instructions given to your subcontractors.
Define the purposes
Clarify the purpose(s) of the project from the design phase
• If it is general-purpose AI, refer to the type of system developed (e.g., the development of a large language model, a computer vision system) as well as the technically feasible features and capabilities.

Define the purposes and choose the legal basis
Identify the legal basis for each processing (consent, legitimate interest, etc.).
Identify the legal basis
Where applicable, document the methods used to obtain consent and retain proof thereof (Article 6.1.a of the GDPR).
Where applicable, ensure that you have a valid contract and that the processing is necessary to fulfill the purpose of the contract (Article 6.1.b of the GDPR).
Define clearly the objective pursued.
Verify the existence of a legitimate interest
Verify that the interest does not conflict with other regulatory obligations (Digital Services Act, Artificial Intelligence Act, etc.).
Ensure that the processing of personal data is necessary to achieve the defined purpose.
Check that less intrusive methods (e.g., anonymization, synthetic data) cannot achieve the same results.
Assess the need for processing
Ensure that the algorithmic techniques used for data processing (e.g., deep convolutional neural networks, support vector machines, etc.) consume as little personal data as possible for the intended purpose. If necessary, document the need to use machine learning, particularly deep learning.

Where applicable, assess the validity of the legal basis for legitimate interest (Article 6.1.f of the GDPR)
Check whether design choices can be taken into account with a view to data protection by design (federated learning, secure multi-party computation, homomorphic encryption, etc.).
Ensure and document that the data subjects can reasonably expect this processing.
Balancing the interests at stake
Where applicable, implement and document appropriate and sufficient safeguards to limit the impact of processing on data subjects (e.g., provide for the rapid anonymization of collected data or, failing that, pseudonymize the data collected, adopt measures to limit the risks of memorization, extraction, regurgitation in the context of generative AI or attacks on AI models or systems, provide for a discretionary and prior right to object, etc.).
Where applicable, implement appropriate safeguards for web scraping (e.g., limit collection to freely accessible data, establish a list of sites from which collection would be excluded by default because they contain particularly intrusive data).

In case of data reuse, perform additional tests and checks
Limit the data processed to what is relevant and

necessary (data minimization)
Define and monitor data retention periods
If you reuse your own data
If you reuse publicly available data or data acquired from a third party (e.g., data broker)
Selection of strictly necessary data
Implement specific measures in the event of web scraping
Specific precautions for sensitive data
Organization of data collection and preparation
Justification and validation of design choices
Continuous reassessment
Define a clear retention policy from the design stage
Retention during the development phase
Retention for the purpose of maintaining or improving the product

If the training purpose of your model was not defined at the time of data collection, ensure that its compatibility with the original purpose through a compatibility test (unless you are authorized by the data subjects' consent or by law, or if you reuse the data for statistical or scientific research purposes):
• Is there a link between the initial purpose and the new AI purpose?
• Does the context of the initial collection reasonably allow for this reuse?
• What is the type and nature of the data (identifiers, sensitive data, etc.)?
• What are the possible consequences for individuals?
• What technical and organizational safeguards are in place (pseudonymization, etc.)?
Check that you are not reusing a dataset that was clearly created illegally:
• Is the source of the data clearly identified and documented?
• Is the dataset the result of a crime or offense (leakage, theft, etc.) or has it been the object of a conviction or public sanction by a competent authority that has resulted in its removal or prohibition from use?
• Are the conditions under which the data was collected sufficiently documented?
• Does the dataset contain any sensitive or infringing data, or are enhanced checks carried out to ensure that the processing is lawful if so?
Identify the data that is essential to achieving your objectives and favor less intrusive formats (e.g., age range rather than full date of birth).
Regarding data volume, justify the number of data subjects, historical depth, and granularity.
Justify the need to process highly personal data.
Regarding data types, evaluate the use of real data and synthetic, pseudonymized, or anonymized data.
Identify data sources.
Define specific collection criteria in advance.
Exclude the collection of certain categories of data when they are not necessary, using filters where possible or, failing that, by excluding certain types of sites that structurally contain these categories of data.
Exclude from data collection any websites that explicitly oppose the scraping of their content, for example through the use of robots.txt files or the implementation of CAPTCHA.
Justify the need to process sensitive data.
Identify exceptions to the principle prohibiting the processing of sensitive data (Article 9.2 of the GDPR).
Provide for enhanced security measures (pseudonymization, etc.).
Immediately delete, if possible automatically, any sensitive data collected incidentally and residually during web scraping.
Clean up the data (inconsistencies, duplicates, etc.).
Identify the data that is truly relevant to the task and delete data that is not relevant for learning.
Apply data protection techniques from the design stage (e.g., generalization, randomization, pseudonymization, anonymization, etc.).
Conduct a test run with fictitious, synthetic, or anonymized data.
Consult an ethics advisor or committee on issues related to ethics and the protection of individuals' rights and freedoms.
Establish a process for regularly reviewing the relevance of the data collected.
Establish mechanisms for deleting unnecessary or obsolete data.
Define a specific retention period for each phase of the AI project lifecycle (development, maintenance, improvement, etc.).
Ensure that data is only accessible to authorized persons during development.
Establish a process for archiving or deleting data at the end of the development phase, unless it is necessary to retain the data for maintenance or improvement of the product.
Document the need to retain data beyond development, particularly for product maintenance or improvement.
Verify that data is stored on a secure, segmented medium.
Verify that access is strictly limited to individuals responsible for product maintenance or improvement.
Implement an automatic deletion plan once the improvement has been made.

Ensure transparency of the processing
Implementation of procedures for rights management
Manage identification of individuals
Respect the rights of individuals
Selecting a technical solution to ensure compliance with model rights

Ensure data
annotation
compliance

Inform data subjects in a clear and easily accessible manner of all the information provided for in Articles 13 and 14 of the GDPR.
When data is not collected directly from individuals, document, where applicable, the fact that individual information would require disproportionate effort (Article 14.5.b of the GDPR) and make the information publicly available (website, etc.).
If web scraping involves a limited number of sites, provide precise information on the sources used. If there are a large number of sources, provide the categories of source sites, at least those that pose the greatest risk to individuals.
When the model itself is subject to the GDPR, inform individuals about the data stored and provide all the information required by Articles 13 and 14 of the GDPR.
Inform individuals of the risk of data regurgitation in the case of generative AI, the measures taken to limit these risks, and the existing recourse mechanisms (e.g., the possibility of reporting an instance of regurgitation).
Establish a procedure for notifying recipients, in particular users, of any request for rectification, erasure, or restriction of data, unless such communication proves impossible or requires disproportionate effort.
For generative AI, set up an internal process (like using a list of selected queries) to see what data the model might have stored about the person based on the input.
If it is not possible to identify a data subject within the model but they are identified in a training dataset, inform them of the risk of model memorization.
If it is not possible to identify a data subject in the training dataset or within the model, inform them.
Inform the data subject of any additional information that can be provided to help identify them (e.g., pseudonym, sample of their data).
Establish a process for deleting this additional data after the request has been processed.
In principle, plan for a model retraining process.
• Retraining can be periodic to limit costs and fulfill multiple requests for rights exercises at the same time
Provide users with an updated version of the model, possibly by contractually requiring them to use only a regularly updated version
Where applicable, document the fact that retraining the model is disproportionate (temporarily or permanently).
If retraining is disproportionate, implement filters or other robust measures on the outputs of the AI system.
Where applicable, general rules preventing the generation of personal data should be preferred to a simple “blacklist” of individuals who have exercised their rights.
Ensure that annotations include only the information required to fulfill the purpose and that they remain objective.
Conduct regular reviews to ensure that labels remain relevant.
Establish a continuous verification procedure to monitor the quality of annotation: define an annotation protocol, applying the principles of accuracy and minimization, and involve an ethics advisor or committee (good practice).
Inform data subjects about the data annotation phase.
Ensure that internal rights management procedures and terms and conditions for exercising rights include annotation (right of access, rectification, erasure, restriction, portability, and objection)
Where applicable, verify that sensitive data is processed in accordance with an exception to the data prohibition principle (Article 9.2 of the GDPR).
Implement specific measures to address the increased risk to data subjects: annotate according to objective and factual criteria, limit annotation to the context of the data, strengthen the annotation verification stage, increase the security of annotated data (e.g. by performing annotation processing internally, processing data locally, and ensuring its security through encryption, logging, and stronger access restrictions) and consider the risk of regurgitation and inference of sensitive data on models trained from them.
Train the individuals responsible for annotation on the principles relating to data protection.

Ensure data security
Analyze risks and
conduct a data
protection impact
assessment (DPIA)

Ensure that the security measures applied to the training data are adequate and fit for purpose (see the practice guide for the security of personal data).
Ensure that the security measures applied to system development are adequate and appropriate, notably by using verified development tools, libraries, and, where applicable, pre-trained models.
Ensure that the measures in place to govern the system’s operation are adequate and appropriate for example, by using verified import and storage formats such as safetensors, monitoring AI outputs with filters, and implementing watermarking techniques.
Manage data access permissions, keep records of all access, and regularly review those logs.
Implement and monitor an action plan to ensure that safety requirements are met.
Carry out a DPIA if the model training processing presents high risks according to the criteria established by the European Data Protection Board (innovative use, large scale, sensitive data, vulnerable individuals, etc.).
Include specific AI risks (automated discrimination caused by bias introduced during development, risk of producing fictitious content about a real data subject, risks related to known attacks specific to AI systems, etc.) and take appropriate measures.